

معيـار التحقـق من أمان التطبيقات

الإصدار 5.0.0



مايو 2025

المحتويات

البداية

7	عن المعيار
7	حقوق النشر والترخيص
7	قادة المشروع
7	مجموعة العمل
7	مساهمون رئيسيون آخرون
8	مساهمون ومراجعون آخرون

تمهيد

8	مقدمة
8	المبادئ التي يستند إليها الإصدار 5.0
9	نظرة إلى الأمام

ما هو معيار التحقق من أمان التطبيقات؟

9	نطاق معيار التحقق من أمان التطبيقات
9	التطبيق
10	الأمان
10	التحقق
10	المعيار
10	المتطلب
10	القرارات الأمنية المؤتمّنة
11	مستويات التحقق من أمان التطبيقات
12	تقييم المستويات
12	المستوى 1
12	المستوى 2
12	المستوى 3
13	أي مستوى ينبغي تحقيقه
13	كيفية استخدام معيار التحقق من أمان التطبيقات
13	بنية معيار التحقق من أمان التطبيقات
13	استراتيجية الإصدار
13	المرونة في معيار التحقق من أمان التطبيقات
14	كيفية الإشارة إلى متطلبات معيار التحقق من أمان التطبيقات
14	تفريع معيار التحقق من أمان التطبيقات
15	حالات استخدام معيار التحقق من أمان التطبيقات
15	كإرشادات مفصّلة لمعمارية الأمان
15	كمراجع متخصص للبرمجة الآمنة
15	كدليل لاختبارات الوحدة والتكامل المؤتمّنة
15	للتدريب على التطوير الآمن
16	كإطار لتوجيه شراء البرمجيات الآمنة

16	تطبيق معيار التحقق من أمان التطبيقات عملياً
16	التقييم وإصدار الشهادات
16	موقف OWASP من شهادات معيار التحقق من أمان التطبيقات وعلامات الثقة
16	كيفية التحقق من الامتثال لمعيار التحقق من أمان التطبيقات
16	إعداد تقارير التحقق
16	نطاق التحقق
17	آليات التحقق
18	التغييرات مقارنةً بالإصدار 4.x
18	مقدمة
18	فلسفة المتطلبات
18	النطاق والتركيز
18	التأكيد على الأهداف الأمنية بدلاً من الآليات
18	القرارات الأمنية الموثقة
19	التغييرات الهيكلية والفصول الجديدة
19	إزالة التخطيطات المباشرة إلى المعايير الأخرى
19	تقليل الارتباط بإرشادات الهوية الرقمية من NIST
20	الابتعاد عن تعداد نقاط الضعف الشائعة (CWE)
20	إعادة النظر في تعريفات المستويات
20	مستوى دخول أسهل
20	مغالطة القابلية للاختبار
20	ليس الأمر متعلقاً بالمخاطر وحدها
21	V1 الترميز والتنقية
21	الهدف من ضوابط الأمان
21	V1.1 معمارية الترميز والتنقية
21	V1.2 منع الحقن
23	V1.3 التنقية
24	V1.4 الذاكرة والسلاسل والشفرة غير المدارة
24	V1.5 فك التسلسل الآمن
25	المراجع
25	V2 التحقق من الصحة ومنطق العمل
25	الهدف من ضوابط الأمان
25	V2.1 توثيق التحقق من الصحة ومنطق العمل
26	V2.2 التحقق من صحة المدخلات
27	V2.3 أمان منطق العمل
27	V2.4 مكافحة الأتمتة
28	المراجع

28	V3 أمان واجهة الويب الأمامية
28	الهدف من ضوابط الأمان
28	V3.1 توثيق أمان واجهة الويب الأمامية
28	V3.2 التفسير غير المقصود للمحتوى
29	V3.3 إعداد ملفات تعريف الارتباط
30	V3.4 ترويسات آليات أمان المتصفح
31	V3.5 فصل الأصول في المتصفح
32	V3.6 سلامة الموارد الخارجية
32	V3.7 اعتبارات أخرى لأمان المتصفح
33	المراجع
33	V4 واجهات برمجة التطبيقات وخدمات الويب
33	الهدف من ضوابط الأمان
33	V4.1 الأمان العام لخدمات الويب
34	V4.2 التحقق من بنية رسائل HTTP
35	V4.3 GraphQL
35	V4.4 WebSocket
36	المراجع
36	V5 التعامل مع الملفات
36	الهدف من ضوابط الأمان
36	V5.1 توثيق التعامل مع الملفات
36	V5.2 تحميل الملفات ومحتواها
37	V5.3 تخزين الملفات
37	V5.4 تنزيل الملفات
38	المراجع
38	V6 المصادقة
38	الهدف من ضوابط الأمان
39	V6.1 توثيق المصادقة
39	V6.2 أمان كلمات المرور
40	V6.3 الأمان العام للمصادقة
41	V6.4 دورة حياة عوامل المصادقة واستعادتها
42	V6.5 المتطلبات العامة للمصادقة متعددة العوامل
43	V6.6 آليات المصادقة خارج النطاق
43	V6.7 آلية المصادقة التشفيرية
44	V6.8 المصادقة عبر مزود هوية
45	المراجع
45	V7 إدارة الجلسات
45	الهدف من ضوابط الأمان
46	V7.1 توثيق إدارة الجلسات

46	V7.2 الأمان الأساسي لإدارة الجلسات
47	V7.3 مهلة الجلسة
47	V7.4 إنهاء الجلسة
48	V7.5 الدفاعات ضد إساءة استغلال الجلسة
48	V7.6 إعادة المصادقة الاتحادية
49	المراجع
49	V8 التحويل
49	الهدف من ضوابط الأمان
49	V8.1 توثيق التحويل
50	V8.2 التصميم العام للتحويل
50	V8.3 التحويل على مستوى العمليات
51	V8.4 اعتبارات أخرى للتحويل
51	المراجع
51	V9 الرموز المميزة المكتفية بذاتها
51	الهدف من ضوابط الأمان
51	V9.1 مصدر الرمز المميز وسلامته
52	V9.2 محتوى الرمز المميز
53	المراجع
53	V10 معياري OAuth وOIDC
53	الهدف من ضوابط الأمان
54	V10.1 الأمان العام ل OAuth وOIDC
55	V10.2 عميل OAuth
55	V10.3 خادم موارد OAuth
56	V10.4 خادم تحويل OAuth
58	V10.5 عميل OIDC
58	V10.6 مزود OpenID
59	V10.7 إدارة الموافقة
59	المراجع
60	V11 التشفير
60	الهدف من ضوابط الأمان
60	V11.1 جرد التشفير وتوثيقه
61	V11.2 التنفيذ الآمن للتشفير
62	V11.3 خوارزميات التشفير
62	V11.4 التلييد والدوالّ المبنية على التلييد
63	V11.5 القيم العشوائية
63	V11.6 تشفير المفتاح العام
64	V11.7 تشفير البيانات قيد الاستخدام
64	المراجع

64	V12 الاتصال الآمن
64	الهدف من ضوابط الأمان
65	V12.1 إرشادات عامة لأمان TLS
65	V12.2 اتصالات HTTPS مع الخدمات الموجهة إلى الخارج
66	V12.3 الأمان العام للاتصال بين الخدمات
66	المراجع
66	V13 التكوين
66	الهدف من ضوابط الأمان
67	V13.1 توثيق التكوين
67	V13.2 تكوين اتصالات الواجهة الخلفية
68	V13.3 إدارة الأسرار
69	V13.4 تسريب المعلومات غير المقصود
69	المراجع
69	V14 حماية البيانات
69	الهدف من ضوابط الأمان
70	V14.1 توثيق حماية البيانات
70	V14.2 الحماية العامة للبيانات
71	V14.3 حماية البيانات من جانب العميل
71	المراجع
72	V15 البرمجة الآمنة والمعمارية
72	الهدف من ضوابط الأمان
72	V15.1 توثيق البرمجة الآمنة والمعمارية
73	V15.2 معمارية الأمان والتبعيات
74	V15.3 البرمجة الدفاعية
74	V15.4 التزامن الآمن
75	المراجع
75	V16 تسجيل الأحداث الأمنية ومعالجة الأخطاء
75	الهدف من ضوابط الأمان
76	V16.1 توثيق تسجيل الأحداث الأمنية
76	V16.2 تسجيل الأحداث العام
77	V16.3 الأحداث الأمنية
77	V16.4 حماية السجلات
77	V16.5 معالجة الأخطاء
78	المراجع
78	WebRTC V17
78	الهدف من ضوابط الأمان
79	V17.1 TURN خادم

79	 V17.2 الوسائط
80	 V17.3 الإشارات
81	 المراجع

81 الملحق أ: قائمة المصطلحات

86 الملحق ب: المراجع

86	 مشاريع OWASP الأساسية
86	 مشروع سلسلة الأوراق المرجعية من OWASP
87	 المشاريع المتعلقة بأمان الأجهزة المحمولة
87	 مشاريع OWASP المتعلقة بإنترنت الأشياء
87	 مشاريع OWASP الخاصة بالحوسبة بلا خادم
87	 أخرى

87 الملحق ج: معايير التشفير

88	 جرد التشفير وتوثيقه
88	 القوى المكافئة لمعاملات التشفير
89	 القيم العشوائية
89	 خوارزميات التشفير
90	 أنماط تشفير AES
91	 تغليف المفاتيح
92	 التشفير المصادق عليه
92	 دوال التليد
92	 دوال التليد لحالات الاستخدام العامة
93	 دوال التليد لتخزين كلمات المرور
94	 دوال اشتقاق المفاتيح (KDFs)
94	 دوال اشتقاق المفاتيح العامة
94	 دوال اشتقاق المفاتيح القائمة على كلمات المرور
95	 آليات تبادل المفاتيح
95	 مخططات تبادل المفاتيح
96	 مجموعات ديفي-هيلمان
97	 رموز مصادقة الرسائل (MAC)
97	 التوقيعات الرقمية
98	 معايير التشفير ما بعد الكومي

98 الملحق د: التوصيات

98	 مقدمة
98	 آليات موصى بها وداخلة في النطاق
98	 مبادئ أمان البرمجيات
99	 عمليات أمان البرمجيات

99 الملحق هـ - المساهمون

البداية

عن المعيار

معيّار التحقق من أمان التطبيقات هو قائمة بمتطلبات أمان التطبيقات التي يمكن للمعماريين والمطوّرين والمختبرين ومتخصصي الأمان وموردي الأدوات والمستهلكين استخدامها لتحديد التطبيقات الآمنة وبناءها واختبارها والتحقق منها.

حقوق النشر والترخيص

الإصدار 5.0.0، مايو 2025



شكل 1: license

حقوق النشر © 2008-2025 مؤسسة OWASP.

يُنشر هذا المستند بموجب ترخيص المشاع الإبداعي: النسبة إلى المُنصّف - الترخيص بالمثل 4.0 دولي. عند أي إعادة استخدام أو توزيع، يجب أن توضّح للآخرين شروط ترخيص هذا العمل بجلاء.

قادة المشروع

Elar Lang Josh C Grossman

Jim Manico Daniel Cuthbert

مجموعة العمل

Ahnoff Tobias	Andalis Ralph	Armstrong Ryan	Corona Gabriel
Jacquot Meghan	Prutchi Shanni	Sharafaldin Iman	Yardeni Eden

مساهمون رئيسيون آخرون

Sjoerd Langkemper Isaac Lewis

Mark Carney Sandro Gauci

مساهمون ومراجعون آخرون

لقد أدرجنا قائمة بالمساهمين الآخرين في الملحق هـ.

إذا كان هناك إسهام غائب عن قائمة الإسهامات للإصدار 5.0، فيرجى تسجيل تذكّرة على GitHub ليُعترف به في تحديثات 5.0 المستقبلية. يبني معيار التحقق من أمان التطبيقات على عمل من شاركوا في إصدارات معيار التحقق من أمان التطبيقات من 1.0 (2008) حتى 4.0 (2019). وقد كُتب في الأصل كثير من البنية والعديد من بنود التحقق التي لا تزال موجودة في معيار التحقق من أمان التطبيقات اليوم على أيدي Stock der van Andrew و Boberski Mike و Williams Jeff و Dave و Wichers إلى جانب عدد كبير من المساهمين الآخرين. شكرًا لكل من ساهم في الماضي. وللحصول على قائمة شاملة بالمساهمين السابقين، يُرجى الرجوع إلى كل إصدار سابق.

تمهيد

أهلاً بك في الإصدار 5.0 من معيار التحقق من أمان التطبيقات (ASVS).

مقدمة

أُطلق معيار التحقق من أمان التطبيقات في الأصل عام 2008 من خلال تعاون مجتمعي عالمي، وهو يحدّد مجموعة شاملة من متطلبات الأمان لتصميم تطبيقات وخدمات الويب الحديثة وتطويرها واختبارها.

بعد إصدار معيار التحقق من أمان التطبيقات 4.0 عام 2019 وتحديثه الطفيف (الإصدار 4.0.3) عام 2021، يمثّل الإصدار 5.0 محطة مهمة—حدّث ليُجسّد أحدث التطورات في أمان البرمجيات.

معيار التحقق من أمان التطبيقات 5.0 هو نتاج إسهامات واسعة من قادة المشروع وأعضاء مجموعة العمل ومجتمع OWASP الأوسع لتحديث هذا المعيار المهم وتحسينه.

المبادئ التي يستند إليها الإصدار 5.0

طوّرت هذه المراجعة الرئيسية مع مراعاة عدة مبادئ أساسية:

- نطاق وتركيز مُحسّن: صُمّم هذا الإصدار من المعيار ليتوافق بشكل أكثر مباشرة مع الركائز الأساسية في اسمه: التطبيق، والأمان، والتحقق، والمعيّار. وقد أُعيدت كتابة المتطلبات للتأكيد على منع العيوب الأمنية بدلاً من إلزام تنفيذات تقنية محدّدة. والمقصود أن تكون نصوص المتطلبات شارحة لنفسها، موصّحة سبب وجودها.
- دعم القرارات الأمنية الموثّقة: يقدّم معيار التحقق من أمان التطبيقات 5.0 متطلبات لتوثيق القرارات الأمنية الرئيسية. وهذا يعزّز إمكانية التتبع ويدعم التنفيذات الحسّاسة للسياق، ما يتيح للمؤسسات تكييف وضعها الأمني وفق احتياجاتها ومخاطرها المحدّدة.
- مستويات محدّثة: مع أن معيار التحقق من أمان التطبيقات يحتفظ بنموذجه ثلاثي الطبقات، فقد تطوّرت تعريفات المستويات لتسهيل تبني معيار التحقق من أمان التطبيقات. صُمّم المستوى 1 خطوة أولى لتبني معيار التحقق من أمان التطبيقات، موفّراً الطبقة الأولى من الدفاع. ويمثّل المستوى 2 نظرة شاملة لممارسات الأمان القياسية، أما المستوى 3 فيتناول المتطلبات المتقدّمة عالية التوكيد.
- محتوى مُعاد هيكلته وموسّع: يشتمل معيار التحقق من أمان التطبيقات 5.0 على نحو 350 مطلباً موزّعة على 17 فصلاً. وقد أُعيد تنظيم الفصول لتحقيق الوضوح وسهولة الاستخدام. ويتّاح تخطيط ثنائي الاتجاه بين الإصدارين 4.0 و 5.0 لتيسير الانتقال.

نظرة إلى الأمام

كما أن تأمين التطبيق لا ينتهي حقاً، فكذلك معيار التحقق من أمان التطبيقات. ومع أن الإصدار 5.0 إصدار رئيسي، فإن التطوير مستمر. ويتيح هذا الإصدار للمجتمع الأوسع الاستفادة من التحسينات والإضافات التي تراكمت، لكنه يرسي كذلك الأساس لتحسينات مستقبلية. وقد يشمل ذلك جهوداً يقودها المجتمع لإنشاء إرشادات للتنفيذ والتحقق مبنية على مجموعة المتطلبات الأساسية. صُمم معيار التحقق من أمان التطبيقات 5.0 ليكون أساساً موثقاً لتطوير البرمجيات الآمنة. والمجتمع مدعو إلى تبني هذا المعيار والإسهام فيه والبناء عليه للنهوض جماعياً بحالة أمان التطبيقات.

ما هو معيار التحقق من أمان التطبيقات؟

يحدّد معيار التحقق من أمان التطبيقات (ASVS) متطلبات أمنية لتطبيقات الويب وخدماته، وهو مورد قيم لكل من يسعى إلى تصميم تطبيقات آمنة وتطويرها وصيانتها أو إلى تقييم أمانها. ويبيّن هذا الفصل الجوانب الجوهرية لاستخدام معيار التحقق من أمان التطبيقات، بما فيها نطاقه وبنية مستوياته القائمة على الأولوية وحالات الاستخدام الرئيسية للمعيار.

نطاق معيار التحقق من أمان التطبيقات

يتحدّد نطاق معيار التحقق من أمان التطبيقات باسمه: التطبيق والأمان والتحقق والمعيار. فهو يرسي أي المتطلبات مدرجة وأياً مستثناة، مع الهدف الشامل لتحديد المبادئ الأمنية التي يجب تحقيقها. ويراعي النطاق كذلك متطلبات التوثيق، التي تشكّل الأساس لمتطلبات التنفيذ. ولا وجود لشيء يُسمّى نطاقاً بالنسبة إلى المهاجمين. ولذلك ينبغي تقييم متطلبات معيار التحقق من أمان التطبيقات إلى جانب الإرشادات المتعلقة بجوانب أخرى من دورة حياة التطبيق، بما فيها عمليات التكامل والتسليم المستمرين (CI/CD) والاستضافة والأنشطة التشغيلية.

التطبيق

يُعرّف معيار التحقق من أمان التطبيقات “التطبيق” بأنه المنتج البرمجي قيد التطوير، الذي يجب دمج ضوابط الأمان فيه. ولا يفرض معيار التحقق من أمان التطبيقات أنشطة دورة حياة التطوير ولا يحدّد كيفية بناء التطبيق عبر خط CI/CD بل يحدّد المخرجات الأمنية التي يجب تحقيقها داخل المنتج نفسه.

وقد تُعدّ المكونات التي تقدّم حزم HTTP أو تعدّلها أو تتحقّق منها، مثل جدران حماية تطبيقات الويب (WAFs) أو موازنات الحمل أو الوكلاء، جزءاً من التطبيق لتلك الأغراض بعينها، إذ تعتمد بعض ضوابط الأمان عليها مباشرة أو يمكن تنفيذها من خلالها. وينبغي مراعاة هذه المكونات في المتطلبات المتعلقة بالاستجابات المخزّنة مؤقتاً أو تحديد المعدّل أو تقييد الاتصالات الواردة والصادرة بناءً على المصدر والمقصد.

وفي المقابل، يستثني معيار التحقق من أمان التطبيقات عموماً المتطلبات التي ليست ذات صلة مباشرة بالتطبيق أو التي يكون تكوينها خارج مسؤولية التطبيق. على سبيل المثال، تُدار مشكلات نظام أسماء النطاقات (DNS) عادةً بواسطة فريق أو وظيفة منفصلة.

وبالمثل، مع أن التطبيق مسؤول عن كيفية استهلاكه للداخلات وإنتاجه للمخرجات، فإذا تفاعلت عملية خارجية مع التطبيق أو بياناته، فإنها تُعدّ خارج نطاق معيار التحقق من أمان التطبيقات. فعلى سبيل المثال، يكون النسخ الاحتياطي للتطبيق أو لبياناته عادةً مسؤولية عملية خارجية ولا يتحكّم فيه التطبيق أو مطوّروه.

الأمان

يجب أن يكون لكل متطلب أثر ملموس على الأمان. ويجب أن يؤدي غياب المتطلب إلى تطبيق أقل أماناً، ويجب أن يقلل تنفيذ المتطلب إما احتمال وقوع خطر أمني أو أثره.

أما جميع الاعتبارات الأخرى، مثل الجوانب الوظيفية أو أسلوب كتابة الشيفرة أو متطلبات السياسات، فهي خارج النطاق.

التحقق

يجب أن يكون المتطلب قابلاً للتحقق، ويجب أن يؤدي التحقق إلى قرار "فشل" أو "نجاح".

المعيّار

صُمم معيار التحقق من أمان التطبيقات ليكون مجموعة من المتطلبات الأمنية التي يجب تنفيذها لامتثال للمعيّار. ويعني ذلك أن المتطلبات تقتصر على تحديد الهدف الأمني الذي ينبغي تحقيقه. ويمكن بناء المعلومات الأخرى ذات الصلة فوق معيار التحقق من أمان التطبيقات أو ربطها به عبر التخطيطات.

وعلى وجه التحديد، لدى OWASP مشاريع كثيرة، ويتجنب معيار التحقق من أمان التطبيقات متعمداً التداخل مع محتوى المشاريع الأخرى. فعلى سبيل المثال، قد يكون لدى المطورين سؤال: "كيف أنفذ متطلباً معيناً في تقنيتي أو بيئتي بعينها"، وهذا ينبغي أن يغطيه مشروع Cheat Sheet. وقد يكون لدى المدققين سؤال: "كيف أختبر هذا المتطلب في هذه البيئة"، وهذا ينبغي أن يغطيه مشروع Security Web Guide. Testing

ومع أن معيار التحقق من أمان التطبيقات ليس موجّهاً لاستخدام خبراء الأمان وحدهم، فإنه يتوقع من القارئ أن يمتلك معرفة تقنية لفهم المحتوى أو القدرة على البحث في مفاهيم بعينها.

المتطلب

تُستخدم كلمة متطلب في معيار التحقق من أمان التطبيقات على وجه التحديد لأنها تصف ما يجب تحقيقه لاستيفائه. ولا يحتوي معيار التحقق من أمان التطبيقات إلا على متطلبات (يجب) ولا يحتوي على توصيات (ينبغي) كشرط رئيسي.

وبعبارة أخرى، فإن التوصيات، سواء كانت مجرد خيار من خيارات ممكنة كثيرة لحل مشكلة أو اعتبارات لأسلوب كتابة الشيفرة، لا تستوفي التعريف لتكون متطلباً.

والمقصود من متطلبات معيار التحقق من أمان التطبيقات تناول مبادئ أمنية محدّدة دون أن تكون شديدة الخصوصية بالتنفيذ أو التقنية، وأن تكون في الوقت نفسه شارحة لنفسها فيما يخص سبب وجودها. ويعني ذلك كذلك أن المتطلبات ليست مبنية حول طريقة تحقق أو تنفيذ بعينها.

القرارات الأمنية المؤثقة

في أمان البرمجيات، سيؤدي التخطيط للتصميم الأمني والآليات التي ستستخدم في وقت مبكر إلى تنفيذ أكثر اتساقاً وموثوقية في المنتج أو الميزة النهائية.

وإضافةً إلى ذلك، سيكون التنفيذ في بعض المتطلبات معقداً وخاصاً جداً باحتياجات التطبيق. ومن الأمثلة الشائعة الصلاحيات والتحقق من صحة المدخلات والضوابط الحمايية حول مستويات مختلفة من البيانات الحساسة.

ولمراعاة ذلك، وبدلاً من عبارات عامة مثل "يجب تشفير جميع البيانات" أو محاولة تغطية كل حالة استخدام ممكنة في مطلب واحد، أُدرجت متطلبات توثيق تُلزم بتوثيق منهج مطوّر التطبيق وتكوينه لهذه الأنواع من الضوابط. ويمكن بعد ذلك مراجعة ذلك للتأكد من ملاءمته، ثم مقارنة التنفيذ الفعلي بالوثائق لتقدير ما إذا كان التنفيذ يطابق التوقعات.

والمقصود من هذه المتطلبات توثيق القرارات التي اتخذتها المؤسسة المطوّرة للتطبيق بشأن كيفية تنفيذ متطلبات أمنية معيّنة.

وتكون متطلبات التوثيق دائماً في القسم الأول من الفصل (وإن لم يكن لكل فصل متطلبات توثيق)، ويكون لها دائماً مطلب تنفيذ مرتبط بها ينبغي فيه تطبيق القرارات المؤثقة فعلياً. والمقصود هنا أن التحقق من وجود الوثائق والتحقق من التنفيذ الفعلي نشاطان منفصلان.

وهناك محرّكان رئيسيان لإدراج هذه المتطلبات. المحرّك الأول أن المطلب الأمني كثيراً ما يتضمّن إنفاذ قواعد، مثل أنواع الملفات المسموح بتحميلها، وضوابط العمل التي ينبغي إنفاذها، والمخارف المسموح بها في حقل معين. وستختلف هذه القواعد في كل تطبيق، ولذلك لا يستطيع معيار التحقق من أمان التطبيقات أن يحدّد إلزامياً ما ينبغي أن تكون عليه، ولن تفيد ورقة مرجعية أو استجابة أكثر تفصيلاً في هذه الحالة. وبالمثل، فمن دون توثيق هذه القرارات، لن يكون من الممكن إجراء تحقق من المتطلبات التي تنفّذها.

والمحرّك الثاني أنه من المهم، في متطلبات معيّنة، منح جهة تطوير التطبيق مرونة بشأن كيفية تناول تحديات أمنية بعينها. فعلى سبيل المثال، كانت قواعد مهلة الجلسة في إصدارات معيار التحقق من أمان التطبيقات السابقة إلزامية جداً. ومن الناحية العملية، لدى تطبيقات كثيرة، وخصوصاً الموجهة إلى المستهلكين، قواعد أكثر تسامحاً بكثير وتفضّل تنفيذ ضوابط تخفيف أخرى بدلاً من ذلك. ولذلك تتيح متطلبات التوثيق مرونة صريحة في هذا الشأن.

ومن الواضح أنه ليس من المتوقع أن يتخذ المطوّرون الأفراد هذه القرارات ويوثّقوها، بل ستأخذها المؤسسة ككل وثناً أكد من إبلاغها إلى المطوّرين الذين يحرصون بعد ذلك على اتباعها.

إن تزويد المطوّرين بمواصفات وتصاميم للميزات والوظائف الجديدة جزء معتاد من تطوير البرمجيات. وبالمثل، يُتوقع من المطوّرين استخدام مكوّنات وآليات واجهة مستخدم مشتركة بدلاً من مجرد اتخاذ قراراتهم الخاصة كل مرة. ولذلك لا ينبغي أن يُنظر إلى توسيع ذلك ليشمل الأمان كأمر مفاجئ أو مثير للجدل.

وهناك مرونة كذلك في كيفية تحقيق ذلك. فقد تُوثّق القرارات الأمنية في مستند فعلي يُتوقع من المطوّرين الرجوع إليه. وبدلاً من ذلك، قد تُوثّق القرارات الأمنية وتنفّذ في مكتبة شيفرة مشتركة يلزم جميع المطوّرين باستخدامها. وفي كلتا الحالتين تتحقق النتيجة المرجوة.

مستويات التحقق من أمان التطبيقات

يحدّد معيار التحقق من أمان التطبيقات ثلاثة مستويات للتحقق الأمني، يزايد كل مستوى منها في العمق والتعقيد. والهدف العام أن تبدأ المؤسسات بالمستوى الأول لتناول أهم الاعتبارات الأمنية، ثم تنتقل إلى المستويات الأعلى وفق احتياجات المؤسسة والتطبيق. وقد تُعرض المستويات في المستند وفي نصوص المتطلبات بالصور L1 و L2 و L3.

ويشير كل مستوى في معيار التحقق من أمان التطبيقات إلى المتطلبات الأمنية اللازم تحقيقها من ذلك المستوى، مع اعتبار متطلبات المستويات الأعلى المتبقية توصيات.

ولتجنّب المتطلبات المكرّرة أو المتطلبات التي لم تعد ذات صلة في المستويات الأعلى، تنطبق بعض المتطلبات على مستوى معين لكن بشروط أكثر صرامة في المستويات الأعلى.

تقييم المستويات

تُحدّد المستويات بتقييم قائم على الأولوية لكل مطلب بناءً على الخبرة في تنفيذ المتطلبات الأمنية واختبارها. والتركيز الرئيسي على مقارنة تقليل المخاطر بالجهد اللازم لتنفيذ المطلب. وهناك عامل رئيسي آخر هو الحفاظ على حاجز دخول منخفض. ويراعي تقليل المخاطر مدى تقليل المطلب لمستوى الخطر الأمني في التطبيق، مع مراعاة عوامل الأثر الكلاسيكية للسرية والسلامة والتوافر، وكذلك النظر في ما إذا كان هذا طبقة دفاع أولية أو يُعدّ دفاعاً في العمق. وقد أدّت المناقشات الدقيقة حول المعايير وقرارات المستويات على حد سواء إلى توزيع ينبغي أن يصحّ في الأغلبية الساحقة من الحالات، مع الإقرار بأنه قد لا يكون ملائماً بنسبة 100% لكل وضع. ويعني ذلك أن المؤسسات قد ترغب في حالات معيّنة في إعطاء أولوية أكبر لمتطلبات من مستوى أعلى بناءً على اعتباراتها الخاصة للمخاطر. ويمكن توصيف أنواع المتطلبات في كل مستوى على النحو التالي.

المستوى 1

يحتوي هذا المستوى على الحد الأدنى من المتطلبات التي ينبغي مراعاتها عند تأمين تطبيق، ويمثّل نقطة انطلاق بالغة الأهمية. ويحتوي هذا المستوى على نحو 20% من متطلبات معيار التحقق من أمان التطبيقات. والهدف من هذا المستوى أن يكون عدد المتطلبات أقل ما يمكن، لتخفيض حاجز الدخول. وهذه المتطلبات عموماً حرجية أو أساسية، وهي متطلبات الطبقة الأولى من الدفاع لمنع الهجمات الشائعة التي لا تتطلّب ثغرات أو شروطاً مسبقة أخرى لتكون قابلة للاستغلال. وإضافةً إلى متطلبات الطبقة الأولى من الدفاع، هناك متطلبات أقل أثراً في المستويات الأعلى، مثل المتطلبات المتعلقة بكلمات المرور. وهذه أكثر أهمية في المستوى 1، إذ تصبح متطلبات المصادقة متعددة العوامل ذات صلة من المستويات الأعلى. والمستوى 1 ليس بالضرورة قابلاً لاختبار الاختراق بواسطة مختبر خارجي دون وصول داخلي إلى الوثائق أو الشيفرة (مثل اختبار "الصندوق الأسود")، وإن كان العدد الأقل من المتطلبات ينبغي أن يسهّل التحقق منه.

المستوى 2

ينبغي أن تسعى معظم التطبيقات إلى تحقيق هذا المستوى من الأمان. فنحو 50% من متطلبات معيار التحقق من أمان التطبيقات هي من المستوى 2، ما يعني أن التطبيق يحتاج إلى تنفيذ نحو 70% من متطلبات معيار التحقق من أمان التطبيقات (جميع متطلبات المستويين 1 و2) للائتمثال للمستوى 2. وتتعلق هذه المتطلبات عموماً إما بهجمات أقل شيوعاً أو بحماية أكثر تعقيداً من الهجمات الشائعة. وقد تكون لا تزال طبقة دفاع أولية، أو قد تتطلّب شروطاً مسبقة معيّنة لنجاح الهجوم.

المستوى 3

ينبغي أن يكون هذا المستوى هدفاً للتطبيقات التي تسعى إلى إظهار أعلى مستويات الأمان، وهو يوفّر النسبة الأخيرة البالغة نحو 30% من المتطلبات اللازمة للائتمثال. والمتطلبات في هذا القسم عموماً إما آليات دفاع في العمق أو ضوابط أخرى مفيدة لكن صعبة التنفيذ.

أي مستوى ينبغي تحقيقه

المقصود من المستويات القائمة على الأولوية أن توفر انعكاساً لنضج أمان التطبيقات في المؤسسة وفي التطبيق. وبدلاً من أن ينص معيار التحقق من أمان التطبيقات إلزامياً على المستوى الذي ينبغي أن يكون التطبيق عليه، ينبغي للمؤسسة أن تحلل مخاطرها وتقرّر المستوى الذي تعتقد أنه ينبغي أن تكون عليه، بحسب حساسية التطبيق، وبالطبع، توقعات مستخدمي التطبيق.

على سبيل المثال، قد تقرر شركة ناشئة في مرحلة مبكرة لا تجمع سوى بيانات حساسة محدودة أن تركز على المستوى 1 لأهدافها الأمنية الأولية، لكن مصرفاً قد يجد صعوبة في تبرير أي شيء أدنى من المستوى 3 لعملائه في تطبيقه للخدمات المصرفية عبر الإنترنت.

كيفية استخدام معيار التحقق من أمان التطبيقات

بنية معيار التحقق من أمان التطبيقات

يتكوّن معيار التحقق من أمان التطبيقات من نحو 350 مطلباً إجمالاً مقسّمة على 17 فصلاً، كل منها مقسّم كذلك إلى أقسام. والهدف من تقسيم الفصول والأقسام تبسيط اختيار الفصول والأقسام أو تصفيتها بناءً على ما هو ذو صلة بالتطبيق. فعلى سبيل المثال، بالنسبة إلى واجهة برمجة تطبيقات من آلة إلى آلة، لن تكون المتطلبات في الفصل V3 المتعلقة بواجهات الويب الأمامية ذات صلة. وإذا لم يكن هناك استخدام لـ OAuth أو WebRTC، فيمكن تجاهل هذين الفصلين كذلك.

استراتيجية الإصدار

تتبع إصدارات معيار التحقق من أمان التطبيقات النمط "رئيسي.ثانوي.ترقيعي"، وتوفر الأرقام معلومات عما تغيّر في الإصدار. ففي الإصدار الرئيسي يتغيّر الرقم الأول، وفي الإصدار الثانوي يتغيّر الرقم الثاني، وفي الإصدار الترقيعي يتغيّر الرقم الثالث.

- الإصدار الرئيسي - إعادة تنظيم كاملة، وقد يكون كل شيء تقريباً قد تغيّر، بما في ذلك أرقام المتطلبات. وسيكون من الضروري إعادة التقييم للامثال (مثلاً من 4.0.3 إلى 5.0.0).
- الإصدار الثانوي - قد تُضاف متطلبات أو تُزال، لكن الترقيم العام سيبقى كما هو. وسيكون من الضروري إعادة التقييم للامثال، لكنه ينبغي أن يكون أسهل (مثلاً من 5.0.0 إلى 5.1.0).
- الإصدار الترقيعي - قد تُزال متطلبات (مثلاً إذا كانت مكررة أو متقدمة) أو تُجعل أقل صرامة، لكن التطبيق الذي امتثل للإصدار السابق سيمتثل للإصدار الترقيعي كذلك (مثلاً من 5.0.0 إلى 5.0.1).

وينطبق ما سبق تحديداً على المتطلبات في معيار التحقق من أمان التطبيقات. أما التغيرات في النص المحيط وغيره من المحتوى مثل الملاحق فلن تُعدّ تغييراً قاطعاً للتوافق.

المرونة في معيار التحقق من أمان التطبيقات

توفر عدة نقاط من الموصوفة أعلاه، مثل متطلبات التوثيق وآلية المستويات، القدرة على استخدام معيار التحقق من أمان التطبيقات بطريقة أكثر مرونة وأكثر خصوصية بالمؤسسة.

وإضافةً إلى ذلك، تُشجّع المؤسسات بقوة على إنشاء نسخة متفرّعة خاصة بالمؤسسة أو بالمجال تعدّل المتطلبات بناءً على الخصائص ومستويات المخاطر المحددة لتطبيقاتها. لكن من المهم الحفاظ على إمكانية التتبع بحيث يعني استيفاء المطلب 4.1.1 الشيء نفسه في جميع الإصدارات.

ومن الأفضل أن تنشئ كل مؤسسة نسخة معيار التحقق من أمان التطبيقات مُصمّمة لها، مع حذف الأقسام غير ذات الصلة (مثل GraphQL وWebSockets وSOAP إذا لم تكن مستخدمة). كما أن نسخة معيار التحقق من أمان التطبيقات الخاصة بالمؤسسة أو ملحقها موضع جيد كذلك لتقديم إرشادات تنفيذ خاصة بالمؤسسة، تبين المكتبات أو الموارد التي ينبغي استخدامها عند الامتثال للمتطلبات.

كيفية الإشارة إلى متطلبات معيار التحقق من أمان التطبيقات

- لكل مطلب معرف بالصيغة `<requirement>.<section>.<chapter>`، حيث كل عنصر رقم. على سبيل المثال، 1.11.3.
- تقابل قيمة `<chapter>` الفصل الذي يأتي منه المطلب؛ فعلى سبيل المثال، جميع المتطلبات #.1 هي من فصل 'الترميز والتنقية'.
- تقابل قيمة `<section>` القسم داخل ذلك الفصل الذي يظهر فيه المطلب، فعلى سبيل المثال: جميع المتطلبات #.1.2 هي في قسم 'منع الحقن' من فصل 'الترميز والتنقية'.
- تحدّد قيمة `<requirement>` المطلب بعينه داخل الفصل والقسم، فعلى سبيل المثال 1.2.5 الذي هو، منذ الإصدار 5.0.0 من هذا المعيار:

تحقق من أن التطبيق يحمي من حقن أوامر نظام التشغيل ومن أن استدعاءات نظام التشغيل تستخدم استعلامات مُعمّمة لنظام التشغيل أو تستخدم ترميزاً سياقياً لمخرجات سطر الأوامر.

وبما أن المعرفات قد تتغير بين إصدارات المعيار، فمن الأفضل للمستندات أو التقارير أو الأدوات الأخرى استخدام الصيغة التالية: `<requirement>.<section>.<chapter>.<version>`، حيث 'الإصدار' هو وسم إصدار معيار التحقق من أمان التطبيقات. على سبيل المثال: يفهم من 1.2.5-5.0.0 أنه يعني تحديداً المطلب الخامس في قسم 'منع الحقن' من فصل 'الترميز والتنقية' من الإصدار 5.0.0. (ويمكن تلخيص ذلك بالصورة `<requirement_idenfier>-<version>`).

ملاحظة: ينبغي أن يكون الحرف v السابق لرقم الإصدار في هذه الصيغة بحرف صغير دائماً.

وإذا استخدمت المعرفات دون إدراج عنصر `<version>`، فينبغي افتراض أنها تشير إلى أحدث محتوى لمعيار التحقق من أمان التطبيقات. ومع نمو المعيار وتغيّره يصبح ذلك مشكلاً، ولهذا ينبغي للكاتب أو المطورين إدراج عنصر الإصدار. ونُتاح قوائم متطلبات معيار التحقق من أمان التطبيقات بصيغ CSV وJSON وغيرها، وقد تكون مفيدة للرجوع إليها أو للاستخدام البرمجي.

تفريع معيار التحقق من أمان التطبيقات

يمكن للمؤسسات أن تستفيد من تبني معيار التحقق من أمان التطبيقات باختيار أحد المستويات الثلاثة أو بإنشاء نسخة متفرّعة خاصة بالمجال تعدّل المتطلبات بحسب مستوى مخاطر التطبيق. وهذا النوع من التفريع مُشجّع، بشرط أن يحافظ على إمكانية التبع بحيث يعني استيفاء المطلب 4.1.1 الشيء نفسه في جميع الإصدارات.

ومن الأفضل أن تنشئ كل مؤسسة نسخة معيار التحقق من أمان التطبيقات مُصمّمة لها، مع حذف الأقسام غير ذات الصلة (مثل GraphQL وWebsockets وSOAP إذا لم تكن مستخدمة). وينبغي أن يبدأ التفريع بالمستوى 1 من معيار التحقق من أمان التطبيقات كنقطة أساس، ثم التقدّم إلى المستويين 2 أو 3 بناءً على مخاطر التطبيق.

حالات استخدام معيار التحقق من أمان التطبيقات

يمكن استخدام معيار التحقق من أمان التطبيقات لتقييم أمان تطبيق، وهذا مستقصى بعمق أكبر في الفصل التالي. لكن هناك عدة استخدامات محتملة أخرى لمعيار التحقق من أمان التطبيقات (أو لنسخة متفرعة منه) قد حدّدت.

كإرشادات مفصّلة لمعمارية الأمان

من الاستخدامات الأكثر شيوعاً لمعيار التحقق من أمان التطبيقات استخدامه كمورد لمعماري الأمان. فالموارد المتاحة عن كيفية بناء معمارية تطبيق آمنة محدودة، وخصوصاً مع التطبيقات الحديثة. ويمكن استخدام معيار التحقق من أمان التطبيقات لسدّ هذه الفجوات بتمكين معماري الأمان من اختيار ضوابط أفضل للمشكلات الشائعة، مثل أنماط حماية البيانات واستراتيجيات التحقق من صحة المدخلات. وستكون متطلبات المعمارية والتوثيق مفيدة لذلك على وجه الخصوص.

كمراجع متخصص للبرمجة الآمنة

يمكن استخدام معيار التحقق من أمان التطبيقات كأساس لإعداد مرجع للبرمجة الآمنة أثناء تطوير التطبيقات، بما يساعد المطوّرين على التأكد من أنهم يضعون الأمان في اعتبارهم عند بناء البرمجيات. ومع أن معيار التحقق من أمان التطبيقات يمكن أن يكون الأساس، فينبغي للمؤسسات إعداد إرشاداتها الخاصة التي تكون واضحة وموحّدة، ومن الأفضل أن تُعدّ بناءً على توجيه من مهندسي الأمان أو معماري الأمان. وكامتداد لذلك، تُشجّع المؤسسات، حيثما أمكن، على إعداد آليات ومكتبات أمنية معتمدة يمكن الإشارة إليها في الإرشادات واستخدامها من قبل المطوّرين.

كدليل لاختبارات الوحدة والتكامل المؤتمتة

صُمم معيار التحقق من أمان التطبيقات ليكون قابلاً للاختبار بدرجة عالية. وستكون بعض عمليات التحقق تقنية، في حين قد تتطلب متطلبات أخرى (مثل متطلبات المعمارية والتوثيق) مراجعة للوثائق أو للمعمارية. وبناء اختبارات وحدة وتكامل تختبر وتُشوّش حالات إساءة استخدام محدّدة وذات صلة بالمتطلبات القابلة للتحقق بوسائل تقنية، ينبغي أن يكون أسهل التحقق من أن هذه الضوابط تعمل على نحو صحيح في كل عملية بناء. فعلى سبيل المثال، يمكن صياغة اختبارات إضافية لمجموعة اختبارات متحكّم تسجيل الدخول، لاختبار معامل اسم المستخدم بحثاً عن أسماء المستخدمين الافتراضية الشائعة وتعداد الحسابات والقوة الغاشمة وحقن LDAP وSQL والبرمجة النصية عبر المواقع. وبالمثل، ينبغي أن يشمل اختبار معامل كلمة المرور كلمات المرور الشائعة وطول كلمة المرور وحقن البايث الفارغ وإزالة المعامل والبرمجة النصية عبر المواقع وغير ذلك.

للتدريب على التطوير الآمن

يمكن استخدام معيار التحقق من أمان التطبيقات كذلك لتحديد خصائص البرمجيات الآمنة. فكثير من دورات “البرمجة الآمنة” هي مجرد دورات في الاختراق الأخلاقي مع مسحة خفيفة من نصائح البرمجة. وقد لا يساعد ذلك بالضرورة المطوّرين على كتابة شيفرة أكثر أماناً. وبدلاً من ذلك، يمكن لدورات التطوير الآمن أن تستخدم معيار التحقق من أمان التطبيقات مع تركيز قوي على الآليات الإيجابية الموجودة فيه، بدلاً من التركيز على الأشياء السلبية العشرة الأولى التي لا ينبغي فعلها. كما أن بنية معيار التحقق من أمان التطبيقات توفر بنية منطقية للتنقل بين المواضيع المختلفة عند تأمين تطبيق.

كإطار لتوجيه شراء البرمجيات الآمنة

يُعدّ معيار التحقق من أمان التطبيقات إطاراً ممتازاً للمساعدة في شراء البرمجيات الآمنة أو شراء خدمات تطوير مخصصة. فيمكن للمشتري ببساطة أن يضع مطلباً بأن البرمجية التي يرغب في شرائها يجب أن تكون مطوّرة بمستوى معيار التحقق من أمان التطبيقات س، وأن يطلب من البائع إثبات أن البرمجية تستوفي مستوى معيار التحقق من أمان التطبيقات س.

تطبيق معيار التحقق من أمان التطبيقات عملياً

للتحديات المختلفة دوافع مختلفة. ولبعض الصناعات أصول معلوماتية وتقنية فريدة ومتطلبات امتثال تنظيمية خاصة بالجمال. وتُشجّع المؤسسات بقوة على النظر بعمق في خصائص مخاطرها الفريدة بناءً على طبيعة عملها، وأن تحدّد بناءً على تلك المخاطر ومتطلبات العمل مستوى معيار التحقق من أمان التطبيقات الملائم.

التقييم وإصدار الشهادات

موقف OWASP من شهادات معيار التحقق من أمان التطبيقات وعلامات الثقة

إن OWASP، كمؤسسة غير ربحية محايدة تجاه الموردين، لا تمنح شهادات لأي موردين أو مدققين أو برمجيات. وأي تأكيد أو علامة ثقة أو شهادة تدّعي الامتثال لمعيار التحقق من أمان التطبيقات ليست معتمدة رسمياً من OWASP، ولذلك ينبغي للمؤسسات أن تتوخى الحذر من ادعاءات الأطراف الثالثة بالحصول على شهادة معيار التحقق من أمان التطبيقات. ويمكن للمؤسسات أن تقدّم خدمات تأكيد، بشرط ألا تدّعي حصولها على شهادة رسمية من OWASP.

كيفية التحقق من الامتثال لمعيار التحقق من أمان التطبيقات

إن معيار التحقق من أمان التطبيقات ليس إلزامياً بشكل متعمّد بخصوص الطريقة الدقيقة للتحقق من الامتثال على مستوى دليل اختبار. ومع ذلك، من المهم إبراز بعض النقاط الرئيسية.

إعداد تقارير التحقق

تُبلّغ تقارير اختبار الاختراق التقليدية عن المشكلات "على سبيل الاستثناء"، فتسرد حالات الفشل فقط. أما تقرير شهادة معيار التحقق من أمان التطبيقات فينبغي أن يشتمل على النطاق، وملخص لجميع المتطلبات التي خُصّت، والمتطلبات التي رُصدت فيها استثناءات، وإرشادات لمعالجة المشكلات. وقد تكون بعض المتطلبات غير منطبقة (مثل إدارة الجلسات في واجهات برمجة التطبيقات عديمة الحالة)، ويجب الإشارة إلى ذلك في التقرير.

نطاق التحقق

لن تُنفذ المؤسسة التي تطوّر تطبيقاً جميع المتطلبات عادةً، إذ قد يكون بعضها غير ذي صلة أو أقل أهمية بحسب وظائف التطبيق. وينبغي للمدقّق أن يوضّح نطاق التحقق، بما في ذلك المستوى الذي تسعى المؤسسة إلى تحقيقه والمتطلبات التي أدرجت. وينبغي أن يكون ذلك من منظور ما أُدرج بدلاً من ما لم يُدرج. كما ينبغي له أن يقدّم رأياً في مبررات استثناء المتطلبات التي لم تُنفذ.

وهذا ينبغي أن يُمْكِن مسْتَهْلِك تقرير التحقق من فهم سياق التحقق واتخاذ قرار مستنير بشأن مستوى الثقة الذي يمكن أن يوليه للتطبيق. ويمكن للمؤسسات المانحة للشهادات أن تختار طرائق اختبارها، لكن ينبغي لها الإفصاح عنها في التقرير، ومن المستحسن أن تكون قابلة للتكرار. وقد تُستخدم طرائق مختلفة، مثل اختبارات الاختراق اليدوية أو تحليل الشيفرة المصدرية، للتحقق من جوانب مثل التحقق من صحة المدخلات، وذلك بحسب التطبيق والمتطلبات.

آليات التحقق

هناك عدد من التقنيات المختلفة التي قد تكون لازمة للتحقق من متطلبات معيار التحقق من أمان التطبيقات المحددة. وإلى جانب اختبار الاختراق (باستخدام بيانات اعتماد صحيحة للحصول على تغطية كاملة للتطبيق)، قد يتطلب التحقق من متطلبات معيار التحقق من أمان التطبيقات الوصول إلى الوثائق والشيفرة المصدرية والتكوين والأشخاص المشاركين في عملية التطوير. وخصوصاً للتحقق من متطلبات المستويين 2 و3. ومن الممارسات المتبعة تقديم أدلة قوية على النتائج مع توثيق مفصّل، قد يشمل أوراق العمل ولقطات الشاشة والنصوص البرمجية وسجلات الاختبار. ولا يكفي مجرد تشغيل أداة مؤتمتة دون اختبار شامل للحصول على الشهادة، إذ يجب اختبار كل مطلب على نحو قابل للتحقق.

إن استخدام الأتمتة للتحقق من متطلبات معيار التحقق من أمان التطبيقات موضوع يثير الاهتمام باستمرار. ولذلك من المهم توضيح بعض النقاط المتعلقة بالاختبار المؤتمت واختبار الصندوق الأسود.

دور أدوات اختبار الأمان المؤتمتة عندما تُنفَّذ أدوات اختبار الأمان المؤتمتة، مثل أدوات الاختبار الديناميكي والساكن لأمان التطبيقات (DAST وSAST)، تنفيذاً صحيحاً في خط بناء البرمجيات، فقد تمكّن من تحديد بعض المشكلات الأمنية التي لا ينبغي أن توجد أبداً. لكنها من دون تكوين وضبط دقيقين لن توفر التغطية المطلوبة، وسيمنح مستوى الضجيج تحديد المشكلات الأمنية الحقيقية والتخفيف منها. ومع أن ذلك قد يوفر تغطية لبعض المتطلبات التقنية الأبسط والأكثر مباشرة، مثل تلك المتعلقة بترميز المخرجات أو التنقية، فمن الأهمية البالغة ملاحظة أن هذه الأدوات ستكون عاجزة تماماً عن التحقق من كثير من متطلبات معيار التحقق من أمان التطبيقات الأكثر تعقيداً أو تلك المتعلقة بمنطق العمل والتحكم في الوصول.

وبالنسبة إلى المتطلبات الأقل مباشرة، من المرجح أنه لا يزال بالإمكان الاستفادة من الأتمتة، لكن سيتعيّن كتابة عمليات تحقق خاصة بالتطبيق لتحقيق ذلك. وقد تكون هذه مشابهة لاختبارات الوحدة والتكامل التي ربما تستخدمها المؤسسة بالفعل. ولذلك قد يكون من الممكن استخدام هذه البنية التحتية القائمة لأتمتة الاختبارات في كتابة اختبارات معيار التحقق من أمان التطبيقات هذه. ومع أن القيام بذلك سيتطلب استثماراً قصير الأجل، فإن الفوائد طويلة الأجل للقدرة على التحقق المستمر من متطلبات معيار التحقق من أمان التطبيقات هذه ستكون كبيرة. وخلاصة القول، القابلية للاختبار باستخدام الأتمتة لا تساوي تشغيل أداة جاهزة.

دور اختبار الاختراق مع أن المستوى 1 في الإصدار 4.0 كان مهيأً لإجراء اختبار "الصندوق الأسود" (دون وثائق ودون شيفرة مصدرية)، فقد كان المعيار واضحاً حتى في ذلك الحين في أن هذا ليس نشاط توكيد فعّالاً وينبغي الإثناء عنه بفعالية.

إن الاختبار دون الوصول إلى المعلومات الإضافية اللازمة آلية غير كفؤة وغير فعّالة للتحقق الأمني، إذ يفوت إمكانية مراجعة الشيفرة المصدرية وتحديد التهديدات والضوابط المفقودة وإجراء اختبار أكثر شمولاً بكثير في إطار زمني أقصر.

ويُشجّع بقوة على إجراء اختبار اختراق مبني على الوثائق أو الشيفرة المصدرية (هجين)، يتيح وصولاً كاملاً إلى مطوري التطبيق ووثائق التطبيق، بدلاً من اختبارات الاختراق التقليدية. وسيكون ذلك ضرورياً بالتأكيد للتحقق من كثير من متطلبات معيار التحقق من أمان التطبيقات.

التغييرات مقارنةً بالإصدار 4.x

مقدمة

قد يجد المستخدمون المعتادون على الإصدار 4.x من المعيار أنه من المفيد مراجعة التغييرات الرئيسية المدخلة في الإصدار 5.0، بما فيها التحديثات في المحتوى والنطاق والفلسفة الأساسية.

ومن بين 286 مطلباً في الإصدار 4.0.3، بقي 11 مطلباً فقط دون تغيير، في حين خضع 15 مطلباً لتعديلات نحوية طفيفة دون تغيير معناها. وإجمالاً، لم يعد 109 متطلبات (38%) متطلبات منفصلة في الإصدار 5.0، إذ حُذِفَ 50 منها ببساطة، وأُزيلَ 28 كحكرّات، ودُجِجَ 31 في متطلبات أخرى. أما الباقي فقد نُفِّحَ بصورة ما. وحتى المتطلبات التي لم تُعدّل جوهرياً لها معرّفات مختلفة بسبب إعادة الترتيب أو إعادة الهيكلة.

ولتيسير تبني الإصدار 5.0، تُوفّر مستندات تخطيط لمساعدة المستخدمين على تتبع كيفية تقابل متطلبات الإصدار 4.x مع متطلبات الإصدار 5.0. وهذه التخطيطات غير مرتبطة بترقيم الإصدارات وقد تُحدّث أو تُوضَّح حسب الحاجة.

فلسفة المتطلبات

النطاق والتركيز

اشتمل الإصدار 4.x على متطلبات لم تتوافق مع النطاق المقصود للمعيار؛ وقد أُزيلت هذه المتطلبات. كما استُثِنَت المتطلبات التي لم تستوف معايير النطاق للإصدار 5.0 أو التي لم تكن قابلة للتحقق.

التأكيد على الأهداف الأمنية بدلاً من الآليات

في الإصدار 4.x، ركّز كثير من المتطلبات على آليات معيّنة بدلاً من الأهداف الأمنية الأساسية. وفي الإصدار 5.0، تتمحور المتطلبات حول الأهداف الأمنية، مع الإشارة إلى آليات بعينها فقط عندما تكون الحل العملي الوحيد، أو تقديمها كأمثلة أو إرشادات تكميلية. ويقرّ هذا المنهج بأنه قد توجد طرائق متعددة لتحقيق هدف أمني معيّن، ويتجنّب الإلزام غير الضروري الذي قد يحدّ من مرونة المؤسسات. وإضافةً إلى ذلك، دُجِجت المتطلبات التي تتناول الشأن الأمني نفسه حيث كان ذلك ملائماً.

القرارات الأمنية المؤثقة

مع أن مفهوم القرارات الأمنية المؤثقة قد يبدو جديداً في الإصدار 5.0، فهو تطوّر لمتطلبات سابقة متعلقة بتطبيق السياسات ونمذجة التهديدات في الإصدار 4.0. فقد كانت بعض المتطلبات سابقاً تقتضي ضمناً إجراء تحليل لتوجيه تنفيذ ضوابط الأمان، مثل تحديد اتصالات الشبكة المسموح بها.

وللتأكد من توافر المعلومات اللازمة للتنفيذ والتحقق، صارت هذه التوقعات مُعرّفة صراحةً كمتطلبات توثيق، ما يجعلها واضحة وقابلة للتنفيذ وقابلة للتحقق.

التغييرات الهيكلية والفصول الجديدة

تقدّم عدة فصول في الإصدار 5.0 محتوىً جديداً كلياً:

- OAuth وOIDC - نظراً للتبني الواسع لهذين البروتوكولين لتفويض الوصول والدخول الموحد، أُضيفت متطلبات مخصصة لتناول السيناريوهات المتنوعة التي قد يواجهها المطوّرون. وقد يتطوّر هذا المجال في النهاية إلى معيار قائم بذاته، على نحو شبيه بمعالجة متطلبات الأجهزة المحمولة وإنترنت الأشياء في الإصدارات السابقة.
- WebRTC - مع تزايد شعبية هذه التقنية، تُتناول الآن اعتباراتها وتحدياتها الأمنية الفريدة في قسم مخصص.

وقد بذلت جهود كذلك للتأكد من أن الفصول والأقسام منظمّة حول مجموعات متسقة من المتطلبات المترابطة.

وقد أدّت إعادة الهيكلة هذه إلى إنشاء فصول إضافية:

- الرموز المميزة المكتفية بذاتها - كانت مصنّفة سابقاً تحت إدارة الجلسات، وصارت الرموز المميزة المكتفية بذاتها تُعدّ الآن آلية متميزة وعنصراً أساسياً للاتصال عديم الحالة (كما في OAuth وOIDC). ونظراً لتبعاتها الأمنية الفريدة، تُتناول في فصل مخصص، مع إدخال بعض المتطلبات الجديدة في الإصدار 5.x.
- أمان واجهة الويب الأمامية - مع تزايد تعقيد التطبيقات القائمة على المتصفح وصعود المعماريات القائمة على واجهات برمجة التطبيقات فقط، فُصلت متطلبات أمان الواجهة الأمامية في فصل خاص بها.
- البرمجة الآمنة والمعمارية - جُمعت هنا المتطلبات الجديدة التي تتناول ممارسات أمنية عامة لم تكن تدرج في الفصول القائمة.

وقد أُجريت تغييرات تنظيمية أخرى في الإصدار 5.0 لتوضيح المقصد. على سبيل المثال، نُقلت متطلبات التحقق من صحة المدخلات إلى جانب منطق العمل، بما يجسّد دورها في إنفاذ قواعد العمل، بدلاً من تصنيفها مع التفتية والترميز.

وقد أُزيل فصل V1 المعمارية السابق. فقد احتوى قسمه الأول على متطلبات كانت خارج النطاق، في حين أُعيد توزيع الأقسام اللاحقة على الفصول المعنية، مع إزالة تكرار المتطلبات وتوضيحها حسب الضرورة.

إزالة التخطيطات المباشرة إلى المعايير الأخرى

أزيلت التخطيطات المباشرة إلى المعايير الأخرى من المتن الرئيسي للمعيار. والهدف إعداد تخطيط مع مشروع تعداد المتطلبات المشتركة (CRE) الخاص بـ OWASP، والذي سيربط بدوره معيار التحقق من أمان التطبيقات بمجموعة من مشاريع OWASP والمعايير الخارجية. ولم تعد التخطيطات المباشرة إلى CWE وNIST مُصانة، على النحو الموضح أدناه.

تقليل الارتباط بإرشادات الهوية الرقمية من NIST

لطالما شكّلت إرشادات الهوية الرقمية (SP 800-63) الصادرة عن NIST مرجعاً لضوابط المصادقة والتحويل. وفي الإصدار 4.x، كانت فصول معينة متوافقة على نحو وثيق مع بنية NIST ومصطلحاتها.

ومع أن هذه الإرشادات تبقى مرجعاً مهماً، فقد أدّى التوافق الصارم إلى تحديات، منها مصطلحات أقل شيوعاً في التعارف، وتكرار متطلبات متشابهة، وتخطيطات غير كاملة. ويبتعد الإصدار 5.0 عن هذا المنهج لتحسين الوضوح والصلة.

الابتعاد عن تعداد نقاط الضعف الشائعة (CWE)

يُوفّر تعداد نقاط الضعف الشائعة (CWE) تصنيفاً مفيداً لنقاط ضعف أمان البرمجيات. لكن تحديات مثل مُدخلات CWE التي هي فئات فقط، وصعوبات تخطيط المتطلبات إلى CWE واحد، ووجود تخطيطات غير دقيقة في الإصدار 4.x، أدّت إلى قرار إيقاف التخطيطات المباشرة إلى CWE في الإصدار 5.0.

إعادة النظر في تعريفات المستويات

وصف الإصدار 4.x المستويات بأنها المستوى 1 ("الأدنى") والمستوى 2 ("القياسي") والمستوى 3 ("المتقدّم")، مع ما يفهم منه أن جميع التطبيقات التي تتعامل مع بيانات حساسة ينبغي أن تستوفي المستوى 2 على الأقل. ويعالج الإصدار 5.0 عدة مشكلات في هذا المنهج، وهي موصوفة في الفقرات التالية.

ومن الناحية العملية، في حين استخدم الإصدار 4.x علامات الاختيار كمؤشرات للمستويات، يستخدم الإصدار 5.x رقماً بسيطاً في جميع صيغ المعيار، بما فيها markdown و PDF و DOCX و CSV و JSON و XML. وللتوافق مع الإصدارات السابقة، تولّد كذلك إصدارات قديمة من مخرجات CSV و JSON و XML التي لا تزال تستخدم علامات الاختيار.

مستوى دخول أسهل

أشارت التعليقات إلى أن العدد الكبير من متطلبات المستوى 1 (نحو 120)، مقترناً بتصنيفه كالمستوى "الأدنى" الذي لا يكفي لمعظم التطبيقات، قد أثنى عن التبني. ويهدف الإصدار 5.0 إلى تخفيض هذا الحاجز بتعريف المستوى 1 أساساً حول متطلبات الدفاع في الطبقة الأولى، ما ينتج عنه متطلبات أوضح وأقل عدداً في ذلك المستوى. وبيان ذلك عددياً، كان في الإصدار 4.0.3 عدد 128 مطلباً للمستوى 1 من أصل 278 مطلباً، أي ما يمثل 46%. وفي الإصدار 5.0.0 هناك 70 مطلباً للمستوى 1 من أصل 345 مطلباً، أي ما يمثل 20%.

مغالطة القابلية للاختبار

كان أحد العوامل الرئيسية في انتقاء الضوابط للمستوى 1 في الإصدار 4.x ملاءمتها للتقييم عن طريق اختبار الاختراق الخارجي بمنهج "الصندوق الأسود". لكن هذا المنهج لم يتوافق تماماً مع مقصد المستوى 1 كالمجموعة الأدنى من ضوابط الأمان. فقد رأى بعض المستخدمين أن المستوى 1 غير كافٍ لتأمين التطبيقات، في حين وجده آخرون صعب الاختبار للغاية.

والتعويل على القابلية للاختبار كمعيار أمر نسبي ومُضلل أحياناً. فكون المطلب قابلاً للاختبار لا يضمن إمكانية اختباره بطريقة مؤتمتة أو مباشرة. وعلاوة على ذلك، ليست المتطلبات الأسهل اختباراً هي دائماً تلك ذات الأثر الأمني الأكبر أو الأبسط تنفيذاً.

ولذلك، في الإصدار 5.0، اتُّخذت قرارات المستويات أساساً على أساس تقليل المخاطر، مع مراعاة الجهد اللازم للتنفيذ كذلك.

ليس الأمر متعلقاً بالمخاطر وحدها

لقد ثبت أن استخدام مستويات إلزامية مبنية على المخاطر تفرض مستوى معيناً لتطبيقات بعينها مفرط الصلابة. فن الناحية العملية، يعتمد ترتيب أولويات ضوابط الأمان وتنفيذها على عوامل متعددة، منها تقليل المخاطر والجهد اللازم للتنفيذ على حد سواء.

ولذلك تُشجّع المؤسسات على تحقيق المستوى الذي تشعر أنه ينبغي لها تحقيقه بناءً على نضجها والرسالة التي تريد إيصالها إلى مستخدميها.

V1 الترميز والتنقية

الهدف من ضوابط الأمان

يتناول هذا الفصل أكثر نقاط ضعف أمان تطبيقات الويب شيوعاً فيما يتصل بالمعالجة غير الآمنة للبيانات غير الموثوقة. ويمكن أن تؤدي نقاط الضعف هذه إلى ثغرات تقنية متنوعة، تُفسّر فيها البيانات غير الموثوقة وفق قواعد صياغة المُفسّر المعني. وبالنسبة إلى تطبيقات الويب الحديثة، من الأفضل دائماً استخدام واجهات برمجة تطبيقات أكثر أماناً، مثل الاستعلامات المُمعّمة أو الإفلات التلقائي أو أطر القوالب. وبخلاف ذلك، يصبح الترميز أو الإفلات أو التنقية المُنفّذة بعناية على المخرجات أمراً بالغ الأهمية لأمان التطبيق. ويعمل التحقق من صحة المدخلات كآلية دفاع في العمق للحماية من المحتوى غير المتوقع أو الخطير. لكن، بما أن غرضه الأساسي هو ضمان تطابق المحتوى الوارد مع التوقعات الوظيفية والتجارية، فإن المتطلبات المتعلقة بذلك يمكن العثور عليها في فصل "التحقق من الصحة ومنطق العمل".

V1.1 معمارية الترميز والتنقية

في الأقسام أدناه، تُقدّم متطلبات خاصة بالصياغة أو بالمُفسّر لمعالجة المحتوى غير الآمن بأمان لتجنّب الثغرات الأمنية. وتتناول متطلبات هذا القسم الترتيب الذي ينبغي أن تحدث به هذه المعالجة والموضع الذي ينبغي أن تحدث فيه. وتهدف كذلك إلى ضمان أن البيانات، عند تخزينها، تبقى في حالتها الأصلية ولا تُخزّن في صورة مُرمّزة أو مُفلّنة (مثل ترميز HTML) وذلك لمنع مشكلات الترميز المزدوج.

المستوى	الوصف	#
2	تحقق من أن المدخلات تُفكّ ترميزها أو يُلغى إفلاتها إلى صورة قياسية مرة واحدة فقط، ومن أنها لا تُفكّ إلا عندما تكون البيانات المُرّمة بهذه الصورة متوقعة، ومن أن ذلك يحدث قبل معالجة المدخلات أكثر، أي أنه لا ينفّذ بعد التحقق من صحة المدخلات أو تنقيتها.	1.1.1
2	تحقق من أن التطبيق ينفّذ ترميز المخرجات وإفلاتها إما خطوة أخيرة قبل استخدامها بواسطة المُفسّر المقصود لها أو بواسطة المُفسّر نفسه.	1.1.2

V1.2 منع الحقن

إن ترميز المخرجات أو إفلاتها، المُنفّذ قريباً من سياق خطير محتمل أو ملاصقاً له، بالغ الأهمية لأمان أي تطبيق. وعادةً لا يُحفظ ترميز المخرجات وإفلاتها، بل يُستخدمان لجعل المخرجات آمنة للاستخدام الفوري في المُفسّر الملائم. وقد تؤدي محاولة تنفيذ ذلك مبكراً جداً إلى محتوى مشوّه أو إلى جعل الترميز أو الإفلات غير فعّال. وفي حالات كثيرة، تتضمن مكتبات البرمجيات دوال آمنة أو أكثر أماناً تُنفّذ ذلك تلقائياً، وإن كان من الضروري التأكد من صحتها للسياق الراهن.

المستوى	الوصف	#
1	تحقق من أن ترميز المخرجات لاستجابة HTTP أو مستند HTML أو مستند XML ملائم للسياق المطلوب، مثل ترميز المحارف المعنية لعناصر HTML أو سماتها أو تعليقاتها أو لـ CSS أو حقول ترويسة HTTP، وذلك لتجنّب تغيير بنية الرسالة أو المستند.	1.2.1
1	تحقق من أن البيانات غير الموثوقة، عند بناء عناوين URL ديناميكياً، تُرمز وفق سياقها (مثل ترميز URL أو ترميز base64url لمعاملات الاستعلام أو المسار). وتأكد من أن بروتوكولات URL الآمنة هي وحدها المسموح بها (مثلاً منع javascript: أو data:).	1.2.2
1	تحقق من استخدام ترميز المخرجات أو إفلاتها عند بناء محتوى JavaScript ديناميكياً (بما في ذلك JSON)، وذلك لتجنّب تغيير بنية الرسالة أو المستند (لتجنّب حقن JavaScript وJSON).	1.2.3
1	تحقق من أن انتقاء البيانات أو استعلامات قواعد البيانات (مثل SQL وHQL وNoSQL وCypher) تستخدم استعلامات مُعمّمة أو أنظمة ORM أو أطر الكيانات، أو أنها محمية بطريقة أخرى من حقن SQL وغيره من هجمات حقن قواعد البيانات. وهذا ذو صلة كذلك عند كتابة الإجراءات المخزّنة.	1.2.4
1	تحقق من أن التطبيق يحمي من حقن أوامر نظام التشغيل ومن أن استدعاءات نظام التشغيل تستخدم استعلامات مُعمّمة لنظام التشغيل أو تستخدم ترميزاً سياقياً لمخرجات سطر الأوامر.	1.2.5
2	تحقق من أن التطبيق يحمي من ثغرات حقن LDAP، أو من أن ضوابط أمنية محدّدة لمنع حقن LDAP قد نُفّذت.	1.2.6
2	تحقق من أن التطبيق يحمي من هجمات حقن XPath باستخدام تعميم الاستعلامات أو الاستعلامات المُصرّفة مسبقاً.	1.2.7
2	تحقق من أن معالجات LaTeX مُهيّأة بأمان (مثل عدم استخدام العَلَم "shell-escape" ومن استخدام قائمة سماح بالأوامر لمنع هجمات حقن LaTeX).	1.2.8
2	تحقق من أن التطبيق يُفلت المحارف الخاصة في التعبيرات النمطية (عادةً باستخدام شرطة مائلة عكسية) لمنع تفسيرها خطأً كمحارف وصفية.	1.2.9
3	تحقق من أن التطبيق محمي من حقن CSV والصيغ. ويجب أن يتّبع التطبيق قواعد الإفلات المحدّدة في RFC 4180 القسمين 2.6 و2.7 عند تصدير محتوى CSV. وإضافةً إلى ذلك، عند التصدير إلى CSV أو غيره من صيغ جداول البيانات (مثل XLS أو XLSX أو ODF)، يجب إفلات المحارف الخاصة (بما فيها '='+ و'-' و'@ و't' (مسافة جدولة) و'0' (محرّف فارغ)) بعلامة اقتباس مفردة إذا ظهرت كأول محرّف في قيمة حقن.	1.2.10

ملاحظة: استخدام الاستعلامات المُعمّمة أو إفلات SQL ليس كافياً دائماً. فأجزاء الاستعلام مثل أسماء الجداول والأعمدة (بما فيها أسماء أعمدة "ORDER BY") لا يمكن إفلاتها. وإدراج بيانات مُفلّنة مقدّمة من المستخدم في هذه الحقول يؤدي إلى استعلامات فاشلة أو إلى حقن SQL.

V1.3 التنقية

الحماية المثالية من استخدام محتوى غير موثوق في سياق غير آمن هي استخدام ترميز أو إفلات خاص بالسياق، يحافظ على المعنى الدلالي نفسه للمحتوى غير الآمن لكنه يجعله آمناً للاستخدام في ذلك السياق بعينه، على النحو المبين بتفصيل أكبر في القسم السابق.

وحيث لا يكون ذلك ممكناً، تصبح التنقية ضرورية، بإزالة الحارف أو المحتوى الخطير المحتمل. وقد يغيّر ذلك في بعض الحالات المعنى الدلالي للمدخل، لكن لأسباب أمنية قد لا يكون هناك بديل.

المستوى	الوصف	#
1	تحقق من أن جميع مدخلات HTML غير الموثوقة الواردة من محرّرات "ما تراه هو ما تحصل عليه" أو ما شابهها تُنقى باستخدام مكتبة تنقية HTML معروفة وآمنة أو ميزة في إطار العمل.	1.3.1
1	تحقق من أن التطبيق يتجنّب استخدام eval() أو غيره من ميزات تنفيذ الشيفرة الديناميكية مثل لغة تعبيرات Spring (SpEL). وحيث لا يوجد بديل، يجب تنقية أي مدخلات مستخدم تُضمّن قبل تنفيذها.	1.3.2
2	تحقق من أن البيانات المُمرّرة إلى سياق خطير محتمل تُنقى مسبقاً لإنفاذ تدابير السلامة، مثل السماح بالحارف الآمنة لهذا السياق فقط وتقليم المدخلات المفرطة الطول.	1.3.3
2	تحقق من أن محتوى الرسوميات المتجهية القابلة للتجسيم (SVG) القابل للبرمجة والمقدّم من المستخدم يُتحقّق من صحته أو يُنقى بحيث لا يحتوي إلا على الوسوم والسمات (مثل رسم الرسوميات) الآمنة للتطبيق، أي مثلاً لا يحتوي على نصوص برمجية أو foreignObject.	1.3.4
2	تحقق من أن التطبيق يُنقى أو يعطّل المحتوى القابل للبرمجة أو محتوى لغات قوالب التعبيرات المقدّم من المستخدم، مثل Markdown أو أوراق أنماط CSS أو XSL أو BBCode أو ما شابهها.	1.3.5
2	تحقق من أن التطبيق يحمي من هجمات تزوير الطلب من جانب الخادم، (SSRF) وذلك بالتحقق من البيانات غير الموثوقة مقابل قائمة سماح بالبروتوكولات والنطاقات والمسارات والمنافذ، وتنقية الحارف الخطيرة المحتملة قبل استخدام البيانات لاستدعاء خدمة أخرى.	1.3.6
2	تحقق من أن التطبيق يحمي من هجمات حقن القوالب بعدم السماح ببناء القوالب على أساس مدخلات غير موثوقة. وحيث لا يوجد بديل، يجب تنقية أي مدخلات غير موثوقة تُضمّن ديناميكياً أثناء إنشاء القالب أو التحقق منها بصراحة.	1.3.7
2	تحقق من أن التطبيق يُنقى المدخلات غير الموثوقة على النحو الملائم قبل استخدامها في استعلامات واجهة التسمية والدليل في Java، (JNDI) ومن أن JNDI مُهيّأة بأمان لمنع هجمات حقن JNDI.	1.3.8
2	تحقق من أن التطبيق يُنقى المحتوى قبل إرساله إلى memcache لمنع هجمات الحقن.	1.3.9
2	تحقق من أن سلاسل التنسيق التي قد تُحلّل بطريقة غير متوقعة أو خبيثة عند استخدامها تُنقى قبل معالجتها.	1.3.10
2	تحقق من أن التطبيق يُنقى مدخلات المستخدم قبل تمريرها إلى أنظمة البريد للحماية من حقن SMTP أو IMAP.	1.3.11
3	تحقق من أن التعبيرات النمطية خالية من العناصر المسببة للتراجع الأسّي، وتأكد من تنقية المدخلات غير الموثوقة للتخفيف من هجمات ReDoS أو التعبيرات النمطية الشاردة.	1.3.12

V1.4 الذاكرة والسلاسل والشفرة غير المُدارة

تتناول المتطلبات التالية المخاطر المرتبطة بالاستخدام غير الآمن للذاكرة، وهي تنطبق عموماً عندما يستخدم التطبيق لغة أنظمة أو شيفرة غير مُدارة.

وقد يكون من الممكن في بعض الحالات تحقيق ذلك بضبط أعلام المُصرِّف التي تُمكن الحماية من فيضان المخزن المؤقت والتحذيرات، بما في ذلك عشوائية المكّس ومنع تنفيذ البيانات، والتي تُفشل عملية البناء إذا وُجدت عمليات غير آمنة على المؤشرات أو الذاكرة أو سلاسل التنسيق أو الأعداد الصحيحة أو السلاسل.

المستوى	الوصف	#
2	تحقق من أن التطبيق يستخدم سلاسل آمنة للذاكرة ونسخاً أكثر أماناً للذاكرة وحساباً للمؤشرات لكشف فيضانات المكّس أو المخزن المؤقت أو الكومة أو منعها.	1.4.1
2	تحقق من استخدام تقنيات التحقق من الإشارة والنطاق والمدخلات لمنع فيضان الأعداد الصحيحة.	1.4.2
2	تحقق من تحرير الذاكرة والموارد المخصصة ديناميكياً، ومن إزالة المراجع أو المؤشرات إلى الذاكرة الحُرّة أو تعيينها إلى null لمنع المؤشرات المعلقة وثغرات الاستخدام بعد التحرير.	1.4.3

V1.5 فك التسلسل الآمن

إن تحويل البيانات من صورة مخزّنة أو منقولة إلى كائنات تطبيق فعلية (فك التسلسل) كان تاريخياً سبباً لثغرات حقن شيفرة متنوعة. ومن المهم تنفيذ هذه العملية بعناية وأمان لتجنّب هذه الأنواع من المشكلات.

وعلى وجه الخصوص، حدّدت طرائق معيّنة لفك التسلسل في وثائق لغات البرمجة أو أطر العمل بأنها غير آمنة ولا يمكن جعلها آمنة مع البيانات غير الموثوقة. ولكل آلية قيد الاستخدام، ينبغي إجراء تحرّ دقيق.

المستوى	الوصف	#
1	تحقق من أن التطبيق يهيئ مُحلّلات XML لاستخدام تكوين تقييدي ومن أن الميزات غير الآمنة، مثل حلّ الكائنات الخارجية، معطّلة لمنع هجمات كيان XML الخارجي (XXE).	1.5.1
2	تحقق من أن فك تسلسل البيانات غير الموثوقة يُنفذ معالجة آمنة للمدخلات، مثل استخدام قائمة سماح بأنواع الكائنات أو تقييد أنواع الكائنات التي يحددها العميل، وذلك لمنع هجمات فك التسلسل. ويجب ألا تُستخدم آليات فك التسلسل المعرّفة صراحةً بأنها غير آمنة مع مدخلات غير موثوقة.	1.5.2
3	تحقق من أن المُحلّلات المختلفة المستخدمة في التطبيق لنوع البيانات نفسه (مثل مُحلّلات JSON ومُحلّلات XML ومُحلّلات URL) تُنفذ التحليل بطريقة متسقة وتستخدم آلية ترميز المحارف نفسها، وذلك لتجنّب مشكلات مثل ثغرات قابلية التشغيل المتبادل في JSON أو استغلال اختلاف سلوك تحليل معرفات الموارد أو الملفات في هجمات تضمين الملفات البعيدة (RFI) أو تزوير الطلب من جانب الخادم (SSRF).	1.5.3

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Sheet Cheat Prevention Injection LDAP OWASP
- Sheet Cheat Prevention Scripting Site Cross OWASP
- Sheet Cheat Prevention Scripting Site Cross Based DOM OWASP
- Sheet Cheat Prevention Entity External XML OWASP
- Testing Client-Side Guide: Testing Security Web OWASP
- Project Encoding Java OWASP
- Library Sanitization HTML Client-side - DOMPurify
- Files (CSV) Values Comma-Separated for Type MIME and Format Common - RFC4180

ولمزيد من المعلومات، وتحديدًا عن مشكلات فك التسلسل أو التحليل، يُرجى الاطلاع على:

- Sheet Cheat Deserialization OWASP
- Vulnerabilities Interoperability JSON of Exploration An
- Languages Programming Trending In Parser URL Exploiting SSRF of Era New A - Tsai Orange

V2 التحقق من الصحة ومنطق العمل

الهدف من ضوابط الأمان

يهدف هذا الفصل إلى ضمان أن التطبيق المتحقق منه يحقق الأهداف الرفيعة المستوى التالية:

- أن تتوافق المدخلات التي يستقبلها التطبيق مع التوقعات التجارية أو الوظيفية.
- أن يكون سير منطق العمل تسلسلياً، ويُعالج بالترتيب، ولا يمكن تجاوزه.
- أن يشمل منطق العمل على حدود وضوابط لكشف الهجمات المؤتمتة ومنعها، مثل التحويلات المالية الصغيرة المتواصلة أو إضافة مليون صديق واحداً تلو الآخر.
- أن تكون مسارات منطق العمل عالية القيمة قد راعت حالات إساءة الاستخدام والجهات الخبيثة، وأن تتوافر لها حماية من هجمات التنكّر والتلاعب وكشف المعلومات وتضعيد الصلاحيات.

V2.1 توثيق التحقق من الصحة ومنطق العمل

ينبغي أن يحدّد توثيق التحقق من الصحة ومنطق العمل بوضوح حدود منطق العمل وقواعد التحقق من الصحة والاتساق السياقي لعناصر البيانات المجتمعة، بحيث يكون واضحاً ما يلزم تنفيذه في التطبيق.

المستوى	الوصف	#
1	تحقق من أن وثائق التطبيق تحدّد قواعد التحقق من صحة المدخلات لبيان كيفية فحص صلاحية عناصر البيانات مقابل بنية متوقعة. وقد تكون هذه صيغ بيانات شائعة مثل أرقام بطاقات الائتمان أو عناوين البريد الإلكتروني أو أرقام الهاتف، أو قد تكون صيغة بيانات داخلية.	2.1.1
2	تحقق من أن وثائق التطبيق تحدّد كيفية التحقق من الاتساق المنطقي والسياقي لعناصر البيانات المجمعة، مثل فحص تطابق الحي والرمز البريدي.	2.1.2
2	تحقق من أن التوقعات الخاصة بحدود منطق العمل وعمليات التحقق من الصحة موثقة، بما يشمل المستوى الخاص بكل مستخدم والمستوى العام على نطاق التطبيق.	2.1.3

V2.2 التحقق من صحة المدخلات

تُفد ضوابط التحقق الفعّالة من صحة المدخلات التوقعات التجارية أو الوظيفية بشأن نوع البيانات التي يتوقع التطبيق استقبالها. وهذا يضمن جودة البيانات ويقلّل سطح الهجوم. لكنه لا يزيل الحاجة إلى استخدام الترميز أو التعميم أو التنقية الصحيحة عند استخدام البيانات في مكّون آخر أو عند عرضها كمخرجات، ولا يحلّ محلّها.

وفي هذا السياق، قد تأتي "المدخلات" من مصادر متنوعة كثيرة، منها حقول نماذج HTML وطلبات REST ومعاملات URL وحقول ترويسة HTTP وملفات تعريف الارتباط والملفات على القرص وقواعد البيانات وواجهات برمجة التطبيقات الخارجية.

قد يفحص ضابط لمنطق العمل أن مُدخلًا معيّنًا هو رقم أقل من 100. وقد يفحص توقّع وظيفي أن رقمًا ما دون حد معيّن، لأن ذلك الرقم يتحكم في عدد مرات تنفيذ حلقة معيّنة، وقد يؤدي رقم كبير إلى معالجة مفرطة واحتمال حدوث حالة حجب خدمة.

ومع أن التحقق من الصحة عبر المخطّط ليس إلزاميًا صراحةً، فقد يكون الآلية الأكثر فعالية لتغطية التحقق الكامل لواجهات برمجة تطبيقات HTTP أو غيرها من الواجهات التي تستخدم JSON أو XML.

يرجى ملاحظة النقاط التالية بشأن التحقق من الصحة عبر المخطّط:

- يُعدّ "الإصدار المنشور" من مواصفة التحقق من الصحة عبر مخطّط JSON جاهزًا للإنتاج، لكنه ليس "مستقرًا" بالمعنى الدقيق. وعند استخدام التحقق عبر مخطّط JSON، تأكد من عدم وجود فجوات مقارنةً بالإرشادات الواردة في المتطلبات أدناه.
- ينبغي كذلك مراقبة أي مكتبات للتحقق من الصحة عبر مخطّط JSON قيد الاستخدام وتحديثها إذا لزم الأمر بعد إقرار المعيار رسميًا.
- لا ينبغي استخدام التحقق عبر DTD، وينبغي تعطيل تقييم DTD في أطر العمل، لتجنّب المشكلات المتعلقة بهجمات XXE على DTD.

المستوى	الوصف	#
1	تحقق من أن المدخلات يتم التحقق من صحتها لإنفاذ التوقعات التجارية أو الوظيفية الخاصة بها. وينبغي أن يستخدم ذلك إما تحققًا إيجابيًا مقابل قائمة سماح بالقيم والأنماط والنطاقات، أو أن يستند إلى مقارنة المُدخل ببنية متوقعة وحدود منطقية وفق قواعد محدّدة مسبقًا. وبالنسبة إلى المستوى 1، يمكن أن يركّز ذلك على المدخلات المستخدمة في اتخاذ قرارات تجارية أو أمنية محدّدة. أما للمستوى 2 وما فوق، فينبغي أن ينطبق على جميع المدخلات.	2.2.1

المستوى	الوصف	#
1	تحقق من أن التطبيق مصمّم لإنفاذ التحقق من صحة المدخلات في طبقة خدمة موثوقة. ومع أن التحقق من جانب العميل يحسّن قابلية الاستخدام وينبغي تشجيعه، فيجب ألا يعتمد عليه كضابط أمني.	2.2.2
2	تحقق من أن التطبيق يضمن أن تكون تركيبات عناصر البيانات المترابطة معقولة وفق القواعد المحددة مسبقاً.	2.2.3

V2.3 أمان منطق العمل

يتناول هذا القسم المتطلبات الرئيسية للتأكد من أن التطبيق يُنفذ عمليات منطق العمل على النحو الصحيح وأنه غير معرض للهجمات التي تستغل منطق التطبيق وسير عمله.

المستوى	الوصف	#
1	تحقق من أن التطبيق لن يعالج مسارات منطق العمل للمستخدم نفسه إلا بترتيب الخطوات التسلسلي المتوقع ودون تخطي خطوات.	2.3.1
2	تحقق من أن حدود منطق العمل مُنفذة وفق وثائق التطبيق لتجنّب استغلال عيوب منطق العمل.	2.3.2
2	تحقق من استخدام المعاملات على مستوى منطق العمل بحيث تنجح عملية منطق العمل بكاملها أو تُرجع إلى الحالة الصحيحة السابقة.	2.3.3
2	تحقق من استخدام آليات القفل على مستوى منطق العمل للتأكد من أن الموارد محدودة الكمية (مثل مقاعد المسرح أو فترات التوصيل) لا يمكن حجزها مرتين عن طريق التلاعب بمنطق التطبيق.	2.3.4
3	تحقق من أن مسارات منطق العمل عالية القيمة تتطلب موافقة متعددة المستخدمين لمنع الإجراءات غير المصرّح بها أو العارضة. وقد يشمل ذلك، على سبيل المثال لا الحصر، التحويلات المالية الكبيرة أو الموافقات على العقود أو الوصول إلى المعلومات المصنّفة أو تجاوزات السلامة في التصنيع.	2.3.5

V2.4 مكافحة الأتمتة

يشتمل هذا القسم على ضوابط لمكافحة الأتمتة للتأكد من اشتراط تفاعلات شبيهة بالبشرية ومنع الطلبات المؤتمتة المفرطة.

المستوى	الوصف	#
2	تحقق من وجود ضوابط لمكافحة الأتمتة للحماية من الاستدعاءات المفرطة لوظائف التطبيق التي قد تؤدي إلى تسريب البيانات أو إنشاء بيانات غير مفيدة أو استنفاد الحصص أو تجاوز حدود المعدّل أو حجب الخدمة أو الاستخدام المفرط للموارد المكلفة.	2.4.1
3	تحقق من أن مسارات منطق العمل تتطلب توقيتاً بشرياً واقعياً، بما يمنع تقديم المعاملات بسرعة مفرطة.	2.4.2

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Testing Validation Input Guide: Testing Security Web OWASP
- Testing Logic Business Guide: Testing Security Web OWASP
- يمكن تحقيق مكافحة الأتمتة بطرائق كثيرة، منها استخدام Applications Web to Threats Automated OWASP
- Sheet Cheat Validation Input OWASP
- Schema JSON

V3 أمان واجهة الويب الأمامية

الهدف من ضوابط الأمان

تركّز هذه الفئة على المتطلبات المصمّمة للحماية من الهجمات التي تُنفَّذ عبر واجهة ويب أمامية. ولا تنطبق هذه المتطلبات على الحلول من آلة إلى آلة.

V3.1 توثيق أمان واجهة الويب الأمامية

يبين هذا القسم ميزات أمان المتصفح التي ينبغي تحديدها في وثائق التطبيق.

المستوى	الوصف	#
3	تحقق من أن وثائق التطبيق تنص على ميزات الأمان المتوقعة التي يجب أن تدعمها المتصفحات المستخدمة للتطبيق (مثل HTTPS وأمان النقل الصارم عبر HTTP (HSTS) وسياسة أمان المحتوى (CSP) وغيرها من آليات أمان HTTP المعنية). ويجب أن تحدّد كذلك كيف يجب أن يتصرّف التطبيق عندما تكون بعض هذه الميزات غير متاحة (مثل تحذير المستخدم أو حجب الوصول).	3.1.1

V3.2 التفسير غير المقصود للمحتوى

يمكن أن يؤدي عرض المحتوى أو الوظائف في سياق غير صحيح إلى تنفيذ محتوى ضار أو عرضه.

المستوى	الوصف	#
1	تحقق من وجود ضوابط أمنية لمنع المتصفحات من عرض المحتوى أو الوظائف في استجابات HTTP في سياق غير صحيح (مثلاً عند طلب واجهة برمجة تطبيقات أو ملف حمّله المستخدم أو مورد آخر مباشرة). وقد تشمل الضوابط الممكنة: عدم تقديم المحتوى إلا إذا أشارت حقول ترويسة طلب HTTP (مثل Sec-Fetch-*) إلى أنه السياق الصحيح، أو استخدام توجيه sandbox في حقل ترويسة Content-Security-Policy، أو استخدام نوع الترتيب attachment في حقل ترويسة Content-Disposition.	3.2.1
1	تحقق من أن المحتوى المقصود عرضه كنص، بدلاً من عرضه كـ HTML، يُعالج باستخدام دوالّ عرض آمنة (مثل createTextNode أو textContent) لمنع التنفيذ غير المقصود لمحتوى مثل HTML أو JavaScript.	3.2.2
3	تحقق من أن التطبيق يتجنّب إغراق DOM عند استخدام JavaScript من جانب العميل، وذلك باستخدام تصريحات صريحة للمتغيرات وإجراء فحص صارم للأشكال وتجنّب تخزين المتغيرات العامة على كائن document وتنفيذ عزل لمساحات الأسماء.	3.2.3

V3.3 إعداد ملفات تعريف الارتباط

يبيّن هذا القسم متطلبات التهيئة الآمنة لملفات تعريف الارتباط الحساسة لتوفير مستوى أعلى من التوكيد بأنها أُنشئت بواسطة التطبيق نفسه، ولمنع تسريب محتوياتها أو تعديلها على نحو غير ملائم.

المستوى	الوصف	#
1	تحقق من أن ملفات تعريف الارتباط لها السمة 'Secure' مضبوطة، وإذا لم تُستخدم البادئة '-Host' لاسم ملف تعريف الارتباط، فيجب استخدام البادئة '-Secure' لاسمه.	3.3.1
2	تحقق من أن قيمة السمة 'SameSite' لكل ملف تعريف ارتباط مضبوطة وفق الغرض منه، للحد من التعرّض لهجمات إعادة تلبس واجهة المستخدم وهجمات تزوير الطلبات القائمة على المتصفح، المعروفة عموماً بتزوير الطلبات عبر المواقع (CSRF).	3.3.2
2	تحقق من أن ملفات تعريف الارتباط تحمل البادئة '-Host' في اسمها، إلا إذا كانت مصمّمة صراحةً لمشاركتها مع مضيفين آخرين.	3.3.3
2	تحقق من أنه، إذا لم يكن المقصود أن تكون قيمة ملف تعريف الارتباط متاحة للنصوص البرمجية من جانب العميل (مثل رمز الجلسة)، فيجب أن تكون السمة 'HttpOnly' مضبوطة لملف تعريف الارتباط، ويجب ألا تُنقل القيمة نفسها (مثل رمز الجلسة) إلى العميل إلا عبر حقل ترويسة 'Set-Cookie'.	3.3.4
3	تحقق من أن التطبيق، عند كتابته ملف تعريف ارتباط، لا يتجاوز مجموع طول اسمه وقيمته 4096 بايت. فملفات تعريف الارتباط المفرطة الحجم لن يُخزنها المتصفح ومن ثم لن تُرسل مع الطلبات، ما يمنع المستخدم من استخدام وظائف التطبيق التي تعتمد على ذلك الملف.	3.3.5

V3.4 ترويسات آليات أمان المتصفح

يوضّح هذا القسم ترويسات الأمان التي ينبغي ضبطها على استجابات HTTP لتمكين ميزات أمان المتصفح وقيوده عند التعامل مع استجابات التطبيق.

المستوى	الوصف	#
1	تحقق من إدراج حقل ترويسة Strict-Transport-Security في جميع الاستجابات لإنفاذ سياسة أمان النقل الصارم عبر HTTP (HSTS). ويجب تحديد عمر أقصى لا يقل عن سنة واحدة، والمستوى 2 وما فوق يجب أن تنطبق السياسة على جميع النطاقات الفرعية كذلك.	3.4.1
1	تحقق من أن حقل ترويسة Access-Control-Allow-Origin الخاص بمشاركة الموارد عبر الأصول (CORS) قيمة ثابتة يحددها التطبيق، أو أنه، في حال استخدام قيمة حقل ترويسة طلب HTTP المسمّى Origin، يُحقّق منها مقابل قائمة سماح بالأصول الموثوقة. وعندما يلزم استخدام 'Access-Control-Allow-Origin: *'، تحقق من أن الاستجابة لا تشتمل على أي معلومات حساسة.	3.4.2
2	تحقق من أن استجابات HTTP تشتمل على حقل ترويسة استجابة Content-Security-Policy يحدّد توجيهات تضمن ألا يحمل المتصفح وينفذ إلا المحتوى أو الموارد الموثوقة، وذلك للحد من تنفيذ JavaScript الضارة. وكحد أدنى، يجب استخدام سياسة عامة تشتمل على التوجيهين 'base-uri' و 'none'، وتحدّد إما قائمة سماح أو تستخدم قيمًا عشوائية لمرة واحدة أو تليديدات. وبالنسبة إلى تطبيق من المستوى 3، يجب تحديد سياسة لكل استجابة تستخدم قيمًا عشوائية لمرة واحدة أو تليديدات.	3.4.3
2	تحقق من أن جميع استجابات HTTP تحتوي على حقل ترويسة 'X-Content-Type-Options: nosniff'. وهذا يوجّه المتصفحات إلى عدم استخدام استشعار المحتوى وتخمين نوع MIME للاستجابة المعنية، وإلى اشتراط تطابق قيمة حقل ترويسة Content-Type للاستجابة مع المورد المقصود. على سبيل المثال، لا تُقبل الاستجابة لطلب نمط إلا إذا كان Content-Type للاستجابة هو 'text/css'. وهذا يُمكن كذلك استخدام وظيفة جيب القراءة عبر الأصول (CORB) في المتصفح.	3.4.4
2	تحقق من أن التطبيق يضبط سياسة للمُحيل لمنع تسريب البيانات الحساسة تقنياً إلى خدمات الأطراف الثالثة عبر حقل ترويسة طلب HTTP المسمّى 'Referer'. ويمكن تحقيق ذلك باستخدام حقل ترويسة استجابة HTTP المسمّى Referrer-Policy أو عبر سمات عناصر HTML. وقد تشمل البيانات الحساسة بيانات المسار والاستعلام في عنوان URL، وكذلك اسم المضيف في التطبيقات الداخلية غير العامة.	3.4.5
2	تحقق من أن تطبيق الويب يستخدم توجيه frame-ancestors في حقل ترويسة Content-Security-Policy لكل استجابة HTTP لضمان عدم إمكانية تضمينه افتراضياً، وأن تضمين موارد معينة مسموح به عند الضرورة فقط. ولاحظ أن حقل ترويسة X-Frame-Options، وإن كانت المتصفحات تدعمه، صار متقادماً ولا يجوز التعويل عليه.	3.4.6
3	تحقق من أن حقل ترويسة Content-Security-Policy يحدّد موقعاً للإبلاغ عن الانتهاكات.	3.4.7
3	تحقق من أن جميع استجابات HTTP التي تستهل عرض مستند (مثل الاستجابات ذات Content-Type text/html) تشتمل على حقل ترويسة Cross-Origin-Opener-Policy مع توجيه same-origin أو توجيه same-origin-allow-popups حسب المطلوب. وهذا يمنع الهجمات التي تأتيء استغلال الوصول المشترك إلى كائنات Window، مثل انتحال علامات التبويب وعدّ الإطارات.	3.4.8

V3.5 فصل الأصول في المتصفح

عند قبول طلب لوظيفة حساسة من جانب الخادم، يحتاج التطبيق إلى التأكد من أن الطلب قد استهّل التطبيق نفسه أو طرف موثوق وأنه لم يُزور بواسطة مهاجم.

وقد تشمل الوظائف الحساسة في هذا السياق قبول إرسال النماذج للمستخدمين المصادق عليهم وغير المصادق عليهم (مثل طلب مصادقة)، أو العمليات المعيّرة للحالة، أو الوظائف المطلوبة للموارد بكثافة (مثل تصدير البيانات).

وأهم الحماية هنا هي سياسات أمان المتصفح مثل سياسة الأصل الواحد الخاصة بـ JavaScript وكذلك منطق SameSite الخاص بملفات تعريف الارتباط. وهناك حماية شائعة أخرى هي آلية CORS التهديدية. وستكون هذه الآلية بالغة الأهمية لنقاط النهاية المصممة لاستدعائها من أصل مختلف، لكنها قد تكون كذلك آلية مفيدة لمنع تزوير الطلبات لنقاط النهاية غير المصممة لاستدعائها من أصل مختلف.

المستوى	الوصف	#
1	تحقق من أنه، إذا كان التطبيق لا يعول على آلية CORS التهديدية لمنع الطلبات غير المسموح بها عبر الأصول من استخدام وظائف حساسة، فإن هذه الطلبات يُتحقق منها للتأكد من أنها صادرة عن التطبيق نفسه. ويمكن تحقيق ذلك باستخدام رموز الحماية من التزوير والتحقق منها، أو باشتراط حقول ترويسة HTTP إضافية ليست من حقول ترويسة الطلب المدرجة في قائمة CORS الآمنة. والغرض من ذلك الدفاع عن هجمات تزوير الطلبات القائمة على المتصفح، المعروفة عموماً بتزوير الطلبات عبر المواقع (CSRF).	3.5.1
1	تحقق من أنه، إذا كان التطبيق يعول على آلية CORS التهديدية لمنع الاستخدام غير المسموح به للوظائف الحساسة عبر الأصول، فلا يمكن استدعاء الوظيفة بطلب لا يُشغل طلباً تهديدياً لـ CORS. وقد يقتضي ذلك فحص قيمتي حقلي ترويسة الطلب 'Origin' و'Content-Type' أو استخدام حقول ترويسة إضافي ليس من حقول الترويسة المدرجة في قائمة CORS الآمنة.	3.5.2
1	تحقق من أن طلبات HTTP الموجهة إلى الوظائف الحساسة تستخدم طرائق HTTP ملائمة مثل POST أو PUT أو PATCH أو DELETE، وليس الطرائق التي تعرفها مواصفة HTTP بأنها "آمنة" مثل HEAD أو OPTIONS أو GET. وبدلاً من ذلك، يمكن استخدام تحقق صارم من حقول ترويسة الطلب Sec-Fetch- للتأكد من أن الطلب لم يصدر عن استدعاء غير ملائم عبر الأصول أو عن طلب تنقل أو تحميل مورد (مثل مصدر صورة) حيث لا يكون ذلك متوقعاً.	3.5.3
2	تحقق من أن التطبيقات المنفصلة مستضافة على أسماء مضيفين مختلفة للاستفادة من القيود التي توفرها سياسة الأصل الواحد، بما في ذلك كيفية تفاعل المستندات أو النصوص البرمجية التي يحملها أصل ما مع موارد من أصل آخر، والقيود المبنية على اسم المضيف الخاصة بملفات تعريف الارتباط.	3.5.4
2	تحقق من أن الرسائل التي تستقبلها واجهة postMessage تُهمل إذا كان أصل الرسالة غير موثوق، أو إذا كانت صياغة الرسالة غير صحيحة.	3.5.5
3	تحقق من أن وظيفة JSONP غير مُمكنة في أي مكان في التطبيق، وذلك لتجنب هجمات تضمين النصوص البرمجية عبر المواقع (XSSI).	3.5.6
3	تحقق من أن البيانات التي تتطلب تخزيناً غير مدرجة في استجابات موارد النصوص البرمجية، مثل ملفات JavaScript، وذلك لمنع هجمات تضمين النصوص البرمجية عبر المواقع (XSSI).	3.5.7

المستوى	الوصف	#
3	تتحقق من أن الموارد المصادق عليها (مثل الصور ومقاطع الفيديو والنصوص البرمجية والمستندات الأخرى) لا يمكن تحميلها أو تضمينها بالنيابة عن المستخدم إلا عند القصد. ويمكن تحقيق ذلك بتحقيق صارم من حقول ترويسة طلب HTTP المسماة *Sec-Fetch للتأكد من أن الطلب لم يصدر عن استدعاء غير ملائم عبر الأصول، أو بضبط حقول ترويسة استجابة HTTP المسمى Cross-Origin-Resource-Policy ضبطاً	3.5.8
	تقييداً لتوجيه المتصفح إلى حجب المحتوى المُعاد.	

V3.6 سلامة الموارد الخارجية

يوفر هذا القسم إرشادات للاستضافة الآمنة للمحتوى على مواقع الأطراف الثالثة.

المستوى	الوصف	#
3	تتحقق من أن أصول جانب العميل، مثل مكتبات JavaScript أو CSS أو خطوط الويب، لا تُستضاف خارجياً (مثلاً على شبكة توصيل محتوى) إلا إذا كان المورد ساكناً ومُصدراً بإصدار، واستُخدمت سلامة الموارد الفرعية (SRI) للتحقق من سلامة الأصل. وإذا لم يكن ذلك ممكناً، فينبغي أن يكون هناك قرار أمني موثّق لتبرير ذلك لكل مورد.	3.6.1

V3.7 اعتبارات أخرى لأمان المتصفح

يشتمل هذا القسم على ضوابط أمنية أخرى متنوعة وميزات أمان المتصفحات الحديثة اللازمة لأمان المتصفح من جانب العميل.

المستوى	الوصف	#
2	تتحقق من أن التطبيق لا يستخدم إلا تقنيات جانب العميل التي لا تزال مدعومة وتُعدّ آمنة. ومن أمثلة التقنيات التي لا تستوفي هذا المتطلب إضافات NSAPI وFlash وShockwave وActiveX وSilverlight وNACL أو تطبيقات Java الصغيرة من جانب العميل.	3.7.1
2	تتحقق من أن التطبيق لن يعيد توجيه المستخدم تلقائياً إلى اسم مضيف أو نطاق مختلف (لا يتحكم فيه التطبيق) إلا إذا كانت الجهة المقصودة مدرجة في قائمة سماح.	3.7.2
3	تتحقق من أن التطبيق يعرض إشعاراً عند إعادة توجيه المستخدم إلى عنوان URL خارج نطاق سيطرة التطبيق، مع خيار إلغاء التنقل.	3.7.3
3	تتحقق من إضافة النطاق الأعلى للتطبيق (مثل site.tld إلى قائمة التحميل المسبق العامة الخاصة بأمان النقل الصارم عبر HTTP). (HSTS). وهذا يضمن أن استخدام TLS للتطبيق مدجج مباشرة في المتصفحات الرئيسية، بدلاً من التعويل على حقول ترويسة استجابة Strict-Transport-Security فقط.	3.7.4

المستوى	الوصف	#
3	تحقق من أن التطبيق يتصرّف على النحو الموثّق (مثل تحذير المستخدم أو حجب الوصول) إذا كان المتصفح المستخدم للوصول إلى التطبيق لا يدعم ميزات الأمان المتوقعة.	3.7.5

المراجع

لمزيد من المعلومات، انظر أيضًا:

- details prefix __Host- Set-Cookie
- Sheet Cheat Policy Security Content OWASP
- Project Headers Secure OWASP
- Sheet Cheat Prevention Forgery Request Cross-Site OWASP
- form submission List Preload Browser HSTS
- Sheet Cheat Prevention Clobbering DOM OWASP

V4 واجهات برمجة التطبيقات وخدمات الويب

الهدف من ضوابط الأمان

تنطبق عدة اعتبارات بشكل خاص على التطبيقات التي تعرض واجهات برمجة التطبيقات (APIs) لاستخدامها من قبل متصفحات الويب أو غيرها من المستهلكين (باستخدام JSON أو XML أو GraphQL في الغالب). يغطي هذا الفصل التكوينات والآليات الأمنية ذات الصلة التي ينبغي تطبيقها.

لاحظ أن الاعتبارات المتعلقة بالمصادقة وإدارة الجلسات والتحقق من صحة المدخلات الواردة في فصول أخرى تنطبق كذلك على واجهات برمجة التطبيقات، ولذلك لا يمكن أخذ هذا الفصل خارج سياقه أو اختباره بمعزل عن غيره.

V4.1 الأمان العام لخدمات الويب

يتناول هذا القسم الاعتبارات الأمنية العامة لخدمات الويب، وبالتالي الممارسات الأساسية للسلامة الأمنية في خدمات الويب.

المستوى	الوصف	#
1	تحقق من أن كل استجابة HTTP تحتوي على متن رسالة تشتمل على حقل ترويسة Content-Type يطابق المحتوى الفعلي للاستجابة، بما في ذلك معامل charset لتحديد ترميز محارف آمن (مثل UTF-8 أو ISO-8859-1 وفقًا لأنواع الوسائط المعتمدة من IANA، مثل "text/" و"xml+" و"xml/").	4.1.1

المستوى	الوصف	#
2	تحقق من أن نقاط النهاية الموجهة للمستخدم فقط (المخصصة للوصول اليدوي عبر متصفح الويب) هي التي تعيد التوجيه تلقائياً من HTTP إلى HTTPS، بينما لا تنفذ الخدمات أو نقاط النهاية الأخرى إعادة توجيه شفافة. والغرض من ذلك تجنب الحالة التي يرسل فيها العميل طلبات HTTP غير مشفرة عن طريق الخطأ، ولكن نظراً لإعادة توجيه هذه الطلبات تلقائياً إلى HTTPS، يبقى تسريب البيانات الحساسة غير مكتشف.	4.1.2
2	تحقق من أن أي حقل ترويسة HTTP يستخدمه التطبيق ويضبط بواسطة طبقة وسيطة، مثل موازن الحمل أو وكيل الويب أو خدمة الواجهة الخلفية للواجهة الأمامية، لا يمكن للمستخدم النهائي تجاوزه. ومن أمثلة الترويسات X-Real-IP أو X-Forwarded-* أو X-User-ID.	4.1.3
3	تحقق من أنه لا يمكن استخدام سوى طرائق HTTP المدعومة صراحةً من قبل التطبيق أو واجهة برمجة التطبيقات الخاصة به (بما في ذلك OPTIONS أثناء الطلبات التمهيدية)، وأن الطرائق غير المستخدمة محجوبة.	4.1.4
3	تحقق من استخدام التوقيعات الرقمية لكل رسالة لتوفير ضمان إضافي فوق حماية طبقة النقل للطلبات أو المعاملات البالغة الحساسية أو التي تمر عبر عدد من الأنظمة.	4.1.5

V4.2 التحقق من بنية رسائل HTTP

يوضح هذا القسم كيف ينبغي التحقق من بنية رسالة HTTP وحقوق ترويسها لمنع هجمات مثل تهريب الطلبات وتقسيم الاستجابة وحقن الترويسات وجلب الخدمة عن طريق رسائل HTTP المفرطة الطول.

هذه المتطلبات ذات صلة بمعالجة رسائل HTTP وتوليدها بشكل عام، لكنها مهمة على وجه الخصوص عند تحويل رسائل HTTP بين إصدارات HTTP المختلفة.

المستوى	الوصف	#
2	تحقق من أن جميع مكونات التطبيق (بما في ذلك موازنات الحمل والجدران النارية وخوادم التطبيقات) تحدّد حدود رسائل HTTP الواردة باستخدام الآلية المناسبة لإصدار HTTP لمنع تهريب طلبات HTTP في HTTP/1.x، إذا كان حقل الترويسة Transfer-Encoding موجوداً، فيجب تجاهل ترويسة Content-Length وفقاً لـ RFC 2616. وعند استخدام HTTP/2 أو HTTP/3، إذا كان حقل الترويسة Content-Length موجوداً، فيجب على المستقبل التأكد من توافقه مع طول أطر DATA.	4.2.1
3	تحقق من أن حقل الترويسة Content-Length عند توليد رسائل HTTP، لا يتعارض مع طول المحتوى كما تحدده أطر بروتوكول HTTP، وذلك لمنع هجمات تهريب الطلبات.	4.2.2
3	تحقق من أن التطبيق لا يرسل ولا يقبل رسائل HTTP/2 أو HTTP/3 التي تحتوي على حقول ترويسة خاصة بالاتصال مثل Transfer-Encoding، وذلك لمنع هجمات تقسيم الاستجابة وحقن الترويسات.	4.2.3
3	تحقق من أن التطبيق لا يقبل سوى طلبات HTTP/2 وHTTP/3 التي لا تحتوي حقول ترويسها وقيمها على أي متتاليات CR (\r) أو LF (\n) أو CRLF (\n\r)، وذلك لمنع هجمات حقن الترويسات.	4.2.4

المستوى	الوصف	#
3	تتحقق من أن التطبيق، إذا كان يبني الطلبات ويرسلها (في الواجهة الخلفية أو الأمامية)، يستخدم التحقق من الصحة أو التنقية أو آليات أخرى لتجنب إنشاء معرفات موارد موحدة (URIs) (مثل تلك الخاصة باستدعاءات واجهة برمجة التطبيقات) أو حقول ترويسة طلب HTTP (مثل Authorization أو Cookie) تكون أطول من أن يقبلها المكوّن المستقبل. وقد يؤدي ذلك إلى حجب الخدمة، كما يحدث عند إرسال طلب مفرط الطول (مثل حقل ترويسة cookie طويل)، ما ينتج عنه رد الخادم دائماً بحالة خطأ.	4.2.5

GraphQL V4.3

أصبح GraphQL أكثر شيوعاً كوسيلة لإنشاء عملاء غنيين بالبيانات وغير مرتبطين ارتباطاً وثيقاً بمجموعة متنوعة من خدمات الواجهة الخلفية. يغطي هذا القسم الاعتبارات الأمنية الخاصة بـ GraphQL.

المستوى	الوصف	#
2	تتحقق من استخدام قائمة سماح للاستعلامات أو تحديد العمق أو تحديد الكمية أو تحليل تكلفة الاستعلام لمنع حجب الخدمة (DoS) في GraphQL أو في تعبيرات طبقة البيانات نتيجة الاستعلامات المتداخلة والمكلفة.	4.3.1
2	تتحقق من تعطيل استعلامات الاستبطان (introspection) في GraphQL في بيئة الإنتاج، إلا إذا كان الغرض من واجهة برمجة تطبيقات GraphQL أن تستخدمها أطراف أخرى.	4.3.2

WebSocket V4.4

WebSocket هو بروتوكول اتصالات يوفر قناة اتصال ثنائية الاتجاه متزامنة عبر اتصال TCP واحد. وقد وضعته IETF كمعيّار في RFC 6455 عام 2011، وهو مختلف عن HTTP، على الرغم من أنه مصمّم للعمل عبر منفذي HTTP رقم 443 و80. يوفر هذا القسم متطلبات أمنية أساسية لمنع الهجمات المتعلقة بأمان الاتصال وإدارة الجلسات التي تستغل تحديداً قناة الاتصال الفوري هذه.

المستوى	الوصف	#
1	تتحقق من استخدام WebSocket عبر TLS (WSS) في جميع اتصالات WebSocket.	4.4.1
2	تتحقق من أن حقل الترويسة Origin أثناء مصادقة WebSocket الأولية عبر HTTP، يُفحص مقابل قائمة بالأصول المسموح بها للتطبيق.	4.4.2
2	تتحقق من أنه، في حال عدم إمكانية استخدام إدارة الجلسات القياسية الخاصة بالتطبيق، تُستخدم رموز مميزة مخصصة لهذا الغرض، تمثل لمتطلبات أمان إدارة الجلسات ذات الصلة.	4.4.3
2	تتحقق من أن الرموز المميزة المخصصة لإدارة جلسات WebSocket يتم الحصول عليها أو التحقق منها مبدئياً من خلال جلسة HTTPS المصادق عليها مسبقاً عند تحويل جلسة HTTPS قائمة إلى قناة WebSocket.	4.4.4

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Sheet Cheat Security REST OWASP
- موارد عن التخويل في GraphQL من graphQL.org وApollo.
- Testing GraphQL Guide: Testing Security Web OWASP
- WebSockets Testing Guide: Testing Security Web OWASP

V5 التعامل مع الملفات

الهدف من ضوابط الأمان

يمكن أن يمثل استخدام الملفات مخاطر متنوعة للتطبيق، منها يجب الخدمة والوصول غير المصرّح به واستنفاد مساحة التخزين. ويشتمل هذا الفصل على متطلبات لمعالجة هذه المخاطر.

V5.1 توثيق التعامل مع الملفات

يشتمل هذا القسم على متطلب لتوثيق الخصائص المتوقعة للملفات التي يقبلها التطبيق، كشرط مسبق ضروري لتطوير الفحوص الأمنية ذات الصلة والتحقق منها.

المستوى	الوصف	#
2	تتحقق من أن الوثائق تحدّد أنواع الملفات المسموح بها وامتدادات الملفات المتوقعة والحجم الأقصى (بما في ذلك الحجم بعد فك الحزم) لكل ميزة تحميل. وإضافةً إلى ذلك، تأكّد من أن الوثائق تحدّد كيف تُجعل الملفات آمنة للمستخدمين النهائيين لتنزيلها ومعالجتها، مثل كيفية تصرّف التطبيق عند اكتشاف ملف ضار.	5.1.1

V5.2 تحميل الملفات ومحتواها

تُعدّ وظيفة تحميل الملفات مصدراً رئيسياً للملفات غير الموثوقة. ويبيّن هذا القسم المتطلبات اللازمة للتأكد من أن وجود هذه الملفات أو حجمها أو محتواها لا يمكن أن يضرّ بالتطبيق.

المستوى	الوصف	#
1	تتحقق من أن التطبيق لن يقبل سوى الملفات ذات الحجم الذي يمكنه معالجته دون التسبب في فقدان الأداء أو هجوم يجب الخدمة.	5.2.1

المستوى	الوصف	#
1	تحقق من أن التطبيق، عند قبوله ملفاً، سواء بمفرده أو داخل أرشيف مثل ملف zip، يفحص ما إذا كان امتداد الملف يطابق امتداداً متوقعاً ويتحقق من أن المحتويات تتوافق مع النوع الذي يمثله الامتداد. ويشمل ذلك، على سبيل المثال لا الحصر، فحص "البايتات السحرية" الأولية، وإجراء إعادة كتابة للصور، واستخدام مكتبات متخصصة للتحقق من محتوى الملفات. وبالنسبة إلى المستوى 1، يمكن أن يركّز ذلك على الملفات المستخدمة في اتخاذ قرارات تجارية أو أمنية محدّدة فقط. أما للمستوى 2 وما فوق، فيجب أن ينطبق على جميع الملفات المقبولة.	5.2.2
2	تحقق من أن التطبيق يفحص الملفات المضغوطة (مثل zip وgz وdocx وodt) مقابل الحجم الأقصى المسموح به بعد فك الضغط ومقابل العدد الأقصى للملفات قبل فك ضغط الملف.	5.2.3
3	تحقق من إنفاذ حصة لحجم الملفات وعدد أقصى للملفات لكل مستخدم للتأكد من أن مستخدماً واحداً لا يمكنه إشغال مساحة التخزين بعدد كبير جداً من الملفات أو بملفات كبيرة الحجم بشكل مفرط.	5.2.4
3	تحقق من أن التطبيق لا يسمح بتحميل ملفات مضغوطة تحتوي على روابط رمزية إلا إذا كان ذلك مطلوباً تحديداً (وفي هذه الحالة سيكون من الضروري إنفاذ قائمة سماح بالملفات التي يمكن الربط الرمزي إليها).	5.2.5
3	تحقق من أن التطبيق يرفض الصور المحمّلة التي يتجاوز حجمها بالبكسل الحد الأقصى المسموح به، وذلك لمنع هجمات إغراق البكسل.	5.2.6

V5.3 تخزين الملفات

يشتمل هذا القسم على متطلبات لمنع تنفيذ الملفات على نحو غير ملائم بعد تحميلها، ولكشف المحتوى الخطير، ولتجنّب استخدام بيانات غير موثوقة في التحكم بمكان تخزين الملفات.

المستوى	الوصف	#
1	تحقق من أن الملفات المحمّلة أو المُولدة بمدخلات غير موثوقة والمخزّنة في مجلد عام لا تُنفذ كسيفرة برنامج من جانب الخادم عند الوصول إليها مباشرة بطلب HTTP.	5.3.1
1	تحقق من أن التطبيق، عند إنشائه مسارات ملفات لعمليات الملفات، يستخدم بيانات مُولدة داخلياً أو موثوقة بدلاً من أسماء الملفات المقدّمة من المستخدم، أو إذا كان لا بد من استخدام أسماء الملفات أو بياناتها الوصفية المقدّمة من المستخدم، فيجب تطبيق تحقق صارم وتنقية. والغرض من ذلك الحماية من هجمات اجتياز المسار وتضمين الملفات المحلية أو البعيدة (LFI) و(RFI) وتزوير الطلب من جانب الخادم (SSRF).	5.3.2
3	تحقق من أن معالجة الملفات من جانب الخادم، مثل فك ضغط الملفات، تتجاهل معلومات المسار المقدّمة من المستخدم لمنع ثغرات مثل slip. zip	5.3.3

V5.4 تنزيل الملفات

يحتوي هذا القسم على متطلبات للتخفيف من المخاطر عند تقديم الملفات للتنزيل، بما في ذلك اجتياز المسار وهجمات الحقن. ويشمل ذلك أيضاً التأكد من أنها لا تحتوي على محتوى خطير.

المستوى	الوصف	#
2	تحقق من أن التطبيق يتحقق من أسماء الملفات المقدّمة من المستخدم أو يتجاهلها، بما في ذلك الواردة في JSON أو JSONP أو معامل، URL وأنه يحدّد اسم ملف في حقل ترويسة Content-Disposition في الاستجابة.	5.4.1
2	تحقق من أن أسماء الملفات المقدّمة (مثلاً في حقول ترويسة استجابة HTTP أو مرفقات البريد الإلكتروني) مُرمّزة أو مُنقّاة (مثلاً وفقاً لـ RFC 6266) للحفاظ على بنية المستند ومنع هجمات الحقن.	5.4.2
2	تحقق من أن الملفات التي تُجلب من مصادر غير موثوقة تُفحص بواسطة برامج مكافحة الفيروسات لمنع تقديم محتوى ضار معروف.	5.4.3

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Sheet Cheat Upload File OWASP
- read file arbitrary for symlinks using of Example
- Wikipedia from Bytes” “Magic of Explanation

V6 المصادقة

الهدف من ضوابط الأمان

المصادقة هي عملية إرساء أو تأكيد أصالة فرد أو جهاز. وهي تتضمن التحقق من المطالبات التي يقدّمها شخص أو التي تُقدّم عن جهاز، وضمان المقاومة لانتحال الهوية، ومنع استعادة كلمات المرور أو اعتراضها.

إن NIST SP 800-63 معيار حديث قائم على الأدلة وقيم للمؤسسات في جميع أنحاء العالم، لكنه وثيق الصلة على وجه الخصوص بالوكالات الأمريكية وبمن يتعامل معها.

ومع أن كثيراً من المتطلبات في هذا الفصل مبنية على القسم الثاني من ذلك المعيار (المعروف بـ NIST SP 800-63B “إرشادات الهوية الرقمية - المصادقة وإدارة دورة الحياة”)، فإن الفصل يركّز على التهديدات الشائعة ونقاط ضعف المصادقة الشائعة الاستغلال. وهو لا يحاول تغطية كل نقطة في المعيار تغطيةً شاملة. وللحالات التي يكون فيها الامتثال الكامل لـ NIST SP 800-63 ضرورياً، يُرجى الرجوع إلى NIST SP 800-63.

وإضافةً إلى ذلك، قد تختلف مصطلحات NIST SP 800-63 أحياناً، ويستخدم هذا الفصل غالباً مصطلحات أكثر شيوعاً في الفهم لتحسين الوضوح.

ومن السمات الشائعة في التطبيقات الأكثر تقدماً القدرة على تكييف مراحل المصادقة المطلوبة بناءً على عوامل مخاطر متنوعة. وهذه السمة مشمولة في فصل “التحويل”، إذ يلزم مراعاة هذه الآليات في قرارات التحويل كذلك.

V6.1 توثيق المصادقة

يحتوي هذا القسم على متطلبات تبين توثيق المصادقة الذي ينبغي الاحتفاظ به لتطبيق ما. وهذا بالغ الأهمية لتنفيذ ضوابط المصادقة المعنية وتقدير كيفية تهيئتها.

المستوى	الوصف	#
1	تحقق من أن وثائق التطبيق تحدّد كيفية استخدام ضوابط مثل تحديد المعدّل ومكافحة الأتمتة والاستجابة التكيّفية للدفاع عن هجمات مثل حشو بيانات الاعتماد والقوة الغاشمة على كلمات المرور. ويجب أن توضّح الوثائق كيفية تهيئة هذه الضوابط ومنع الإغلاق الخبيث للحسابات.	6.1.1
2	تحقق من توثيق قائمة بالكلمات الخاصة بالسياق لمنع استخدامها في كلمات المرور. وقد تشمل القائمة على تصاريح أسماء المؤسسة وأسماء المنتجات ومعرفات الأنظمة والأسماء الرمزية للمشاريع وأسماء الأقسام أو الأدوار وما شابهها.	6.1.2
2	تحقق من أنه، إذا كان التطبيق يشتمل على مسارات مصادقة متعددة، فإنها موثّقة جميعاً إلى جانب ضوابط الأمان وقوة المصادقة التي يجب إنفاذها باتساق فيها كلها.	6.1.3

V6.2 أمان كلمات المرور

كلمات المرور، التي يسمّيها 800-63 SP NIST "الأسرار المحفوظة"، تشمل كلمات المرور وعبارات المرور وأرقام التعريف الشخصية وأنماط إلغاء القفل واختيار الحرية الصحيحة أو عنصر صورة آخر. وتعدّ عموماً "شيئاً تعرفه" وتستخدم غالباً كآلية مصادقة أحادية العامل. ولذلك يحتوي هذا القسم على متطلبات للتأكد من إنشاء كلمات المرور والتعامل معها بأمان. ومعظم المتطلبات من المستوى 1 لأنها أكثر أهمية في ذلك المستوى. ومن المستوى 2 وما بعده، تكون آليات المصادقة متعددة العوامل مطلوبة، وقد تكون كلمات المرور أحد تلك العوامل. وتتعلق المتطلبات في هذا القسم في معظمها بـ § 5.1.1.2 من إرشادات NIST.

المستوى	الوصف	#
1	تحقق من أن كلمات المرور التي يعيّن المستخدم لا تقل عن 8 محارف طولاً، وإن كان يُوصى بقوة بحد أدنى قدره 15 حرفاً.	6.2.1
1	تحقق من أن المستخدمين يمكنهم تغيير كلمة مرورهم.	6.2.2
1	تحقق من أن وظيفة تغيير كلمة المرور تتطلب كلمة مرور المستخدم الحالية والجديدة.	6.2.3
1	تحقق من أن كلمات المرور المقدّمة أثناء تسجيل الحساب أو تغيير كلمة المرور تُفحص مقابل مجموعة متاحة تشمل، على الأقل، أشهر 3000 كلمة مرور مطابقة لسياسة كلمات المرور في التطبيق، مثل الحد الأدنى للطول.	6.2.4
1	تحقق من إمكانية استخدام كلمات مرور بأي تركيب، دون قواعد تحدّد من نوع المحارف المسموح بها. ويجب ألا يكون هناك اشتراط لعدد أدنى من الأحرف الكبيرة أو الصغيرة أو الأرقام أو المحارف الخاصة.	6.2.5
1	تحقق من أن حقول إدخال كلمة المرور تستخدم type=password لإخفاء الإدخال. وقد تسمح التطبيقات للمستخدم بعرض كلمة المرور المخفية بالكامل مؤقتاً، أو آخر محرف مكتوب منها.	6.2.6

المستوى	الوصف	#
1	تحقق من السماح بوظيفة "اللقص" ومساعدات كلمات المرور في المتصفح ومديري كلمات المرور الخارجيين.	6.2.7
1	تحقق من أن التطبيق يتحقق من كلمة مرور المستخدم كما استُلمت منه بالضبط، دون أي تعديلات مثل الاقتطاع أو تحويل حالة الأحرف.	6.2.8
2	تحقق من السماح بكلمات مرور لا يقل طولها عن 64 حرفاً.	6.2.9
2	تحقق من أن كلمة مرور المستخدم تبقى صالحة حتى يُكتشف أنها مخترقة أو يبدّلها المستخدم. ويجب ألا يشترط التطبيق تدويراً دورياً لبيانات الاعتماد.	6.2.10
2	تحقق من استخدام القائمة الموثقة للكلمات الخاصة بالسياق لمنع إنشاء كلمات مرور سهلة التخمين.	6.2.11
2	تحقق من أن كلمات المرور المُقدّمة أثناء تسجيل الحساب أو تغييرها تُفحص مقابل مجموعة من كلمات المرور المسربة.	6.2.12

V6.3 الأمان العام للمصادقة

يحتوي هذا القسم على متطلبات عامة لأمان آليات المصادقة، وكذلك على بيان التوقعات المختلفة للمستويات. فيجب على تطبيقات المستوى 2 أن تُلزم باستخدام المصادقة متعددة العوامل (MFA). ويجب على تطبيقات المستوى 3 أن تستخدم مصادقة قائمة على العتاد، تُنفذ في بيئة تنفيذ موثوقة ومُصدّقة (TEE). وقد يشمل ذلك مفاتيح المرور المرتبطة بالجهاز، أو مُصادقات مُنفذة بمستوى توكيد عالٍ وفق (LoA eIDAS) (High) أو مُصادقات بمستوى توكيد المُصادق الثالث وفق NIST، (AAL3) أو آلية مكافئة.

ومع أن هذا موقف صارم نسبياً بشأن المصادقة متعددة العوامل، فمن الأهمية البالغة رفع مستوى الصعوبة في هذا الشأن لحماية المستخدمين، وينبغي أن تكون أي محاولة لتخفيف هذه المتطلبات مصحوبة بخطة واضحة عن كيفية التخفيف من المخاطر المتعلقة بالمصادقة، مع مراعاة إرشادات NIST وأبحاثها في الموضوع.

ولاحظ أن NIST SP 800-63، في وقت الإصدار، يعتبر البريد الإلكتروني غير مقبول كآلية مصادقة (نسخة محفوظة). وتتعلق المتطلبات في هذا القسم بأقسام متنوعة من إرشادات NIST، منها: § 4.2.1 و § 4.3.1 و § 5.2.2 و § 6.1.2.

المستوى	الوصف	#
1	تحقق من تنفيذ ضوابط لمنع هجمات مثل حشو بيانات الاعتماد والقوة الغاشمة على كلمات المرور وفق وثائق أمان التطبيق.	6.3.1
1	تحقق من أن حسابات المستخدمين الافتراضية (مثل "root" أو "admin" أو "sa") غير موجودة في التطبيق أو أنها معطلة.	6.3.2
2	تحقق من أنه يجب استخدام إما آلية مصادقة متعددة العوامل أو تركيبة من آليات المصادقة أحادية العامل للوصول إلى التطبيق. وبالنسبة إلى المستوى 3، يجب أن يكون أحد العوامل آلية مصادقة قائمة على العتاد توفر مقاومة للاختراق وانتحال الهوية أمام هجمات التصيد، مع التحقق من نية المصادقة باشتراط إجراء يبدأه المستخدم (مثل الضغط على زر في مفتاح FIDO عتادي أو في هاتف محمول). وأي تخفيف لأي من الاعتبارات في هذا المتطلب يقتضي مبرراً موثقاً بالكامل ومجموعة شاملة من الضوابط المخففة.	6.3.3

المستوى	الوصف	#
2	تحقق من أنه، إذا كان التطبيق يشتمل على مسارات مصادقة متعددة، فلا توجد مسارات غير موثقة، ومن أن ضوابط الأمان وقوة المصادقة مُنفذة باتساق.	6.3.4
3	تحقق من إبلاغ المستخدمين بمحاولات المصادقة المشبوهة (الناجحة أو غير الناجحة). وقد يشمل ذلك محاولات المصادقة من موقع أو عميل غير معتاد، أو المصادقة الناجحة جزئياً (أحد عوامل متعددة فقط)، أو محاولة مصادقة بعد فترة طويلة من عدم النشاط، أو مصادقة ناجحة بعد عدة محاولات غير ناجحة.	6.3.5
3	تحقق من أن البريد الإلكتروني لا يُستخدم كآلية مصادقة أحادية العامل ولا متعددة العوامل.	6.3.6
3	تحقق من إبلاغ المستخدمين بعد التحديثات على تفاصيل المصادقة، مثل إعادة تعيين بيانات الاعتماد أو تعديل اسم المستخدم أو عنوان البريد الإلكتروني.	6.3.7
3	تحقق من عدم إمكانية استنتاج المستخدمين الصحيحين من تحديات المصادقة الفاشلة، مثل الاستناد إلى رسائل الأخطاء أو رموز استجابة HTTP أو اختلاف أوقات الاستجابة. ويجب أن تتوفر هذه الحماية كذلك في وظيفتي التسجيل ونسيان كلمة المرور.	6.3.8

V6.4 دورة حياة عوامل المصادقة واستعادتها

قد تشمل عوامل المصادقة كلمات المرور والرموز البرمجية والرموز العتادية وأجهزة القياسات الحيوية. والتعامل الآمن مع دورة حياة هذه الآليات بالغ الأهمية لأمان التطبيق، ويشتمل هذا القسم على متطلبات متعلقة بذلك.

وتتعلق المتطلبات في هذا القسم في معظمها بـ § 5.1.1.2 أو § 6.1.2.3 من إرشادات NIST.

المستوى	الوصف	#
1	تحقق من أن كلمات المرور الأولية أو رموز التنشيط التي يولدها النظام تولّد عشوائياً بأمان، وتُتبع سياسة كلمات المرور القائمة، وتنتهي صلاحيتها بعد فترة قصيرة أو بعد استخدامها أول مرة. ويجب ألا يُسمح لهذه الأسرار الأولية بأن تصبح كلمة مرور طويلة الأجل.	6.4.1
1	تحقق من عدم وجود تلميحات لكلمات المرور أو مصادقة قائمة على المعرفة (ما يُسمى "الأسئلة السرية").	6.4.2
2	تحقق من تنفيذ عملية آمنة لإعادة تعيين كلمة مرور منسية، لا تتجاوز أي آليات مصادقة متعددة العوامل مُمكنة.	6.4.3
2	تحقق من أنه، في حال فقدان أحد عوامل المصادقة متعددة العوامل، يُجرى إثبات للهوية بالمستوى نفسه المتبع أثناء التسجيل.	6.4.4
3	تحقق من أن تعليمات التجديد لآليات المصادقة التي تنتهي صلاحيتها تُرسل بوقت كافٍ لتنفيذها قبل انتهاء صلاحية آلية المصادقة القديمة، مع تهيئة تذكيرات مؤتمتة إذا لزم الأمر.	6.4.5
3	تحقق من أن المستخدمين الإداريين يمكنهم بدء عملية إعادة تعيين كلمة المرور للمستخدم، لكن دون أن يتيح ذلك لهم تغيير كلمة مرور المستخدم أو اختيارها. وهذا يمنع وضعاً يعرفون فيه كلمة مرور المستخدم.	6.4.6

V6.5 المتطلبات العامة للمصادقة متعددة العوامل

يوفر هذا القسم إرشادات عامة تكون ذات صلة بطرائق مصادقة متعددة العوامل مختلفة ومتنوعة.

وتشمل الآليات ما يلي:

- أسرار البحث
- كلمات المرور لمرة واحدة المعتمدة على الوقت (TOTPs)
- الآليات خارج النطاق

أسرار البحث هي قوائم مُولّدة مسبقاً من الرموز السريّة، شبيهة بأرقام تحويل المعاملات (TAN) أو رموز استعادة وسائل التواصل الاجتماعي أو شبكة تحتوي على مجموعة من القيم العشوائية. ويُعدّ هذا النوع من آليات المصادقة "شيئاً تملكه" لأن الرموز غير قابلة للحفظ متعمداً ولذلك سيلزم تخزينها في مكان ما.

وكلمات المرور لمرة واحدة المعتمدة على الوقت (TOTPs) هي رموز فيزيائية أو برمجية تعرض تحدياً شبه عشوائياً لمرة واحدة يتغيّر باستمرار. ويُعدّ هذا النوع من آليات المصادقة "شيئاً تملكه". وكلمات المرور لمرة واحدة متعددة العوامل شبيهة بأحادية العامل، لكنها تتطلب إدخال رقم تعريف شخصي صحيح أو إلغاء قفل بالقياسات الحيوية أو إدخال USB أو إقران NFC أو قيمة إضافية (مثل حاسبات توقيع المعاملات) لإنشاء كلمة المرور لمرة واحدة النهائية. (OTP)

وستُقدّم تفاصيل عن الآليات خارج النطاق في القسم التالي.

وتنطبق المتطلبات في هذه الأقسام في معظمها بـ § 5.1.2 و § 5.1.3 و § 5.1.4.2 و § 5.1.5.2 و § 5.2.1 و § 5.2.3 من إرشادات NIST.

المستوى	الوصف	#
2	تحقق من أن أسرار البحث وطلبات أو رموز المصادقة خارج النطاق وكلمات المرور لمرة واحدة المعتمدة على الوقت (TOTPs) لا يمكن استخدامها بنجاح إلا مرة واحدة.	6.5.1
2	تحقق من أن أسرار البحث التي تقل عشوائيتها عن 112 بتاً (19 حرفاً أبجدياً رقيقاً عشوائياً أو 34 رقماً عشوائياً)، عند تخزينها في الواجهة الخلفية للتطبيق، تُلبّد بخوارزمية تلبيد معتمدة لتخزين كلمات المرور تشمل على ملح عشوائي بطول 32 بتاً. ويمكن استخدام دالة تلبيد قياسية إذا كانت عشوائية السر 112 بتاً أو أكثر.	6.5.2
2	تحقق من أن أسرار البحث ورموز المصادقة خارج النطاق وبذور كلمات المرور لمرة واحدة المعتمدة على الوقت تولّد باستخدام مولّد أعداد شبه عشوائية آمن تشفيرياً (CSPRNG) لتجنّب القيم القابلة للتوقع.	6.5.3
2	تحقق من أن أسرار البحث ورموز المصادقة خارج النطاق تمتلك 20 بتاً على الأقل من العشوائية (وعادةً يكفي 4 محارف أبجدية رقيقة عشوائية أو 6 أرقام عشوائية).	6.5.4
2	تحقق من أن طلبات أو رموز أو رموز المصادقة خارج النطاق المميزة، وكذلك كلمات المرور لمرة واحدة المعتمدة على الوقت (TOTPs) لها عمر محدّد. ويجب أن يكون للطلبات خارج النطاق عمر أقصى قدره 10 دقائق، وللكلمات المرور لمرة واحدة المعتمدة على الوقت عمر أقصى قدره 30 ثانية.	6.5.5
3	تحقق من إمكانية إبطال أي عامل مصادقة (بما فيها الأجهزة الفيزيائية) في حال السرقة أو أي فقدان آخر.	6.5.6
3	تحقق من أن آليات المصادقة بالقياسات الحيوية لا تُستخدم إلا كعوامل ثانوية إلى جانب إما شيء تملكه أو شيء تعرفه.	6.5.7

المستوى	الوصف	#
3	تُحقق من أن كلمات المرور لمرة واحدة المعتمدة على الوقت (TOTPs) تُفحص بناءً على مصدر وقت من خدمة موثوقة وليس من وقت غير موثوق أو مقدّم من العميل.	6.5.8

V6.6 آليات المصادقة خارج النطاق

يتضمّن ذلك عادةً تواصل خادم المصادقة مع جهاز فيزيائي عبر قناة ثانوية آمنة. على سبيل المثال، إرسال إشعارات دفع إلى الأجهزة المحمولة. ويُعدّ هذا النوع من آليات المصادقة "شيئًا تملكه".

ولا يُسمح بآليات المصادقة خارج النطاق غير الآمنة مثل البريد الإلكتروني والصوت عبر الإنترنت (VOIP) وتُعدّ المصادقة عبر شبكة الهاتف العمومية المبدّلة والرسائل القصيرة حاليًا آليات مصادقة "مقيّدة" لدى NIST وينبغي إيقافها لصالح كلمات المرور لمرة واحدة المعتمدة على الوقت (TOTPs) أو آلية تشفيرية أو ما شابه. ويوصي NIST SP 800-63B في § 5.1.3.3 بمعالجة مخاطر تبديل الجهاز أو تغيير بطاقة SIM أو نقل الرقم أو أي سلوك شاذ آخر، إذا كان لا بد من دعم المصادقة خارج النطاق عبر الهاتف أو الرسائل القصيرة. ومع أن هذا القسم من معيار التحقق من أمان التطبيقات لا يلزم بذلك كمتطلب، فإن عدم اتخاذ هذه الاحتياطات في تطبيق حساس من المستوى 2 أو في تطبيق من المستوى 3 ينبغي أن يُنظر إليه كعلامة تحذير كبيرة.

ولاحظ أن NIST قدّم كذلك مؤخرًا إرشادات ثني عن استخدام إشعارات الدفع. ومع أن هذا القسم من معيار التحقق من أمان التطبيقات لا يفعل ذلك، فن المهم الوعي بمخاطر "إغراق إشعارات الدفع".

المستوى	الوصف	#
2	تُحقق من أن آليات المصادقة التي تستخدم شبكة الهاتف العمومية المبدّلة (PSTN) لتسليم كلمات المرور لمرة واحدة (OTPs) عبر الهاتف أو الرسائل القصيرة لا تُقدّم إلا إذا كان رقم الهاتف قد تم التحقق منه مسبقًا، وتُقدّم كذلك طرائق بديلة أقوى (مثل كلمات المرور لمرة واحدة المعتمدة على الوقت)، وتوفّر الخدمة معلومات للمستخدمين عن مخاطرها الأمنية. وبالنسبة إلى تطبيقات المستوى 3، يجب ألا يكون الهاتف والرسائل القصيرة متاحين لخيارين.	6.6.1
2	تُحقق من أن طلبات أو رموز المصادقة خارج النطاق أو الرموز المميزة مرتبطة بطلب المصادقة الأصلي الذي وُلدت من أجله وأنها غير قابلة للاستخدام في طلب سابق أو لاحق.	6.6.2
2	تُحقق من أن آلية المصادقة خارج النطاق القائمة على رمز محمية من هجمات القوة الغاشمة باستخدام تحديد المعدّل. وينبغي كذلك النظر في استخدام رمز بعشوائية لا تقل عن 64 بتًا.	6.6.3
3	تُحقق من أنه، حيث تُستخدم إشعارات الدفع للمصادقة متعددة العوامل، يُستخدم تحديد المعدّل لمنع هجمات إغراق إشعارات الدفع. وقد يُخفّف مطابقة الأرقام من هذا الخطر كذلك.	6.6.4

V6.7 آلية المصادقة التشفيرية

تشمل آليات المصادقة التشفيرية البطاقات الذكية أو مفاتيح FIDO حيث يتعيّن على المستخدم إدخال الجهاز التشفيري أو إقرانه بالحاسوب لإتمام المصادقة. ويرسل خادم المصادقة قيمة عشوائية للتحدي إلى الجهاز أو البرمجية التشفيرية، فيحسب الجهاز أو البرمجية استجابة بناءً على

مفتاح تشفيري مخزن بأمان. وتوفّر المتطلبات في هذا القسم إرشادات خاصة بالتنفيذ لهذه الآليات، أما الإرشادات المتعلقة بخوارزميات التشفير فهي مشمولة في فصل "التشفير".

وحيث تُستخدم مفاتيح مشتركة أو سرّية للمصادقة التشفيرية، ينبغي تخزينها باستخدام الآليات نفسها المستخدمة لأسرار النظام الأخرى، على النحو الموثّق في قسم "إدارة الأسرار" في فصل "التكوين".

ونتعلق المتطلبات في هذا القسم في معظمها بـ § 5.1.7.2 من إرشادات NIST.

المستوى	الوصف	#
3	تحقق من أن الشهادات المستخدمة للتحقق من تأكيدات المصادقة التشفيرية مخزنة بطريقة تحميها من التعديل.	6.7.1
3	تحقق من أن قيمة التحدي العشوائية لا يقل طولها عن 64 بتاً، وأنها فريدة إحصائياً أو فريدة على مدى عمر الجهاز التشفيري.	6.7.2

V6.8 المصادقة عبر مزود هوية

يوفّر مزودو الهوية (IdPs) هوية اتحادية للمستخدمين. وكثيراً ما يكون للمستخدمين أكثر من هوية لدى مزودي هوية متعددين، مثل هوية مؤسسية باستخدام AD Azure أو Okta أو Identity Ping أو Google، أو هوية استهلاكية باستخدام Facebook أو Twitter أو Google، أو WeChat، على سبيل الذكر لبعض البدائل الشائعة. وهذه القائمة ليست تزكية لهذه الشركات أو الخدمات، بل مجرد تشجيع للمطوّرين على مراعاة واقع أن كثيراً من المستخدمين لديهم هويات مُرتّبة كثيرة. وينبغي للمؤسسات النظر في التكامل مع هويات المستخدمين القائمة، وفق ملف مخاطر قوة إثبات الهوية لدى مزود الهوية. فعلى سبيل المثال، من غير المرجّح أن تقبل مؤسسة حكومية هوية من وسائل التواصل الاجتماعي كوسيلة دخول إلى أنظمة حساسة، إذ يسهل إنشاء هويات مزيفة أو للاستخدام مرة واحدة، في حين قد تحتاج شركة ألعاب محمولة فعلاً إلى التكامل مع منصات التواصل الاجتماعي الكبرى لتنمية قاعدة لاعبيها النشطين.

ويقتضي الاستخدام الآمن لمزودي الهوية الخارجيين تهيئة وتحققاً دقيقين لمنع انتحال الهوية أو تزوير التأكيدات. ويوفّر هذا القسم متطلبات معالجة هذه المخاطر.

المستوى	الوصف	#
2	تحقق من أنه، إذا كان التطبيق يدعم مزودي هوية متعددين (IdPs) فلا يمكن انتحال هوية المستخدم عبر مزود هوية مدعوم آخر (مثلاً باستخدام معرف المستخدم نفسه). والتخفيف القياسي أن يسجل التطبيق المستخدم ويعرفه باستخدام تركيبة من معرف مزود الهوية (يوصفه مساحة أسماء) ومعرف المستخدم لدى ذلك المزود.	6.8.1
2	تحقق من أن وجود التوقيعات الرقمية على تأكيدات المصادقة وسلامتها (مثلاً على رموز JWT أو تأكيدات SAML) يتحقّق منهما دائماً، مع رفض أي تأكيدات غير موقعة أو ذات توقيعات غير صحيحة.	6.8.2
2	تحقق من أن تأكيدات SAML تُعالج على نحو فريد وتُستخدم مرة واحدة فقط خلال مدة الصلاحية لمنع هجمات إعادة الإرسال.	6.8.3

المستوى	الوصف	#
2	تحقق من أنه، إذا كان التطبيق يستخدم مزوّد هوية منفصلاً (IdP) ويتوقع قوة أو طرائق أو حداثة مصادقة معينة لوظائف بعينها، فإن التطبيق يتحقق من ذلك باستخدام المعلومات التي يعيدها مزوّد الهوية. فعلى سبيل المثال، إذا استخدم OI DC، فقد يتحقق ذلك بالتحقق من مطالبات رمز الهوية مثل 'acr' و'amr' و'auth_time' (إن وُجدت). وإذا لم يوفر مزوّد الهوية هذه المعلومات، فيجب أن يكون للتطبيق منهج احتياطي موثّق يفترض أن آلية المصادقة الأدنى قوة قد استخدمت (مثلاً مصادقة أحادية العامل باستخدام اسم المستخدم وكلمة المرور).	6.8.4

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Guidelines Identity Digital - 800-63 SP NIST
- Management Lifecycle and Authentication - 800-63B SP NIST
- FAQ 800-63 SP NIST
- Authentication for Testing Guide: Testing Security Web OWASP
- Sheet Cheat Storage Password OWASP
- Sheet Cheat Password Forgot OWASP
- Sheet Cheat Questions Security Using and Choosing OWASP
- Matching "Number on Guidance CISA
- Alliance FIDO the on Details

V7 إدارة الجلسات

الهدف من ضوابط الأمان

تتيح آليات إدارة الجلسات للتطبيقات ربط تفاعلات المستخدم والجهاز على مدار الزمن، حتى عند استخدام بروتوكولات اتصال عديمة الحالة (مثل HTTP). وقد تستخدم التطبيقات الحديثة رموز جلسة متعددة بخصائص وأغراض متميزة. ونظام إدارة الجلسات الآمن هو الذي يمنع المهاجمين من الحصول على جلسة الضحية أو استخدامها أو إساءة استغلالها بأي صورة أخرى. ويجب على التطبيقات التي تحتفظ بجلسات أن تضمن استيفاء متطلبات إدارة الجلسات الرفيعة المستوى التالية:

- أن تكون الجلسات فريدة لكل فرد ولا يمكن تخمينها أو مشاركتها.
- أن تُبطل الجلسات عندما لا تعد لازمة وأن تنتهي مهلتها في فترات عدم النشاط.

ويتعلق كثير من المتطلبات في هذا الفصل بضوابط مختارة من Guidelines Identity Digital 800-63 SP NIST، مع التركيز على التهديدات الشائعة ونقاط ضعف المصادقة الشائعة الاستغلال.

ولاحظ أن متطلبات تفاصيل التنفيذ المحددة لبعض آليات إدارة الجلسات يمكن العثور عليها في مواضع أخرى:

- تُعدّ ملفات تعريف ارتباط HTTP آلية شائعة لتأمين رموز الجلسة. ويمكن العثور على المتطلبات الأمنية المحددة لملفات تعريف الارتباط في فصل "أمان واجهة الويب الأمامية".
- تُستخدم الرموز المميزة المكتفية بذاتها كثيراً كوسيلة للحفاظ على الجلسات. ويمكن العثور على المتطلبات الأمنية المحددة في فصل "الرموز المميزة المكتفية بذاتها".

7.1.1 توثيق إدارة الجلسات

لا يوجد نمط واحد يناسب جميع التطبيقات. ولذلك ليس من الممكن تحديد حدود وقيود عامة تناسب جميع الحالات. ويجب إجراء تحليل للمخاطر مع قرارات أمنية موثقة متعلقة بالتعامل مع الجلسات كشرط مسبق للتنفيذ والاختبار. وهذا يضمن أن نظام إدارة الجلسات مُصمّم وفق المتطلبات المحددة للتطبيق.

وبصرف النظر عن اختيار آلية جلسة ذات حالة أو "عديمة الحالة"، يجب أن يكون التحليل كاملاً وموثّقاً لإثبات أن الحل المختار قادر على تلبية جميع المتطلبات الأمنية ذات الصلة. وينبغي كذلك مراعاة التفاعل مع أي آليات للدخول الموحد (SSO) قيد الاستخدام.

المستوى	الوصف	#
2	تحقق من أن مهلة عدم نشاط جلسة المستخدم والعمر الأقصى المطلق للجلسة موثّقان، وملائمان بالاقتران مع ضوابط أخرى، ومن أن الوثائق تشتمل على تبرير لأي انحرافات عن متطلبات إعادة المصادقة في SP NIST 800-63B.	7.1.1
2	تحقق من أن الوثائق تحدّد عدد الجلسات المتزامنة (المتوازية) المسموح بها لحساب واحد، وكذلك التصرفات والإجراءات المقصودة التي ستتخذ عند بلوغ العدد الأقصى للجلسات النشطة.	7.1.2
2	تحقق من توثيق جميع الأنظمة التي تنشئ جلسات المستخدمين وتديرها كجزء من منظومة إدارة هوية اتحادية (مثل أنظمة الدخول الموحد)، إلى جانب الضوابط اللازمة لتنسيق أعمار الجلسات وإنائها وأي شروط أخرى تقتضي إعادة المصادقة.	7.1.3

7.2 الأمان الأساسي لإدارة الجلسات

يلبي هذا القسم المتطلبات الجوهرية للجلسات الآمنة بالتحقق من أن رموز الجلسة تُولّد ويُحقّق منها بأمان.

المستوى	الوصف	#
1	تحقق من أن التطبيق ينفذ جميع عمليات التحقق من رموز الجلسة باستخدام خدمة موثوقة في الواجهة الخلفية.	7.2.1
1	تحقق من أن التطبيق يستخدم رموزاً مكتفية بذاتها أو رموزاً مرجعية تُولّد ديناميكياً لإدارة الجلسات، أي أنه لا يستخدم أسراراً ومفاتيح ثابتة لواجهات برمجة التطبيقات.	7.2.2
1	تحقق من أنه، إذا استخدمت الرموز المرجعية لتمثيل جلسات المستخدمين، فإنها فريدة ومُولّدة باستخدام مولّد أعداد شبه عشوائية آمن تشفيرياً (CSPRNG) وتمتلك 128 بتاً على الأقل من العشوائية.	7.2.3

المستوى	الوصف	#
1	تحقق من أن التطبيق يولّد رمز جلسة جديداً عند مصادقة المستخدم، بما في ذلك إعادة المصادقة، وينهي رمز الجلسة الحالي.	7.2.4

V7.3 مهلة الجلسة

تُخدم آليات مهلة الجلسة غرض تقليص نافذة الفرصة لاختطاف الجلسة وغيره من أشكال إساءة استغلال الجلسة. ويجب أن تُلبي المهل القرارات الأمنية الموثقة.

المستوى	الوصف	#
2	تحقق من وجود مهلة لعدم النشاط بحيث تُنفذ إعادة المصادقة وفق تحليل المخاطر والقرارات الأمنية الموثقة.	7.3.1
2	تحقق من وجود عمر أقصى مطلق للجلسة بحيث تُنفذ إعادة المصادقة وفق تحليل المخاطر والقرارات الأمنية الموثقة.	7.3.2

V7.4 إنهاء الجلسة

قد يتولى إنهاء الجلسة التطبيق نفسه أو مزوّد الدخول الموحد إذا كان المزوّد هو من يتولى إدارة الجلسات بدلاً من التطبيق. وقد يكون من الضروري تحديد ما إذا كان مزوّد الدخول الموحد داخلياً في النطاق عند النظر في متطلبات هذا القسم، إذ قد يتحكّم المزوّد في بعضها. وينبغي أن يؤدي إنهاء الجلسة إلى اشتراط إعادة المصادقة وأن يكون نافذاً على امتداد التطبيق وتسجيل الدخول الاتحادي (إن وُجد) وأي أطراف معوّلة.

وبالنسبة إلى آليات الجلسات ذات الحالة، يتضمّن الإنهاء عادةً إبطال الجلسة في الواجهة الخلفية. أما في حالة الرموز المميزة المكتفية بذاتها، فيلزم اتخاذ تدابير إضافية لإبطال هذه الرموز أو حجبها، إذ قد تبقى صالحة حتى انتهاء صلاحيتها.

المستوى	الوصف	#
1	تحقق من أن التطبيق، عند تشغيل إنهاء الجلسة (مثل تسجيل الخروج أو انتهاء الصلاحية)، يمنع أي استخدام إضافي للجلسة. وبالنسبة إلى الرموز المرجعية أو الجلسات ذات الحالة، يعني ذلك إبطال بيانات الجلسة في الواجهة الخلفية للتطبيق. أما التطبيقات التي تستخدم رموزاً مكتفية بذاتها فستحتاج إلى حل مثل الاحتفاظ بقائمة بالرموز المنتهية، أو منع الرموز المنتجة قبل تاريخ ووقت محدّدين لكل مستخدم، أو تدوير مفتاح توقيع خاص بكل مستخدم.	7.4.1
1	تحقق من أن التطبيق ينهي جميع الجلسات النشطة عند تعطيل حساب مستخدم أو حذفه (مثل مغادرة موظف للشركة).	7.4.2
2	تحقق من أن التطبيق يمنح خيار إنهاء جميع الجلسات النشطة الأخرى بعد نجاح تغيير أي عامل مصادقة أو إزالته (بما في ذلك تغيير كلمة المرور عن طريق إعادة التعيين أو الاستعادة، وتحديث إعدادات المصادقة متعددة العوامل إن وُجدت).	7.4.3

المستوى	الوصف	#
2	تحقق من أن جميع الصفحات التي تُطلب مصادقة تتيح وصولاً سهلاً وظاهراً إلى وظيفة تسجيل الخروج.	7.4.4
2	تحقق من أن مسؤولي التطبيق قادرون على إنهاء الجلسات النشطة لمستخدم فردي أو لجميع المستخدمين.	7.4.5

7.5 الدفاعات ضد إساءة استغلال الجلسة

يؤقّر هذا القسم متطلبات للتخفيف من المخاطر التي تمثّلها الجلسات النشطة التي تُحتطّف أو يُساء استغلالها عبر متجهات تعتمد على وجود جلسات المستخدمين النشطة وقدراتها. على سبيل المثال، استخدام تنفيذ محتوى ضار لإجبار متصفح ضحية مصادق عليه على تنفيذ إجراء باستخدام جلسة الضحية.

ولاحظ أنه ينبغي مراعاة الإرشادات الخاصة بالمستويات في فصل "المصادقة" عند النظر في متطلبات هذا القسم.

المستوى	الوصف	#
2	تحقق من أن التطبيق يتطلّب إعادة مصادقة كاملة قبل السماح بتعديل سمات الحساب الحساسة التي قد تؤثر في المصادقة، مثل عنوان البريد الإلكتروني أو رقم الهاتف أو تكوين المصادقة متعددة العوامل أو غيرها من المعلومات المستخدمة في استعادة الحساب.	7.5.1
2	تحقق من أن المستخدمين قادرون على عرض أي من الجلسات النشطة حالياً أو جميعها وإنهاءها (بعد إعادة المصادقة بعامل واحد على الأقل).	7.5.2
3	تحقق من أن التطبيق يتطلّب مصادقة إضافية بعامل واحد على الأقل أو تحقّقاً ثانوياً قبل تنفيذ المعاملات أو العمليات البالغة الحساسية.	7.5.3

7.6 إعادة المصادقة الاتحادية

يتعلق هذا القسم بمن يكتبون شيفرة الطرف المعوّل (RP) أو مزوّد الهوية (IdP) وهذه المتطلبات مستقاة من 800-63C SP NIST الخاص بالاتحاد والتأكدات.

المستوى	الوصف	#
2	تحقق من أن عمر الجلسة وإنهاءها بين الأطراف المعوّل (RPs) ومزوّد الهوية (IdPs) يسلكان على النحو الموثّق، مع اشتراط إعادة المصادقة عند الضرورة، مثل بلوغ الحد الأقصى للمدة بين أحداث المصادقة لدى مزوّد الهوية.	7.6.1
2	تحقق من أن إنشاء الجلسة يتطلّب إما موافقة المستخدم أو إجراءً صريحاً، بما يمنع إنشاء جلسات تطبيق جديدة دون تفاعل المستخدم.	7.6.2

المراجع

لمزيد من المعلومات، انظر أيضاً:

Testing Management Session Guide: Testing Security Web OWASP •

Sheet Cheat Management Session OWASP •

V8 التحويل

الهدف من ضوابط الأمان

يضمن التحويل أن الوصول لا يُمنح إلا للمستهلكين المسموح لهم (المستخدمون والخوادم والعملاء الآخرون). ولإنفاذ مبدأ الحد الأدنى من الصلاحيات (POLP) يجب أن تستوفي التطبيقات المتحقق منها المتطلبات الرفيعة المستوى التالية:

- توثيق قواعد التحويل، بما في ذلك عوامل اتخاذ القرار والسياقات البيئية.
- ينبغي أن يكون للمستهلكين وصول إلى الموارد التي تسمح بها استحقاقاتهم المحددة فقط.

V8.1 توثيق التحويل

إن التوثيق الشامل للتحويل ضروري للتأكد من أن القرارات الأمنية تُطبّق باتساق وقابلة للتدقيق ومتوافقة مع سياسات المؤسسة. وهذا يقلّل خطر الوصول غير المصرّح به بجعل متطلبات الأمان واضحة وقابلة للتنفيذ للمطوّرين والمسؤولين والمختبرين.

المستوى	الوصف	#
1	تحقق من أن توثيق التحويل يحدّد قواعد لتقييد الوصول على مستوى الوظائف والوصول الخاص بالبيانات بناءً على صلاحيات المستهلك وسمات الموارد.	8.1.1
2	تحقق من أن توثيق التحويل يحدّد قواعد لتقييد الوصول على مستوى الحقوق (للقراءة والكتابة على حد سواء) بناءً على صلاحيات المستهلك وسمات الموارد. ولاحظ أن هذه القواعد قد تعتمد على قيم سمات أخرى لكائن البيانات المعني، مثل الحالة أو الوضع.	8.1.2
3	تحقق من أن وثائق التطبيق تحدّد السمات البيئية والسياقية (بما في ذلك، على سبيل المثال لا الحصر، وقت اليوم أو موقع المستخدم أو عنوان IP أو الجهاز) المستخدمة في التطبيق لاتخاذ القرارات الأمنية، بما فيها القرارات المتعلقة بالمصادقة والتحويل.	8.1.3
3	تحقق من أن وثائق المصادقة والتحويل تحدّد كيفية استخدام العوامل البيئية والسياقية في اتخاذ القرار، إضافةً إلى التحويل على مستوى الوظائف والبيانات والحقوق. وينبغي أن يشمل ذلك السمات التي تُقيّم وحدود المخاطر والإجراءات المتخذة (مثل السماح أو التحدي أو المنع أو المصادقة المعززة).	8.1.4

V8.2 التصميم العام للتحويل

إن تنفيذ ضوابط تحويل دقيقة على مستويات الوظائف والبيانات والحقول يضمن أن المستهلكين لا يمكنهم الوصول إلا إلى ما مُنح لهم صراحةً.

المستوى	الوصف	#
1	تحقق من أن التطبيق يضمن أن الوصول على مستوى الوظائف مقصور على المستهلكين ذوي الصلاحيات الصريحة.	8.2.1
1	تحقق من أن التطبيق يضمن أن الوصول الخاص بالبيانات مقصور على المستهلكين ذوي الصلاحيات الصريحة لعناصر بيانات محدّدة، وذلك للتخفيف من الإشارة المباشرة غير الآمنة إلى الكائنات (IDOR) والتحويل المعطوب على مستوى الكائن (BOLA).	8.2.2
2	تحقق من أن التطبيق يضمن أن الوصول على مستوى الحقول مقصور على المستهلكين ذوي الصلاحيات الصريحة لحقوق محدّدة، وذلك للتخفيف من التحويل المعطوب على مستوى خصائص الكائن (BOPLA).	8.2.3
3	تحقق من تنفيذ ضوابط أمنية تكيفية مبنية على السمات البيئية والسياقية للمستهلك (مثل وقت اليوم أو الموقع أو عنوان IP أو الجهاز) لقرارات المصادقة والتحويل، على النحو المحدّد في وثائق التطبيق. ويجب تطبيق هذه الضوابط عندما يحاول المستهلك بدء جلسة جديدة وكذلك أثناء جلسة قائمة.	8.2.4

V8.3 التحويل على مستوى العمليات

إن التطبيق الفوري لتغييرات التحويل في الطبقة المناسبة من معمارية التطبيق أمر بالغ الأهمية لمنع الإجراءات غير المصرّح بها، وخصوصاً في البيئات الديناميكية.

المستوى	الوصف	#
1	تحقق من أن التطبيق يُنفذ قواعد التحويل في طبقة خدمة موثوقة ولا يعتمد على ضوابط يمكن لمستهلك غير موثوق التلاعب بها، مثل JavaScript من جانب العميل.	8.3.1
3	تحقق من أن التغييرات في القيم التي تُتخذ على أساسها قرارات التحويل تُطبّق فوراً. وحيث لا يمكن تطبيق التغييرات فوراً (مثل حالة الاعتماد على بيانات في رموز مميزة مكتفية بذاتها)، يجب أن توجد ضوابط مخفّفة للتنبيه عندما ينفّذ المستهلك إجراءً لم يعد مصرّحاً له بتنفيذه، ولإرجاع التغيير. ولاحظ أن هذا البديل لن يخفّف من تسريب المعلومات.	8.3.2
3	تحقق من أن الوصول إلى كائن يستند إلى صلاحيات الذات الأصلية (مثل المستهلك)، وليس إلى صلاحيات أي وسيط أو خدمة تعمل بالنيابة عنه. على سبيل المثال، إذا استدعى مستهلك خدمة ويب باستخدام رمز مميز مكتفٍ بذاته للمصادقة، ثم طلبت الخدمة بيانات من خدمة أخرى، فستستخدم الخدمة الثانية رمز المستهلك، وليس رمزاً من آلة إلى آلة من الخدمة الأولى، لاتخاذ قرارات الصلاحيات.	8.3.3

V8.4 اعتبارات أخرى للتحويل

تساعد الاعتبارات الإضافية للتحويل، وخصوصاً لواجهات الإدارة والبيئات متعددة المستأجرين، على منع الوصول غير المصرّح به.

المستوى	الوصف	#
2	تتحقق من أن التطبيقات متعددة المستأجرين تستخدم ضوابط عبر المستأجرين للتأكد من أن عمليات المستهلك لن تؤثر أبداً في مستأجرين لا يمتلك صلاحيات التفاعل معهم.	8.4.1
3	تتحقق من أن الوصول إلى واجهات الإدارة يشتمل على طبقات أمان متعددة، بما في ذلك التحقق المستمر من هوية المستهلك وتقييم الوضع الأمني للجهاز وتحليل المخاطر السياقي، بما يضمن ألا يكون موقع الشبكة أو نقاط النهاية الموثوقة العوامل الوحيدة للتحويل، وإن كانت قد تقلّل احتمال الوصول غير المصرّح به.	8.4.2

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Authorization Guide: Testing Security Web OWASP •
- Sheet Cheat Authorization OWASP •

V9 الرموز المميزة المكتفية بذاتها

الهدف من ضوابط الأمان

ورد مفهوم الرمز المميز المكتفي بذاته في الأصل في RFC 6749 الخاص بـ OAuth 2.0 لعام 2012. وهو يشير إلى رمز مميز يحتوي على بيانات أو مطالبات تعوّل عليها خدمة مستقبلية لاتخاذ قرارات أمنية. وينبغي تمييز ذلك عن رمز مميز بسيط يحتوي على معرف فقط، تستخدمه الخدمة المستقبلية للبحث عن البيانات محلياً. وأشهر أمثلة الرموز المميزة المكتفية بذاتها هي رموز Web JSON Tokens (JWTs) وتأكيّادات SAML.

أصبح استخدام الرموز المميزة المكتفية بذاتها واسع الانتشار جداً، حتى خارج نطاق OAuth وOIDC. وفي الوقت نفسه، يعتمد أمان هذه الآلية على القدرة على التحقق من سلامة الرمز والتأكد من أنه صالح لسياق معين. وهناك مزالق كثيرة في هذه العملية، ويوفّر هذا الفصل تفاصيل محدّدة عن الآليات التي ينبغي أن تتوافر في التطبيقات لمنعها.

V9.1 مصدر الرمز المميز وسلامته

يشتمل هذا القسم على متطلبات للتأكد من أن الرمز المميز قد أنتجته طرف موثوق وأنه لم يُتلاعب به.

المستوى	الوصف	#
1	تحقق من أن الرموز المميزة المكتفية بذاتها يتم التحقق منها باستخدام توقيعها الرقمي أو رمز مصادقة الرسالة (MAC) للحماية من التلاعب قبل قبول محتوياتها.	9.1.1
1	تحقق من أن الخوارزميات المدرجة في قائمة سماح هي وحدها التي يمكن استخدامها لإنشاء الرموز المميزة المكتفية بذاتها والتحقق منها، في سياق معيّن. ويجب أن تتضمن قائمة السماح الخوارزميات المسموح بها، ومن الأفضل أن تكون خوارزميات متناظرة فقط أو غير متناظرة فقط، ويجب ألا تتضمن الخوارزمية 'None'. وإذا كان يجب دعم النوعين المتناظر وغير المتناظر، فستكون هناك حاجة إلى ضوابط إضافية لمنع الالتباس في المفاتيح.	9.1.2
1	تحقق من أن مادة المفاتيح المستخدمة للتحقق من الرموز المميزة المكتفية بذاتها تأتي من مصادر موثوقة مهيأة مسبقاً لجهة إصدار الرمز، ما يمنع المهاجمين من تحديد مصادر ومفاتيح غير موثوقة. وبالنسبة إلى رموز JWT وغيرها من بني JWS، يجب التحقق من ترويسات مثل 'jku' و'x5u' و'jwk' مقابل قائمة سماح المصادر الموثوقة.	9.1.3

V9.2 محتوى الرمز المميز

قبل اتخاذ قرارات أمنية بناءً على محتوى رمز مميز مكتفٍ بذاته، من الضروري التحقق من أن الرمز قد قُدّم خلال مدة صلاحيته وأنه مخصّص للاستخدام من قبل الخدمة المستقبلية وللغرض الذي قُدّم من أجله. وهذا يساعد على تجنب الاستخدام المتقاطع غير الآمن بين خدمات مختلفة أو مع أنواع رموز مختلفة من الجهة المُصدِّرة نفسها.

أما المتطلبات الخاصة بـ OAuth وOIDC فهي مشمولة في الفصل المخصّص لها.

المستوى	الوصف	#
1	تحقق من أنه، في حال وجود مدة صلاحية في بيانات الرمز المميز، لا يُقبل الرمز ومحتواه إلا إذا كان وقت التحقق واقعاً داخل مدة الصلاحية هذه. على سبيل المثال، بالنسبة إلى رموز JWT، يجب التحقق من المطالبتين 'nfb' و'exp'.	9.2.1
2	تحقق من أن الخدمة التي تستقبل رمزاً مميزاً تتحقق من أنه من النوع الصحيح وأنه مخصّص للغرض المقصود قبل قبول محتوياته. على سبيل المثال، لا يمكن قبول سوى رموز الوصول لقرارات التخويل، ولا يمكن استخدام سوى رموز الهوية (ID Tokens) لإثبات مصادقة المستخدم.	9.2.2
2	تحقق من أن الخدمة لا تقبل سوى الرموز المميزة المخصّصة للاستخدام معها (الجهة المستهدفة). وبالنسبة إلى رموز JWT، يمكن تحقيق ذلك بالتحقق من مطالبة 'aud' مقابل قائمة سماح محدّدة في الخدمة.	9.2.3
2	تحقق من أنه، إذا كانت جهة إصدار الرموز تستخدم المفتاح الخاص نفسه لإصدار رموز لجهات مستهدفة مختلفة، فإن الرموز الصادرة تحتوي على قيد للجهة المستهدفة يعرف الجهات المقصودة تعريفاً فريداً. وهذا سيمنع إعادة استخدام الرمز مع جهة مستهدفة غير مقصودة. وإذا كان معرف الجهة المستهدفة يُمنح ديناميكياً، فيجب على جهة إصدار الرموز التحقق من هذه الجهات للتأكد من أنها لا تؤدي إلى انتقال هوية الجهة المستهدفة.	9.2.4

المراجع

لمزيد من المعلومات، انظر أيضاً:

• Sheet Cheat Java for Sheet Cheat Token Web JSON OWASP (لكنه يتضمّن إرشادات عامة مفيدة)

V10 معياري OAuth و OIDC

الهدف من ضوابط الأمان

إن OAuth2 (المشار إليه بـ OAuth في هذا الفصل) إطار عمل معياري في الصناعة للتحويل المفوّض. فعلى سبيل المثال، يمكن لتطبيق عميل، باستخدام OAuth، أن يحصل على وصول إلى واجهات برمجة التطبيقات (موارد الخادم) بالنيابة عن مستخدم، بشرط أن يكون المستخدم قد خوّّل تطبيق العميل بذلك.

وليس OAuth بحد ذاته مصمماً لمصادقة المستخدمين. ويوسّع إطار عمل Connect OpenID (OIDC) نطاق OAuth بإضافة طبقة هوية للمستخدم فوّه. ويوفّر OIDC دعمًا لميزات منها معلومات المستخدم الموحّدة والدخول الموحد (SSO) وإدارة الجلسات. وبما أن OIDC امتداد لـ OAuth، فإن متطلبات OAuth في هذا الفصل تنطبق على OIDC كذلك.

وتُعرّف الأدوار التالية في OAuth:

• عميل OAuth هو التطبيق الذي يحاول الحصول على وصول إلى موارد الخادم (مثلاً باستدعاء واجهة برمجة تطبيقات باستخدام رمز الوصول الصادر). و عميل OAuth كثيراً ما يكون تطبيقاً من جانب الخادم.

- العميل السريّ هو عميل قادر على الحفاظ على سرّية بيانات الاعتماد التي يستخدمها للمصادقة على نفسه لدى خادم التحويل.
- العميل العام غير قادر على الحفاظ على سرّية بيانات الاعتماد اللازمة للمصادقة لدى خادم التحويل. ولذلك، فبدلاً من المصادقة على نفسه (مثلاً باستخدام المعاملين 'client_id' و 'client_secret')، فإنه يعرف نفسه فقط (باستخدام المعامل 'client_id').

• خادم موارد OAuth (RS) هو واجهة برمجة تطبيقات الخادم التي تعرض الموارد لعملاء OAuth.
• خادم تحويل OAuth (AS) هو تطبيق خادم يُصدر رموز الوصول لعملاء OAuth. وتتيح رموز الوصول هذه لعملاء OAuth الوصول إلى موارد خادم الموارد، إما بالنيابة عن مستخدم نهائي أو بالنيابة عن عميل OAuth نفسه. وكثيراً ما يكون خادم التحويل تطبيقاً منفصلاً، لكنه قد يكون (إذا كان ذلك ملائماً) مدمجاً في خادم موارد مناسب.
• مالك الموارد (RO) هو المستخدم النهائي الذي يخوّل عملاء OAuth للحصول على وصول محدود إلى الموارد المستضافة على خادم الموارد بالنيابة عنه. ويوافق مالك الموارد على هذا التحويل المفوّض بالتفاعل مع خادم التحويل.

وتُعرّف الأدوار التالية في OIDC:

• الطرف المعوّل (RP) هو تطبيق العميل الذي يطلب مصادقة المستخدم النهائي عبر مزود OpenID. وهو يتولى دور عميل OAuth.
• مزود OpenID (OP) هو خادم تحويل OAuth قادر على مصادقة المستخدم النهائي ويوفّر مطالبات OIDC للطرف المعوّل. وقد يكون مزود OpenID هو مزود الهوية (IdP) لكن في السيناريوهات الاتحادية قد يكون مزود OpenID ومزود الهوية (الذي يصادق المستخدم النهائي لديه) تطبيقَي خادم مختلفين.

وقد صُمِّمَ OAuth و OIDC في البداية لتطبيقات الأطراف الثالثة. وهما اليوم يُستخدمان كثيراً من قبل تطبيقات الطرف الأول كذلك. لكن عند استخدامهما في سيناريوهات الطرف الأول، مثل المصادقة وإدارة الجلسات، يضيف البروتوكول بعض التعقيد، ما قد يُدخل تحديات أمنية جديدة.

ويمكن استخدام OAuth و OIDC في أنواع كثيرة من التطبيقات، لكن تركيز معيار التحقق من أمان التطبيقات والمتطلبات في هذا الفصل على تطبيقات الويب وواجهات برمجة التطبيقات.

وبما أن OAuth و OIDC يمكن اعتبارهما منطقاً فوق تقنيات الويب، فإن المتطلبات العامة من الفصول الأخرى تنطبق دائماً، ولا يمكن أخذ هذا الفصل خارج سياقه.

ويتناول هذا الفصل الممارسات الفضلى الراهنة ل OAuth2 و OIDC بما يتوافق مع المواصفات الموجودة في <https://oauth.net/2/> و <https://openid.net/developers/specs/>. وحتى إن كانت وثائق RFC تُعدّ ناضجة، فإنها تُحدّث بصورة متكرّرة. ولذلك من المهم التوافق مع أحدث الإصدارات عند تطبيق المتطلبات في هذا الفصل. انظر قسم المراجع لمزيد من التفاصيل.

وبالنظر إلى تعقيد هذا المجال، فن الأهمية الحيوية لأي حل آمن يعتمد OAuth أو OIDC أن يستخدم خوادم تخويل معيارية معروفة في الصناعة وأن يطبّق التكوين الأمني الموصى به.

والمصطلحات المستخدمة في هذا الفصل متوافقة مع وثائق RFC الخاصة ب OAuth ومواصفات OIDC، لكن لاحظ أن مصطلحات OIDC لا تُستخدم إلا في المتطلبات الخاصة بـ OIDC، وفيما عدا ذلك تُستخدم مصطلحات OAuth. وفي سياق OAuth و OIDC، يشير مصطلح "الرمز المميز" في هذا الفصل إلى:

- رموز الوصول، التي لا يجوز أن يستهلكها إلا خادم الموارد، ويمكن أن تكون إما رموزاً مرجعية يُتحقّق منها بالاستبطان أو رموزاً مكتفية بذاتها يُتحقّق منها باستخدام مادة مفاتيح ما.
- رموز التحديث، التي لا يجوز أن يستهلكها إلا خادم التخويل الذي أصدر الرمز.
- رموز الهوية في OIDC، التي لا يجوز أن يستهلكها إلا العميل الذي استهلّ مسار التخويل.

وتعتمد مستويات المخاطر لبعض المتطلبات في هذا الفصل على ما إذا كان العميل عميلاً سرياً أو يُعدّ عميلاً عاماً. وبما أن استخدام مصادقة قوية للعميل يُخفّف من متجهات هجوم كثيرة، فقد تُخفّف بعض المتطلبات عند استخدام عميل سري في تطبيقات المستوى 1.

10.1 V10.1 الأمان العام ل OAuth و OIDC

يتناول هذا القسم المتطلبات المعمارية العامة التي تنطبق على جميع التطبيقات التي تستخدم OAuth أو OIDC.

المستوى	الوصف	#
2	تحقق من أن الرموز المميزة لا تُرسل إلا إلى المكونات التي تحتاج إليها حصراً. فعلى سبيل المثال، عند استخدام نمط الواجهة الخلفية للواجهة الأمامية في تطبيقات JavaScript القائمة على المتصفح، لا يجوز أن تكون رموز الوصول والتحديث متاحة إلا للواجهة الخلفية.	10.1.1

المستوى	الوصف	#
2	تُحقق من أن العميل لا يقبل القيم الواردة من خادم التحويل (مثل رمز التحويل أو رمز الهوية) إلا إذا كانت هذه القيم ناتجة عن مسار تحويل استهلته جلسة وكيل المستخدم والمعاملة نفسها. ويقتضي ذلك أن تكون الأسرار التي يولدها العميل، مثل 'code_verifier' الخاص بمفتاح إثبات تبادل الرمز (PKCE) أو 'state' أو 'nonce' في OIDC، غير قابلة للتخمين وخاصة بالمعاملة ومرتبطة بأمان بكل من العميل وجلسة وكيل المستخدم التي بدأت فيها المعاملة.	10.1.2

V10.2 عميل OAuth

تبيّن هذه المتطلبات مسؤوليات تطبيقات عميل OAuth. وقد يكون العميل، على سبيل المثال، واجهة خلفية لخادم ويب (تعمل غالباً كواجهة خلفية للواجهة الأمامية، BFF أو تكاملاً لخدمة في الواجهة الخلفية، أو تطبيق صفحة واحدة في الواجهة الأمامية، SPA) المعروف كذلك بالتطبيق القائم على المتصفح).

وعموماً، تُعدّ عملاء الواجهة الخلفية عملاء سرّيين وتُعدّ عملاء الواجهة الأمامية عملاء عامين. لكن التطبيقات الأصيلة التي تعمل على جهاز المستخدم النهائي يمكن أن تُعدّ سرّية عند استخدام التسجيل الديناميكي للعملاء في OAuth.

المستوى	الوصف	#
2	تُحقق من أن عميل OAuth، في حال استخدام مسار الرمز، يمتلك حماية من هجمات تزوير الطلبات القائمة على المتصفح، المعروفة عموماً بتزوير الطلبات عبر المواقع (CSRF) التي تُشغّل طلبات الرموز، وذلك إما باستخدام وظيفة مفتاح إثبات تبادل الرمز (PKCE) أو بفحص المعامل 'state' الذي أُرسِل في طلب التحويل.	10.2.1
2	تُحقق من أن عميل OAuth، إذا كان يمكنه التفاعل مع أكثر من خادم تحويل، يمتلك دفاعاً عن هجمات الخلط. فعلى سبيل المثال، قد يشترط أن يعيد خادم التحويل قيمة المعامل 'iss' وأن يتحقق منها في استجابة التحويل واستجابة الرمز.	10.2.2
3	تُحقق من أن عميل OAuth لا يطلب سوى النطاقات المطلوبة (أو معاملات التحويل الأخرى) في الطلبات الموجهة إلى خادم التحويل.	10.2.3

V10.3 خادم موارد OAuth

في سياق معيار التحقق من أمان التطبيقات وهذا الفصل، يكون خادم الموارد واجهة برمجية تطبيقات. ولتوفير وصول آمن، يجب على خادم الموارد أن:

- يتحقق من رمز الوصول، وفق صيغة الرمز ومواصفات البروتوكول المعنية، مثل التحقق من JWT أو استبطان رموز OAuth.
- يُنفذ، إذا كان الرمز صحيحاً، قرارات التحويل بناءً على المعلومات المستقاة من رمز الوصول والصلاحيات التي مُنحت. فعلى سبيل المثال، يلزم خادم الموارد أن يتحقق من أن العميل (العامل بالنيابة عن مالك الموارد) مخوّل بالوصول إلى المورد المطلوب.

ولذلك فإن المتطلبات المدرجة هنا خاصة بـ OAuth أو OIDC وينبغي تنفيذها بعد التحقق من الرمز وقبل تنفيذ التحويل بناءً على المعلومات المستقاة منه.

المستوى	الوصف	#
2	تحقق من أن خادم الموارد لا يقبل سوى رموز الوصول المخصصة للاستخدام مع تلك الخدمة (الجهة المستهدفة). وقد تكون الجهة المستهدفة مُدرجة في رمز وصول مُهيكل (مثل مطالبة 'aud' في JWT أو يمكن فحصها باستخدام نقطة نهاية استبطان الرموز.	10.3.1
2	تحقق من أن خادم الموارد يُنفذ قرارات التحويل بناءً على المطالبات المستقاة من رمز الوصول التي تحدّد التحويل المفوّض. وإذا كانت مطالبات مثل 'sub' و'scope' و'authorization_details' موجودة، فيجب أن تكون جزءًا من القرار.	10.3.2
2	تحقق من أنه، إذا كان قرار التحكم في الوصول يقتضي تحديد مستخدم فريد من رمز وصول (JWT) أو استجابة استبطان الرمز المتصلة به)، فإن خادم الموارد يحدّد المستخدم من مطالبات لا يمكن إعادة تخصيصها لمستخدمين آخرين. ويعني ذلك عادةً استخدام تركيبة من مطالبي 'iss' و'sub'.	10.3.3
2	تحقق من أن خادم الموارد، إذا كان يشترط قوة أو طرائق أو حداثة مصادقة معينة، يتحقق من أن رمز الوصول المُقدّم يستوفي هذه القيود. فعلى سبيل المثال، باستخدام مطالبات OIDC 'acr' و'amr' و'auth_time' على التوالي، إن وُجدت.	10.3.4
3	تحقق من أن خادم الموارد يمنع استخدام رموز الوصول المسروقة أو إعادة إرسال رموز الوصول (من أطراف غير مصرّح لها) باشتراط رموز وصول مقيّدة بالمرسل، إما باستخدام TLS المتبادل لـ OAuth 2 أو إثبات الحياة (DPoP) في OAuth 2.	10.3.5

OAuth V10.4 خادم تحويل

تبين هذه المتطلبات مسؤوليات خوادم تحويل OAuth، بما فيها مزودو OpenID. وبالنسبة إلى مصادقة العميل، يُسمح بطريقة 'sefl_signed_tls_client_auth' بالشروط المسبقة التي يقتضيها القسم 2.2 من RFC 8705.

المستوى	الوصف	#
1	تحقق من أن خادم التحويل يتحقق من معرفات إعادة التوجيه بناءً على قائمة سماح خاصة بالعميل تتضمن معرفات مسجلة مسبقاً، باستخدام مقارنة نصية دقيقة.	10.4.1
1	تحقق من أنه، إذا أعاد خادم التحويل رمز التحويل في استجابة التحويل، فلا يمكن استخدامه إلا مرة واحدة لطلب رمز. وعند ورود طلب صحيح ثانٍ يرمز تحويل استخدم بالفعل لإصدار رمز وصول، يجب على خادم التحويل رفض طلب الرمز وإبطال أي رموز صادرة متصلة برمز التحويل.	10.4.2
1	تحقق من أن رمز التحويل قصير الأجل. ويمكن أن يبلغ العمر الأقصى 10 دقائق لتطبيقات المستويين 1 و2 ودقيقة واحدة لتطبيقات المستوى 3.	10.4.3

المستوى	الوصف	#
1	تحقق من أن خادم التحويل، لعميل معيّن، لا يسمح إلا باستخدام المنح التي يحتاج هذا العميل إلى استخدامها. ولاحظ أن المنحيتين 'token' (المسار الضمني) و'password' (مسار بيانات اعتماد كلمة مرور مالك الموارد) يجب ألا تُستخدم بعد الآن.	10.4.4
1	تحقق من أن خادم التحويل يخفّف من هجمات إعادة إرسال رموز التحديث للعملاء العامين، ويفضّل باستخدام رموز تحديث مقيّدة بالمرسل، أي إثبات الحياة (DPoP) أو رموز وصول مرتبطة بالشهادات باستخدام TLS المتبادل (mTLS). وبالنسبة إلى تطبيقات المستويين 1 و2، يمكن استخدام تدوير رموز التحديث. وإذا استُخدم تدوير رموز التحديث، فيجب على خادم التحويل إبطال رمز التحديث بعد استخدامه، وإبطال جميع رموز التحديث لذلك التحويل إذا قدّم رمز تحديث مستخدم ومُبطّل بالفعل.	10.4.5
2	تحقق من أن خادم التحويل، في حال استخدام منحة الرمز، يخفّف من هجمات اعتراض رمز التحويل باشتراك مفتاح إثبات تبادل الرمز (PKCE). وبالنسبة إلى طلبات التحويل، يجب على خادم التحويل اشتراط قيمة 'code_challenge' صحيحة ويجب ألا يقبل قيمة 'plain' للمعامل 'code_challenge_method'. وبالنسبة إلى طلب الرمز، يجب أن يشترط التحقق من المعامل 'code_verifier'.	10.4.6
2	تحقق من أن خادم التحويل، إذا كان يدعم التسجيل الديناميكي غير المصادق عليه للعملاء، يخفّف من خطر تطبيقات العملاء الخبيثة. ويجب أن يتحقق من بيانات العميل الوصفية مثل أي معرفات مسجّلة، وأن يضمن موافقة المستخدم، وأن يحذّر المستخدم قبل معالجة طلب تحويل بتطبيق عميل غير موثوق.	10.4.7
2	تحقق من أن لرموز التحديث انتهاء صلاحية مطلقاً، بما في ذلك في حال تطبيق انتهاء صلاحية متزحلّق لرموز التحديث.	10.4.8
2	تحقق من أن رموز التحديث ورموز الوصول المرجعية يمكن إبطالها بواسطة مستخدم مخوّل عبر واجهة مستخدم خادم التحويل، وذلك للتخفيف من خطر العملاء الخبيثة أو الرموز المسروقة.	10.4.9
2	تحقق من أن العميل السريّ مُصادق عليه في طلبات القناة الخلفية من العميل إلى الخادم المخوّل، مثل طلبات الرموز وطلبات التحويل المدفوعة (PAR) وطلبات إبطال الرموز.	10.4.10
2	تحقق من أن تكوين خادم التحويل لا يخصّص لعميل OAuth إلا النطاقات المطلوبة.	10.4.11
3	تحقق من أن خادم التحويل، لعميل معيّن، لا يسمح إلا بقيمة 'response_mode' التي يحتاج هذا العميل إلى استخدامها. وذلك مثلاً بأن يتحقق خادم التحويل من هذه القيمة مقابل القيم المتوقعة أو باستخدام طلب التحويل المدفوع (PAR) أو طلب التحويل المؤمّن بـ JWT. (JAR)	10.4.12
3	تحقق من أن نوع المنحة 'code' يُستخدم دائماً مع طلبات التحويل المدفوعة (PAR).	10.4.13
3	تحقق من أن خادم التحويل لا يُصدر إلا رموز وصول مقيّدة بالمرسل (إثبات الحياة)، إما رموز وصول مرتبطة بالشهادات باستخدام TLS المتبادل (mTLS) أو رموز وصول مرتبطة بـ DPoP (إثبات الحياة).	10.4.14
3	تحقق من أن خادم التحويل، بالنسبة إلى عميل من جانب الخادم (لا يُنفذ على جهاز المستخدم النهائي)، يضمن أن قيمة المعامل 'authorization_details' واردة من واجهة العميل الخلفية وأن المستخدم لم يتلاعب بها. وذلك مثلاً باشتراك استخدام طلب التحويل المدفوع (PAR) أو طلب التحويل المؤمّن بـ JWT. (JAR)	10.4.15

المستوى	الوصف	#
3	تحقق من أن العميل سرّي وأن خادم التحويل يشترط استخدام طرائق مصادقة قوية للعميل (مبنية على تشفير المفتاح العام ومقاومة لهجمات إعادة الإرسال)، مثل TLS المتبادل ('tls_client_auth') و ('sefl_signed_tls_client_auth') أو JWT بالمفتاح الخاص ('private_key_jwt').	10.4.16

OIDC عميل V10.5

بما أن الطرف المعوّل في OIDC يعمل كعميل، OAuth، فإن المتطلبات الواردة في قسم "عميل OAuth" تنطبق كذلك. ولاحظ أن قسم "المصادقة عبر مزود هوية" في فصل "المصادقة" يحتوي كذلك على متطلبات عامة ذات صلة.

المستوى	الوصف	#
2	تحقق من أن العميل (بوصفه الطرف المعوّل) يخفّف من هجمات إعادة إرسال رمز الهوية. وذلك مثلاً بالتأكد من أن مطالبة 'nonce' في رمز الهوية تطابق قيمة 'nonce' المرسلّة في طلب المصادقة إلى مزود OpenID (المشار إليه في OAuth2 بطلب التحويل المرسل إلى خادم التحويل).	10.5.1
2	تحقق من أن العميل يحدّد المستخدم على نحو فريد من مطالبات رمز الهوية، وعادةً مطالبة 'sub' التي لا يمكن إعادة تخصيصها لمستخدمين آخرين (في نطاق مزود هوية واحد).	10.5.2
2	تحقق من أن العميل يرفض محاولات خادم تحويل خبيث لانتحال هوية خادم تحويل آخر عبر البيانات الوصفية لخادم التحويل. ويجب على العميل رفض البيانات الوصفية لخادم التحويل إذا لم يطابق عنوان URL الخاص بالجهة المصدرة في تلك البيانات، مطابقةً دقيقةً، عنوان URL المهيأ مسبقاً والمتوقع من قبل العميل.	10.5.3
2	تحقق من أن العميل يتحقق من أن رمز الهوية مخصّص للاستخدام من قبل ذلك العميل (الجهة المستهدفة)، وذلك بفحص أن مطالبة 'aud' في الرمز مساوية لقيمة 'client_id' الخاصة بالعميل.	10.5.4
2	تحقق من أن الطرف المعوّل، عند استخدام تسجيل الخروج عبر القناة الخلفية في OIDC، يخفّف من حجب الخدمة عن طريق تسجيل الخروج القسري ومن الالتباس بين رموز JWT في مسار تسجيل الخروج. ويجب على العميل التحقق من أن رمز تسجيل الخروج مُصنّف على نحو صحيح بالقيمة 'logout+jwt'، وأنه يحتوي على مطالبة 'event' باسم العضو الصحيح، وأنه لا يحتوي على مطالبة 'nonce'. ولاحظ أنه يُوصى كذلك بأن يكون له انتهاء صلاحية قصير (مثلاً دقيقتان).	10.5.5

OpenID مزود V10.6

بما أن مزود OpenID يعملون كخوادم تحويل، OAuth، فإن المتطلبات الواردة في قسم "خادم تحويل OAuth" تنطبق كذلك. ولاحظ أنه في حال استخدام مسار رمز الهوية (وليس مسار الرمز)، لا تُصدر رموز وصول، وكثير من متطلبات خادم تحويل OAuth تكون غير منطبقة.

المستوى	الوصف	#
2	تحقق من أن مزود OpenID لا يسمح إلا بالقيم 'code' أو 'ciba' أو 'id_token' أو 'id_token' على 'code' (المسار المهيّج في ،(OIDC وأن لنط الاستجابة. ولاحظ أن 'code' مفضّلة على 'id_token' (أي مسار ضمني) يجب ألا تُستخدم.	10.6.1
2	تحقق من أن مزود OpenID يخفّف من حجب الخدمة عن طريق تسجيل الخروج القسري. وذلك بالحصول على تأكيد صريح من المستخدم النهائي أو، إن وُجدت، بالتحقق من المعاملات في طلب تسجيل الخروج (الذي يستهله الطرف المعوّل)، مثل 'id_token_hint'.	10.6.2

V10.7 إدارة الموافقة

تتناول هذه المتطلبات التحقق من موافقة المستخدم بواسطة خادم التحويل. فمن دون تحقق سليم من موافقة المستخدم، قد يحصل فاعل خبيث على صلاحيات بالنيابة عن المستخدم عن طريق الانتحال أو الهندسة الاجتماعية.

المستوى	الوصف	#
2	تحقق من أن خادم التحويل يضمن موافقة المستخدم على كل طلب تحويل. وإذا لم يكن من الممكن ضمان هوية العميل، فيجب على خادم التحويل أن يطلب موافقة المستخدم صراحةً دائماً.	10.7.1
2	تحقق من أن خادم التحويل، عند طلبه موافقة المستخدم، يعرض معلومات كافية وواضحة عمّا تجري الموافقة عليه. وينبغي أن يشمل ذلك، حيث ينطبق، طبيعة التحويلات المطلوبة (عادةً بناءً على النطاق وخادم الموارد وتفاصيل التحويل في طلبات التحويل الغنية)، (RAR) وهوية التطبيق المخوّل، وعمر هذه التحويلات.	10.7.2
2	تحقق من أن المستخدم يمكنه مراجعة الموافقات التي منحها عبر خادم التحويل وتعديلها وإبطالها.	10.7.3

المراجع

لمزيد من المعلومات عن OAuth، يُرجى الاطلاع على:

• oauth.net

• [Sheet Cheat Protocol 2.0 OAuth OWASP](#)

وبالنسبة إلى المتطلبات المتعلقة بـ OAuth في معيار التحقق من أمان التطبيقات، تُستخدم وثائق RFC المنشورة والتي في حالة مسودة التالية:

• [Framework Authorization 2.0 OAuth The RFC6749](#)

• [Usage Token Bearer Framework: Authorization 2.0 OAuth The RFC6750](#)

• [Considerations Security and Model Threat 2.0 OAuth RFC6819](#)

• [Clients Public OAuth by Exchange Code for Key Proof RFC7636](#)

• [Protocol Registration Client Dynamic 2.0 OAuth RFC7591](#)

• [Grant Authorization Device 2.0 OAuth RFC8628](#)

• [2.0 OAuth for Indicators Resource RFC8707](#)

- Tokens Access 2.0 OAuth for Profile (JWT) Token Web JSON RFC9068
- Requests Authorization Pushed 2.0 OAuth RFC9126
- Identification Issuer Server Authorization 2.0 OAuth RFC9207
- Requests Authorization Rich 2.0 OAuth RFC9396
- (DPoP) Possession of Proof Demonstrating 2.0 OAuth RFC9449
- Security 2.0 OAuth for Practice Current Best RFC9700
- Applications Browser-Based for 2.0 OAuth draft
- Framework Authorization 2.1 OAuth The draft

ولمزيد من المعلومات عن Connect، OpenID يُرجى الاطلاع على:

- 1.0 Core Connect OpenID
- Profile Security 2.0 FAPI

V11 التشفير

الهدف من ضوابط الأمان

الهدف من هذا الفصل تحديد الممارسات الفضلى للاستخدام العام للتشفير، وكذلك إرساء فهم أساسي لمبادئ التشفير والتحفيز على التحوّل إلى مناهج أكثر صموداً وحدائقة. وهو يشجّع على ما يلي:

- تنفيذ أنظمة تشفير متينة تفشل بأمان وتتكيف مع التهديدات المتطورة وتصمد للمستقبل.
 - الاستفادة من آليات تشفير آمنة ومتوافقة مع الممارسات الفضلى في الصناعة.
 - الحفاظ على نظام آمن لإدارة مفاتيح التشفير مع ضوابط وصول وتدقيق ملائمة.
 - التقييم المنتظم لمشهد التشفير لتقدير المخاطر الجديدة وتكييف الخوارزميات وفقاً لذلك.
 - استكشاف حالات استخدام التشفير وإدارتها على امتداد دورة حياة التطبيق للتأكد من أن جميع الأصول التشفيرية محسوبة ومؤمنة.
- وإضافةً إلى بيان المبادئ العامة والممارسات الفضلى، يوفر هذا المستند كذلك معلومات تقنية أكثر تعمقاً عن المتطلبات في الملحق ج - معايير التشفير. ويشمل ذلك الخوارزميات والأنماط التي تُعدّ "معتمدة" لأغراض المتطلبات الواردة في هذا الفصل.
- أما المتطلبات التي تستخدم التشفير لحل مشكلة منفصلة، مثل إدارة الأسرار أو أمان الاتصالات، فستكون في أجزاء أخرى من المعيار.

V11.1 جرد التشفير وتوثيقه

يلزم تصميم التطبيقات بمعمارية تشفير قوية لحماية أصول البيانات وفق تصنيفها. فتشفير كل شيء مضيعة، وعدم تشفير أي شيء إهمال من الناحية القانونية. ويجب إيجاد توازن، عادةً أثناء التصميم المعماري أو الرفيع المستوى أو دورات التصميم أو الاستقصاءات المعمارية. وتصميم التشفير "على عجل" أو إضافته لاحقاً سيكلّف حتماً أكثر بكثير لتنفيذه بأمان من مجرد بنائه من البداية.

ومن المهم التأكد من استكشاف جميع الأصول التشفيرية وجردها وتقييمها بانتظام. يُرجى الاطلاع على الملحق لمزيد من المعلومات عن كيفية تحقيق ذلك.

والحاجة إلى تحصين أنظمة التشفير للمستقبل ضد الصعود المرتقب للحوسبة الكمومية بالغة الأهمية كذلك. ويشير التشفير ما بعد الكمومي (PQC) إلى خوارزميات تشفير مصممة لتبقى آمنة أمام هجمات الحواسيب الكمومية، التي يُتوقع أن تكسر خوارزميات واسعة الاستخدام مثل RSA وتشفير المنحنيات الإهليلجية (ECC).

يُرجى الاطلاع على الملحق للإرشادات الراهنة عن أوليات ومعايير PQC المدروسة.

المستوى	الوصف	#
2	تحقق من وجود سياسة موثقة لإدارة مفاتيح التشفير ودورة حياة لمفاتيح التشفير تُتبع معياراً لإدارة المفاتيح مثل SP NIST 800-57. وينبغي أن يشمل ذلك التأكد من عدم الإفراط في مشاركة المفاتيح (مثلاً مع أكثر من كيانين للأسرار المشتركة وأكثر من كيان واحد للمفاتيح الخاصة).	11.1.1
2	تحقق من أن جرد التشفير يُنفَّذ ويُصان ويُحدَّث بانتظام ويشمل جميع مفاتيح التشفير والخوارزميات والشهادات التي يستخدمها التطبيق. ويجب أن يوثق كذلك المواضع التي يمكن وتلك التي لا يمكن استخدام المفاتيح فيها في النظام، وأنواع البيانات التي يمكن وتلك التي لا يمكن حمايتها باستخدام هذه المفاتيح.	11.1.2
3	تحقق من استخدام آليات استكشاف التشفير لتحديد جميع مواضع التشفير في النظام، بما فيها عمليات التشفير والتلييد والتوقيع.	11.1.3
3	تحقق من الاحتفاظ بمجرد للتشفير. ويجب أن يشمل ذلك خطة موثقة تبيّن مسار الانتقال إلى معايير تشفير جديدة، مثل التشفير ما بعد الكمومي، وذلك للتفاعل مع التهديدات المستقبلية.	11.1.4

V11.2 التنفيذ الآمن للتشفير

يحدّد هذا القسم متطلبات اختيار خوارزميات التشفير الأساسية للتطبيق وتنفيذها وإدارتها المستمرة. والهدف التأكد من عدم نشر إلا أوليات تشفيرية متينة ومقبولة في الصناعة، بما يتوافق مع المعايير الراهنة (مثل NIST وISO/IEC) والممارسات الفضلى. ويجب على المؤسسات التأكد من اختيار كل مكون تشفيري بناءً على أدلة خضعت لمراجعة الأنداد واختبار أمني عملي.

المستوى	الوصف	#
2	تحقق من استخدام تنفيذات مُصادق عليها في الصناعة (بما فيها المكتبات والتنفيذات المعززة بالعتاد) للعمليات التشفيرية.	11.2.1
2	تحقق من أن التطبيق مصمّم بمرونة تشفيرية بحيث يمكن إعادة تهيئة أو ترقية أو استبدال خوارزميات الأعداد العشوائية أو التشفير المصادق عليه أو MAC أو التلييد، وأطوال المفاتيح والدورات ومجموعات التشفير والأنماط، في أي وقت، وذلك للحماية من الانكسارات التشفيرية. وبالمثل، يجب أن يكون من الممكن استبدال المفاتيح وكلمات المرور وإعادة تشفير البيانات. وهذا سيتيح ترقية سلسلة إلى التشفير ما بعد الكمومي (PQC) بمجرد توافر تنفيذات عالية التوكيد لمخططات أو معايير PQC المعتمدة على نطاق واسع.	11.2.2
2	تحقق من أن جميع الأوليات التشفيرية تستخدم 128 بتاً على الأقل من الأمان بناءً على الخوارزمية وحجم المفتاح والتكوين. على سبيل المثال، يوفر مفتاح ECC بطول 256 بتاً نحو 128 بتاً من الأمان، في حين يتطلب RSA مفتاحاً بطول 3072 بتاً لتحقيق 128 بتاً من الأمان.	11.2.3

المستوى	الوصف	#
3	تحقق من أن جميع العمليات التشفيرية ثابتة الزمن، دون عمليات "قصر الدائرة" في المقارنات أو الحسابات أو القيم المُعادَة، وذلك لتجنّب تسريب المعلومات.	11.2.4
3	تحقق من أن جميع وحدات التشفير تفشل بأمان، ومن أن الأخطاء تُعالج بطريقة لا تُمكن الثغرات، مثل هجمات كاهن الحشو.	11.2.5

V11.3 خوارزميات التشفير

تشكّل خوارزميات التشفير المصادق عليها المبنية على AES وCHACHA20 العمود الفقري للممارسة التشفيرية الحديثة.

المستوى	الوصف	#
1	تحقق من عدم استخدام أنماط الكتل غير الآمنة (مثل ECB ومخططات الحشو الضعيفة (مثل PKCS#1 v1.5)).	11.3.1
1	تحقق من عدم استخدام إلا مجموعات التشفير والأنماط المعتمدة مثل AES مع GCM.	11.3.2
2	تحقق من أن البيانات المشفرة محمية من التعديل غير المصرّح به، ويُفضّل باستخدام طريقة تشفير مصادق عليها معتمدة أو بالجمع بين طريقة تشفير معتمدة وخوارزمية MAC معتمدة.	11.3.3
3	تحقق من أن القيم العشوائية لمرة واحدة ومتجهات التهيئة وغيرها من الأعداد ذات الاستخدام الواحد لا تُستخدم لأكثر من زوج واحد من مفتاح التشفير وعنصر البيانات. ويجب أن تكون طريقة التوليد ملائمة للخوارزمية المستخدمة.	11.3.4
3	تحقق من أن أي تركيبة من خوارزمية تشفير وخوارزمية MAC تعمل بنمط التشفير ثم MAC.	11.3.5

V11.4 التلييد والدوالّ المبنية على التلييد

تُستخدم التلييدات التشفيرية في مجموعة واسعة من بروتوكولات التشفير، مثل التوقيعات الرقمية وHMAC ودوالّ اشتقاق المفاتيح (KDF) وتوليد البتات العشوائية وتخزين كلمات المرور. وأمان النظام التشفيري لا يفوق قوة دوالّ التلييد الأساسية المستخدمة. ويبيّن هذا القسم متطلبات استخدام دوالّ تلييد آمنة في العمليات التشفيرية.

وبالنسبة إلى تخزين كلمات المرور، وكذلك ملحق التشفير، ستوفّر OWASP Sheet Cheat Storage Password مبيدات مفيدة كذلك.

المستوى	الوصف	#
1	تحقق من عدم استخدام إلا دوالّ التلييد المعتمدة لحالات الاستخدام التشفيري العامة، بما فيها التوقيعات الرقمية وHMAC وKDF وتوليد البتات العشوائية. ويجب ألا تُستخدم دوالّ التلييد الممنوعة، مثل MD5، لأي غرض تشفيري.	11.4.1

المستوى	الوصف	#
2	تحقق من أن كلمات المرور تُخزّن باستخدام دالة اشتقاق مفاتيح معتمدة ومكثّفة حسابياً (تُعرف كذلك بـ"دالة تليد كلمات المرور")، مع ضبط المعاملات بناءً على الإرشادات الراهنة. وينبغي أن توازن الإعدادات بين الأمان والأداء لجعل هجمات القوة الغاشمة صعبة بما يكفي لمستوى الأمان المطلوب.	11.4.2
2	تحقق من أن دوالّ التليد المستخدمة في التوقيعات الرقمية، كجزء من مصادقة البيانات أو سلامتها، مقاومة للتصادم وذات أطوال بنات ملائمة. وإذا كانت مقاومة التصادم مطلوبة، فيجب أن يكون طول المخرَج 256 بتاً على الأقل. وإذا كانت المقاومة لهجمات الصورة الأولية الثانية فقط مطلوبة، فيجب أن يكون طول المخرَج 128 بتاً على الأقل.	11.4.3
2	تحقق من أن التطبيق يستخدم دوالّ اشتقاق مفاتيح معتمدة مع معاملات لتمديد المفاتيح عند اشتقاق مفاتيح سرّية من كلمات المرور. ويجب أن توازن المعاملات المستخدمة بين الأمان والأداء لمنع هجمات القوة الغاشمة من اختراق المفتاح التشفيري الناتج.	11.4.4

V11.5 القيم العشوائية

إن توليد الأعداد شبه العشوائية الآمن تشفيرياً (CSPRNG) بالغ الصعوبة في إتقانه. وعموماً، ستُستفد مصادر العشوائية الجيدة في نظام ما سريعاً إذا أُفُرد في استخدامها، لكن المصادر الأقل عشوائية قد تؤدي إلى مفاتيح وأسرار قابلة للتوقع.

المستوى	الوصف	#
2	تحقق من أن جميع الأعداد والسلاسل العشوائية المقصود أن تكون غير قابلة للتخمين يجب أن تولّد باستخدام مولّد أعداد شبه عشوائية آمنة تشفيرياً (CSPRNG) وأن تمتلك 128 بتاً على الأقل من العشوائية. ولاحظ أن المعرفات الفريدة عالمياً (UUIDs) لا تتحقّق هذا الشرط.	11.5.1
3	تحقق من أن آلية توليد الأعداد العشوائية المستخدمة مصمّمة للعمل بأمان، حتى تحت الطلب الكثيف.	11.5.2

V11.6 تشفير المفتاح العام

سيُستخدم تشفير المفتاح العام حيث لا يكون من الممكن أو من المرغوب مشاركة مفتاح سرّي بين أطراف متعددة. وكجزء من ذلك، توجد حاجة إلى آليات معتمدة لتبادل المفاتيح، مثل ديفي-هيلمان وديفي-هيلمان بالمنحنيات الإهليلجية، (ECDH) لضمان بقاء النظام التشفيري آمناً أمام التهديدات الحديثة. ويوفّر فصل "الاتصال الآمن" متطلبات TLS، ولذلك فإن المتطلبات في هذا القسم موجهة إلى الحالات التي يُستخدم فيها تشفير المفتاح العام في حالات استخدام غير TLS.

المستوى	الوصف	#
2	تحقق من عدم استخدام إلا خوارزميات التشفير وأنماط التشغيل المعتمدة لتوليد المفاتيح وبذرها، وتوليد التوقعات الرقمية والتحقق منها. ويجب ألا تولّد خوارزميات توليد المفاتيح مفاتيح غير آمنة معرضة لهجمات معروفة، مثل مفاتيح RSA المعرضة لتحليل فيرما إلى عوامل.	11.6.1
3	تحقق من استخدام خوارزميات تشفير معتمدة لتبادل المفاتيح (مثل ديفي-هيلمان) مع التركيز على التأكد من أن آليات تبادل المفاتيح تستخدم معاملات آمنة. وهذا سيمنع الهجمات على عملية إرساء المفاتيح التي قد تؤدي إلى هجمات الخضم في المنتصف أو إلى انكسارات تشفيرية.	11.6.2

V11.7 تشفير البيانات قيد الاستخدام

إن حماية البيانات أثناء معالجتها أمر بالغ الأهمية. ويوصى بتقنيات مثل التشفير الكامل للذاكرة وتشفير البيانات أثناء النقل والتأكد من تشفير البيانات في أسرع وقت ممكن بعد الاستخدام.

المستوى	الوصف	#
3	تحقق من استخدام التشفير الكامل للذاكرة الذي يحمي البيانات الحساسة أثناء استخدامها، بما يمنع وصول المستخدمين أو العمليات غير المصرح لهم.	11.7.1
3	تحقق من أن تدنية البيانات تضمن كشف أقل قدر من البيانات أثناء المعالجة، وتأكد من تشفير البيانات فور استخدامها أو في أقرب وقت ممكن.	11.7.2

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Cryptography Weak for Testing Guide: Testing Security Web OWASP •
- Sheet Cheat Storage Cryptographic OWASP •
- 140-3 FIPS •
- 800-57 SP NIST •

V12 الاتصال الآمن

الهدف من ضوابط الأمان

يشتمل هذا الفصل على متطلبات متعلقة بالآليات المحددة التي ينبغي أن تتوافر لحماية البيانات أثناء النقل، سواء بين عميل المستخدم النهائي وخدمة في الواجهة الخلفية، أو بين الخدمات الداخلية وخدمات الواجهة الخلفية.

وتشمل المفاهيم العامة التي يعزّزها هذا الفصل ما يلي:

- التأكد من أن الاتصالات مشفرة خارجياً، ومن الأفضل داخلياً أيضاً.
- تكوين آليات التشفير باستخدام أحدث الإرشادات، بما في ذلك الخوارزميات ومجموعات التشفير المفضلة.
- التأكد من أن الاتصالات لا تُعترض من قبل أطراف غير مصرّح لها، وذلك باستخدام شهادات موقعة.

وإضافةً إلى بيان المبادئ العامة والممارسات الفضلى، يوفرّ معيار التحقق من أمان التطبيقات كذلك معلومات تقنية أكثر تعمّقاً عن القوة التشفيرية في الملحق ج - معايير التشفير.

V12.1 إرشادات عامة لأمان TLS

يوفرّ هذا القسم إرشادات أولية عن كيفية تأمين اتصالات TLS. وينبغي استخدام أدوات محدّثة لمراجعة تكوين TLS على نحو مستمر. ومع أن استخدام شهادات TLS بأحرف البدل ليس غير آمن في جوهره، فإن اختراق شهادة منشورة في جميع البيئات المملوكة (مثل الإنتاج والتهيئة والتطوير والاختبار) قد يؤدي إلى اختراق الوضع الأمني للتطبيقات التي تستخدمها. وينبغي، إن أمكن، توفير حماية وإدارة سليمتين واستخدام شهادات TLS منفصلة في البيئات المختلفة.

المستوى	الوصف	#
1	تحقق من أن الإصدارات الأحدث الموصى بها من بروتوكول TLS هي وحدها المُمكنة، مثل TLS 1.2 و TLS 1.3. ويجب أن يكون أحدث إصدار من بروتوكول TLS هو الخيار المفضّل.	12.1.1
2	تحقق من أن مجموعات التشفير الموصى بها هي وحدها المُمكنة، مع تعيين أقوى مجموعات التشفير كفضيلة. ويجب ألا تدعم تطبيقات المستوى 3 سوى مجموعات التشفير التي توفرّ السرية التامة للتوجيه.	12.1.2
2	تحقق من أن التطبيق يتحقق من أن شهادات عميل mTLS موثوقة قبل استخدام هوية الشهادة للمصادقة أو التحويل.	12.1.3
3	تحقق من أن إبطال الشهادات على النحو السليم، مثل تديس بروتوكول حالة الشهادة عبر الإنترنت (OCSP)، (Stapling) مُمكن ومُهيأ.	12.1.4
3	تحقق من أن ميزة Hello Client Encrypted (ECH) مُمكنة في إعدادات TLS للتطبيق لمنع كشف البيانات الوصفية الحساسة، مثل إشارة اسم الخادم، (SNI) أثناء عمليات مصافحة TLS.	12.1.5

V12.2 اتصالات HTTPS مع الخدمات الموجهة إلى الخارج

تأكّد من أن جميع حزم HTTP المتجهة إلى الخدمات الموجهة إلى الخارج التي يعرضها التطبيق تُرسل مشفرة، بشهادات موثوقة عموماً.

المستوى	الوصف	#
1	تحقق من استخدام TLS في جميع الاتصالات بين العميل والخدمات الموجهة إلى الخارج القائمة على HTTP، ومن أنه لا يرتد إلى اتصالات غير آمنة أو غير مشفرة.	12.2.1
1	تحقق من أن الخدمات الموجهة إلى الخارج تستخدم شهادات TLS موثوقة عموماً.	12.2.2

V12.3 الأمان العام للاتصال بين الخدمات

تتضمّن اتصالات الخادم (الداخلية والخارجية على حد سواء) أكثر من مجرد HTTP. ويجب أن تكون الاتصالات من الأنظمة الأخرى وإليها آمنة كذلك، ومن الأفضل باستخدام TLS.

المستوى	الوصف	#
2	تحقق من استخدام بروتوكول مشفّر مثل TLS في جميع الاتصالات الواردة والصادرة من التطبيق وإليه، بما في ذلك أنظمة المراقبة وأدوات الإدارة والوصول عن بُعد وSSH والبرمجيات الوسيطة وقواعد البيانات والحواسيب المركزية وأنظمة الشركاء أو واجهات برمجة التطبيقات الخارجية. ويجب ألا يترد الخادم إلى بروتوكولات غير آمنة أو غير مشفّرة.	12.3.1
2	تحقق من أن عملاء TLS يتحققون من الشهادات المستلمة قبل التواصل مع خادم TLS.	12.3.2
2	تحقق من استخدام TLS أو آلية تشفير نقل مناسبة أخرى في جميع الاتصالات بين الخدمات الداخلية القائمة على HTTP داخل التطبيق، ومن أنه لا يترد إلى اتصالات غير آمنة أو غير مشفّرة.	12.3.3
2	تحقق من أن اتصالات TLS بين الخدمات الداخلية تستخدم شهادات موثوقة. وحيث تُستخدم شهادات مُولّدة داخلياً أو موقعة ذاتياً، يجب تهيئة الخدمة المستهلكة لتثق فقط بإصدار شهادات داخلية محدّدة وبشهادات موقعة ذاتياً محدّدة.	12.3.4
3	تحقق من أن الخدمات التي تتواصل داخلياً في نظام ما (الاتصالات بين الخدمات) تستخدم مصادقة قوية للتأكد من التحقق من كل نقطة نهاية. ويجب استخدام طرائق مصادقة قوية، مثل مصادقة العميل في TLS، لضمان الهوية، باستخدام البنية التحتية للمفتاح العام وآليات مقاومة لهجمات إعادة الإرسال، وبالنسبة إلى معماريات الخدمات المصغرة، ينبغي النظر في استخدام شبكة خدمات لتبسيط إدارة الشهادات وتعزيز الأمان.	12.3.5

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Sheet Cheat Security Layer Transport - OWASP
- guide configuration TLS Side Server Mozilla's
- configurations TLS good known generate to tool Mozilla's
- configuration TLS validate to Project OWASP - O-Saft

V13 التكوين

الهدف من ضوابط الأمان

يجب أن يكون التكوين الافتراضي للتطبيق آمناً للاستخدام على الإنترنت.

ويوفّر هذا الفصل إرشادات عن التكوينات المتنوعة اللازمة لتحقيق ذلك، بما فيها التكوينات المطبّقة أثناء التطوير والبناء والنشر.

وتشمل المواضيع المتناولة منع تسريب البيانات، وإدارة الاتصال بين المكونات بأمان، وحماية الأسرار.

V13.1 توثيق التكوين

يبيّن هذا القسم متطلبات التوثيق الخاصة بكيفية اتصال التطبيق بالخدمات الداخلية والخارجية، وكذلك التقنيات اللازمة لمنع فقدان التوافر بسبب تعذّر الوصول إلى الخدمات. ويتناول كذلك التوثيق المتعلق بالأسرار.

المستوى	الوصف	#
2	تحقق من أن جميع احتياجات الاتصال الخاصة بالتطبيق موثّقة. ويجب أن يشمل ذلك الخدمات الخارجية التي يعتمد عليها التطبيق والحالات التي قد يتمكّن فيها المستخدم النهائي من تقديم موقع خارجي يتصل به التطبيق بعد ذلك.	13.1.1
3	تحقق من أن الوثائق تحدّد، لكل خدمة يستخدمها التطبيق، العدد الأقصى للاتصالات المتزامنة (مثل حدود مجمع الاتصالات) وكيفية تصرّف التطبيق عند بلوغ ذلك الحد، بما في ذلك أي آليات احتياطية أو للاستعادة، وذلك لمنع حالات حجب الخدمة.	13.1.2
3	تحقق من أن وثائق التطبيق تحدّد استراتيجيات إدارة الموارد لكل نظام أو خدمة خارجية يستخدمها (مثل قواعد البيانات ومقايض الملفات والخيوط واتصالات HTTP). وينبغي أن يشمل ذلك إجراءات تحرير الموارد وإعدادات المهل ومعالجة الأعطال، وحيث يُنفذ منطق إعادة المحاولة، تحديد حدود إعادة المحاولة والتأخيرات وخوارزميات التراجع. وبالنسبة إلى عمليات طلب واستجابة HTTP المتزامنة، ينبغي أن تُلزم بمهل قصيرة وأن تعطل إعادة المحاولة أو تقيدها بصرامة لمنع التأخيرات المتتالية واستنفاد الموارد.	13.1.3
3	تحقق من أن وثائق التطبيق تحدّد الأسرار الحرجة لأمان التطبيق وجدولاً لتدويرها، بناءً على نموذج التهديد الخاص بالمؤسسة ومتطلبات العمل.	13.1.4

V13.2 تكوين اتصالات الواجهة الخلفية

تتفاعل التطبيقات مع خدمات متعددة، منها واجهات برمجة التطبيقات وقواعد البيانات أو مكونات أخرى. وقد تُعدّ هذه داخلية بالنسبة إلى التطبيق لكنها غير مشمولة في آليات التحكم في الوصول القياسية للتطبيق، أو قد تكون خارجية تماماً. وفي كلتا الحالتين، من الضروري تهيئة التطبيق للتفاعل مع هذه المكونات بأمان، وحماية ذلك التكوين إذا لزم الأمر.

ملاحظة: يوفر فصل "الاتصال الآمن" إرشادات عن التشفير أثناء النقل.

المستوى	الوصف	#
2	تحقق من أن الاتصالات بين مكونات التطبيق في الواجهة الخلفية التي لا تدعم آلية جلسة المستخدم القياسية للتطبيق، بما فيها واجهات برمجة التطبيقات والبرمجيات الوسيطة وطبقات البيانات، مُصادق عليها. ويجب أن تستخدم المصادقة حسابات فردية أو رموزاً قصيرة الأجل أو مصادقة قائمة على الشهادات، وليس بيانات اعتماد ثابتة مثل كلمات المرور أو مفاتيح واجهات برمجة التطبيقات أو الحسابات المشتركة ذات الوصول المتميز.	13.2.1

المستوى	الوصف	#
2	تحقق من أن الاتصالات بين مكونات التطبيق في الواجهة الخلفية، بما فيها الخدمات المحلية أو خدمات نظام التشغيل وواجهات برمجة التطبيقات والبرمجيات الوسيطة وطبقات البيانات، تُنفَّذ بحسابات مُنحت أقلّ الصلاحيات اللازمة.	13.2.2
2	تحقق من أنه، إذا كان لا بد من استخدام بيانات اعتماد لمصادقة الخدمة، فإن بيانات الاعتماد التي يستخدمها المستهلك ليست بيانات اعتماد افتراضية (مثل root/root أو admin/admin).	13.2.3
2	تحقق من استخدام قائمة سماح لتحديد الموارد أو الأنظمة الخارجية التي يُسمح للتطبيق بالاتصال بها (مثلاً للطلبات الصادرة أو تحميل البيانات أو الوصول إلى الملفات). ويمكن تنفيذ قائمة السماح هذه في طبقة التطبيق أو خادم الويب أو الجدار الناري أو في مجموعة من الطبقات المختلفة.	13.2.4
2	تحقق من أن خادم الويب أو التطبيق مُهيأ بقائمة سماح بالموارد أو الأنظمة التي يمكن للخادم إرسال طلبات إليها أو تحميل بيانات أو ملفات منها.	13.2.5
3	تحقق من أن التطبيق، حيث يتصل بخدمات منفصلة، يتّبع التكوين الموثق لكل اتصال، مثل العدد الأقصى للاتصالات المتوازية والتصرّف عند بلوغ العدد الأقصى المسموح به من الاتصالات ومهل الاتصال واستراتيجيات إعادة المحاولة.	13.2.6

V13.3 إدارة الأسرار

إن إدارة الأسرار مهمة تكوين أساسية لضمان حماية البيانات المستخدمة في التطبيق. وتوجد المتطلبات الخاصة بالتشفير في فصل "التشفير"، لكن هذا القسم يركّز على جوانب إدارة الأسرار والتعامل معها.

المستوى	الوصف	#
2	تحقق من استخدام حل لإدارة الأسرار، مثل خزانة مفاتيح، لإنشاء أسرار الواجهة الخلفية وتخزينها والتحكم في الوصول إليها وتدميرها بأمان. وقد تشمل هذه كلمات المرور ومادة المفاتيح والتكاملات مع قواعد البيانات وأنظمة الأطراف الثالثة والمفاتيح والبذور الخاصة بالرموز المعتمدة على الوقت وغيرها من الأسرار الداخلية ومفاتيح واجهات برمجة التطبيقات. ويجب ألا تُدرج الأسرار في الشيفرة المصدرية للتطبيق أو في مخرجات البناء. وبالنسبة إلى تطبيق من المستوى 3، يجب أن يتضمّن ذلك حلاً مدعوماً بالعتاد مثل وحدة أمان العتاد (HSM).	13.3.1
2	تحقق من أن الوصول إلى أصول الأسرار يتقيّد بمبدأ الحد الأدنى من الصلاحيات.	13.3.2
3	تحقق من أن جميع العمليات التشفيرية تُنفَّذ باستخدام وحدة أمان معزولة (مثل خزانة أو وحدة أمان عتادية) لإدارة مادة المفاتيح وحمايتها بأمان من التعرّض خارج وحدة الأمان.	13.3.3
3	تحقق من أن الأسرار مُهيأة لانتها الصلاحية والتدوير بناءً على وثائق التطبيق.	13.3.4

V13.4 تسريب المعلومات غير المقصود

ينبغي تحصين تكوينات الإنتاج لتجنّب كشف بيانات غير ضرورية. وكثير من هذه المشكلات يُصنّف نادراً كمخاطر جسيمة، لكنها تُسلسل غالباً مع ثغرات أخرى. وإذا لم تكن هذه المشكلات موجودة افتراضياً، فإن ذلك يرفع مستوى الصعوبة أمام مهاجمة التطبيق. على سبيل المثال، إخفاء إصدار مكونات جانب الخادم لا يلغي الحاجة إلى ترقيع جميع المكونات، وتعطيل سرد المجلدات لا يزيل الحاجة إلى استخدام ضوابط التحويل أو إبعاد الملفات عن المجلد العام، لكنه يرفع مستوى الصعوبة.

المستوى	الوصف	#
1	تحقق من أن التطبيق يُنشر إما دون أي بيانات وصفية لإدارة الإصدارات، بما فيها مجلداً git، أو svn، أو بطريقة تجعل هذين المجلدين غير قابلين للوصول خارجياً ومن التطبيق نفسه.	13.4.1
2	تحقق من تعطيل أوضاع التنقيح لجميع المكونات في بيئات الإنتاج لمنع كشف ميزات التنقيح وتسريب المعلومات.	13.4.2
2	تحقق من أن خوادم الويب لا تكشف سرد الأدلة للعملاء إلا إذا كان ذلك مقصوداً صراحةً.	13.4.3
2	تحقق من أن استخدام طريقة TRACE HTTP غير مدعوم في بيئات الإنتاج، لتجنّب احتمال تسريب المعلومات.	13.4.4
2	تحقق من أن الوثائق (مثل وثائق واجهات برمجة التطبيقات الداخلية) ونقاط نهاية المراقبة غير مكشوفة إلا إذا كان ذلك مقصوداً صراحةً.	13.4.5
3	تحقق من أن التطبيق لا يكشف معلومات إصدار مفصلة عن مكونات الواجهة الخلفية.	13.4.6
3	تحقق من أن طبقة الويب مُهيأة لتقديم الملفات ذات امتدادات محدّدة فقط، وذلك لمنع التسريب غير المقصود للمعلومات والتكوين والشفرة المصدرية.	13.4.7

المراجع

لمزيد من المعلومات، انظر أيضاً:

Testing Management Deployment and Configuration Guide: Testing Security Web OWASP •

V14 حماية البيانات

الهدف من ضوابط الأمان

لا يمكن للتطبيقات أن تحسب لجميع أنماط الاستخدام وسلوكيات المستخدمين، ولذلك ينبغي لها تنفيذ ضوابط للحد من الوصول غير المصرّح به إلى البيانات الحساسة على أجهزة العملاء. ويشتمل هذا الفصل على متطلبات متعلقة بتحديد البيانات التي تحتاج إلى حماية، وكيفية حمايتها، والآليات المحدّدة التي ينبغي تنفيذها أو المزالق التي ينبغي تجنّبها.

ومن الاعتبارات الأخرى لحماية البيانات الاستخراج بالجملة أو التعديل أو الاستخدام المفرط. ومن المرجّح أن تكون متطلبات كل نظام مختلفة جداً، ولذلك يجب أن يراعي تحديد ما هو "غير طبيعي" نموذج التهديد ومخاطر العمل. ومن منظور معيار التحقق من أمان التطبيقات، يُعالج كشف هذه المشكلات في فصل "تسجيل الأحداث الأمنية ومعالجة الأخطاء"، ويُعالج وضع الحدود في فصل "التحقق من الصحة ومنطق العمل".

V14.1 توثيق حماية البيانات

من الشروط المسبقة الرئيسية للقدرة على حماية البيانات تصنيف البيانات التي ينبغي اعتبارها حساسة. ومن المرجّح أن تكون هناك عدة مستويات مختلفة من الحساسية، وستكون الضوابط اللازمة لحماية البيانات في كل مستوى مختلفة. وهناك لوائح وقوانين خصوصية متنوعة تؤثر في كيفية تعامل التطبيقات مع تخزين المعلومات الشخصية الحساسة واستخدامها ونقلها. ولم يعد هذا القسم يحاول تكرار هذه الأنواع من تشريعات حماية البيانات أو الخصوصية، بل يركّز على الاعتبارات التقنية الرئيسية لحماية البيانات الحساسة. يُرجى الرجوع إلى القوانين واللوائح المحلية، واستشارة متخصص خصوصية مؤهل أو محام عند الحاجة.

المستوى	الوصف	#
2	تحقق من أن جميع البيانات الحساسة التي ينشئها التطبيق ويعالجها قد حُدّدت وصُنّفت في مستويات حماية. ويشمل ذلك البيانات المُرمّزة فقط والتي يسهل بالتالي فك ترميزها، مثل سلاسل Base64 أو الحمولة بنص واضح داخل رمز JWT. ويلزم أن تراعي مستويات الحماية أي لوائح ومعايير لحماية البيانات والخصوصية يُطلب من التطبيق الامتثال لها.	14.1.1
2	تحقق من أن جميع مستويات حماية البيانات الحساسة مجموعة موثقة من متطلبات الحماية. ويجب أن يشمل ذلك (على سبيل المثال لا الحصر) المتطلبات المتعلقة بالتشفير العام والتحقق من السلامة والاستبقاء وكيفية تسجيل البيانات وضوابط الوصول إلى البيانات الحساسة في السجلات والتشفير على مستوى قاعدة البيانات والخصوصية والتقنيات المعززة للخصوصية التي ستستخدم، وغيرها من متطلبات السرية.	14.1.2

V14.2 الحماية العامة للبيانات

يحتوي هذا القسم على متطلبات عملية متنوعة متعلقة بحماية البيانات. ومعظمها خاص بمسائل معيّنة مثل تسريب البيانات غير المقصود، لكن هناك كذلك متطلباً عاماً لتنفيذ ضوابط الحماية بناءً على مستوى الحماية المطلوب لكل عنصر بيانات.

المستوى	الوصف	#
1	تحقق من أن البيانات الحساسة لا تُرسل إلى الخادم إلا في متن رسالة HTTP أو في حقول ترويستها، ومن أن عنوان URL وسلسلة الاستعلام لا يحتويان على معلومات حساسة، مثل مفتاح واجهة برمجة تطبيقات أو رمز جلسة.	14.2.1
2	تحقق من أن التطبيق يمنع تخزين البيانات الحساسة مؤقتاً في مكونات الخادم، مثل موازنات الحمل وذاكرات التخزين المؤقت للتطبيق، أو يضمن إزالة البيانات بأمان بعد الاستخدام.	14.2.2

المستوى	الوصف	#
2	تحقق من أن البيانات الحساسة المحددة لا تُرسل إلى أطراف غير موثوقة (مثل أدوات تتبّع المستخدمين) لمنع الجمع غير المرغوب فيه للبيانات خارج نطاق سيطرة التطبيق.	14.2.3
2	تحقق من أن الضوابط المتعلقة بالبيانات الحساسة بشأن التشفير والتحقق من السلامة والاستبقاء وكيفية تسجيل البيانات وضوابط الوصول إلى البيانات الحساسة في السجلات والخصوصية والتقنيات المعززة للخصوصية، مُنفّذة على النحو المحدد في الوثائق الخاصة بمستوى حماية البيانات المعنية.	14.2.4
3	تحقق من أن آليات التخزين المؤقت مُهيأة لتخزين الاستجابات التي تحمل نوع المحتوى المتوقع لذلك المورد فقط ولا تحتوي على محتوى حساس أو ديناميكي. وينبغي أن يعيد خادم الويب استجابة 404 أو 302 عند الوصول إلى ملف غير موجود بدلاً من إعادة ملف آخر صالح. وهذا ينبغي أن يمنع هجمات خداع ذاكرة التخزين المؤقت للويب.	14.2.5
3	تحقق من أن التطبيق لا يعيد سوى الحد الأدنى المطلوب من البيانات الحساسة اللازم لوظائف التطبيق. على سبيل المثال، إعادة بعض أرقام بطاقة الائتمان فقط وليس الرقم الكامل. وإذا كانت البيانات الكاملة مطلوبة، فينبغي إخفاؤها في واجهة المستخدم إلا إذا أطلع عليها المستخدم تحديداً.	14.2.6
3	تحقق من أن المعلومات الحساسة تخضع لتصنيف استبقاء البيانات، بما يضمن حذف البيانات القديمة أو غير الضرورية تلقائياً، وفق جدول محدّد، أو حسب ما يقتضيه الوضع.	14.2.7
3	تحقق من إزالة المعلومات الحساسة من البيانات الوصفية للملفات المقدّمة من المستخدم إلا إذا وافق المستخدم على تخزينها.	14.2.8

V14.3 حماية البيانات من جانب العميل

يحتوي هذا القسم على متطلبات لمنع تسريب البيانات بطرائق معيّنة في جانب العميل أو وكيل المستخدم في التطبيق.

المستوى	الوصف	#
1	تحقق من أن البيانات المصادق عليها تُمخّح من تخزين العميل، مثل DOM في المتصفح، بعد إنهاء العميل أو الجلسة. وقد يساعد حقل ترويسة استجابة HTTP المسمّى 'Clear-Site-Data' في ذلك، لكن ينبغي أن يكون جانب العميل قادراً كذلك على التنظيف إذا لم يكن الاتصال بالخادم متاحاً عند إنهاء الجلسة.	14.3.1
2	تحقق من أن التطبيق يضبط حقول ترويسة استجابة HTTP كافية لمكافئة التخزين المؤقت (أي Cache-Control: no-store) بحيث لا تُخزّن البيانات الحساسة مؤقتاً في المتصفحات.	14.3.2
2	تحقق من أن البيانات المخزّنة في تخزين المتصفح (مثل localStorage و sessionStorage و IndexedDB أو ملفات تعريف الارتباط) لا تحتوي على بيانات حساسة، باستثناء رموز الجلسة.	14.3.3

المراجع

لمزيد من المعلومات، انظر أيضاً:

- fields header anti-caching and security check to website Headers Security the using Consider
- Mozilla by headers anti-caching about Documentation
- project Headers Secure OWASP
- Project Risks Privacy OWASP
- Sheet Cheat Protection Privacy User OWASP
- information personal of Security - 11 Principle Privacy Australian
- overview (GDPR) Regulation Protection Data General Union European
- Network Engineering Privacy Internet - Supervisor Protection Data Union European
- header "Clear-Site-Data" the on Information
- Deception Cache Web on paper White

V15 البرمجة الآمنة والمعمارية

الهدف من ضوابط الأمان

يتعلق كثير من متطلبات معيار التحقق من أمان التطبيقات إما بنجال معيّن من الأمان، مثل المصادقة أو التحويل، أو بنوع معيّن من وظائف التطبيق، مثل تسجيل الأحداث أو التعامل مع الملفات.

ويوفّر هذا الفصل متطلبات أمنية عامة ينبغي مراعاتها عند تصميم التطبيقات وتطويرها. ولا تتركز هذه المتطلبات على نقاء المعمارية وجودة الشيفرة فحسب، بل كذلك على ممارسات معمارية وبرمجية محدّدة لازمة لأمان التطبيقات.

V15.1 توثيق البرمجة الآمنة والمعمارية

يعتمد كثير من متطلبات إرساء معمارية آمنة وقابلة للدفاع على توثيق واضح للقرارات المتخذة بشأن تنفيذ ضوابط أمنية معيّن والمكوّنات المستخدمة داخل التطبيق.

ويبين هذا القسم متطلبات التوثيق، بما فيها تحديد المكوّنات التي تُعدّ محتوية على "وظائف خطيرة" أو تُعدّ "مكوّنات مخوفة بالمخاطر".

وقد يكون المكوّن ذو "الوظائف الخطيرة" مكوّنًا مطوّراً داخلياً أو من طرف ثالث ينفّذ عمليات مثل فك تسلسل بيانات غير موثوقة أو تحليل ملفات أو بيانات ثنائية خام أو تنفيذ شيفرة ديناميكية أو التلاعب المباشر بالذاكرة. وتمثّل الثغرات في هذه الأنواع من العمليات خطراً مرتفعاً لاختراق التطبيق واحتمال كشف بنيته التحتية الأساسية.

أما "المكوّن المخوف بالمخاطر" فهو مكتبة من طرف ثالث (أي غير مطوّرة داخلياً) تفتقر إلى ضوابط أمنية أو تنفّذها تنفيذاً سيئاً فيما يخص عمليات تطويرها أو وظائفها. ومن الأمثلة المكوّنات التي تُصان صيانة سيئة أو غير المدعومة أو التي في مرحلة نهاية العمر أو التي لها تاريخ من الثغرات الجسيمة.

ويؤكّد هذا القسم كذلك أهمية تحديد أطر زمنية ملائمة لمعالجة الثغرات في مكوّنات الأطراف الثالثة.

المستوى	الوصف	#
1	تحقق من أن وثائق التطبيق تحدّد أطرًا زمنية للمعالجة مبنية على المخاطر لإصدارات مكوّنات الأطراف الثالثة التي تحتوي على ثغرات، ولتحديث المكتبات بشكل عام، وذلك لتقليل المخاطر الناشئة عن هذه المكوّنات.	15.1.1

المستوى	الوصف	#
2	تحقق من الاحتفاظ بفهرس جرد، مثل قائمة مكونات البرمجيات (SBOM) بجميع مكتبات الأطراف الثالثة المستخدمة، بما في ذلك التحقق من أن المكونات تأتي من مستودعات محدّدة مسبقاً وموثوقة وتُصان على نحو مستمر.	15.1.2
2	تحقق من أن وثائق التطبيق تحدّد الوظائف المستهلكة للوقت أو المطلوبة للموارد بكثافة. ويجب أن يشمل ذلك كيفية منع فقدان التوافر بسبب الاستخدام المفرط لهذه الوظائف وكيفية تجنّب وضع يستغرق فيه بناء الاستجابة وقتاً أطول من مهلة المستهلك. وقد تشمل الدفاعات المحتملة المعالجة غير المتزامنة واستخدام قوائم الانتظار وتحديد العمليات المتوازية لكل مستخدم ولكل تطبيق.	15.1.3
3	تحقق من أن وثائق التطبيق تُبرز مكتبات الأطراف الثالثة التي تُعدّ "مكونات محفوفة بالمخاطر".	15.1.4
3	تحقق من أن وثائق التطبيق تُبرز أجزاء التطبيق التي تُستخدم فيها "وظائف خطيرة".	15.1.5

V15.2 معمارية الأمان والتبعيات

يشتمل هذا القسم على متطلبات للتعامل مع التبعيات والمكونات المحفوفة بالمخاطر أو القديمة أو غير الآمنة من خلال إدارة التبعيات. ويشمل كذلك استخدام تقنيات على مستوى المعمارية مثل العزل في صندوق رملي والتغليف والاحتواء في حاويات وعزل الشبكة، لتقليل أثر استخدام "العمليات الخطيرة" أو "المكونات المحفوفة بالمخاطر" (كما هي محدّدة في القسم السابق) ولمنع فقدان التوافر بسبب الاستخدام المفرط للوظائف المطلوبة للموارد بكثافة.

المستوى	الوصف	#
1	تحقق من أن التطبيق لا يحتوي إلا على مكونات لم تتجاوز الأطر الزمنية الموثّقة للتحديث والمعالجة.	15.2.1
2	تحقق من أن التطبيق قد نفّذ دفاعات ضد فقدان التوافر بسبب الوظائف المستهلكة للوقت أو المطلوبة للموارد بكثافة، بناءً على القرارات والاستراتيجيات الأمنية الموثّقة لذلك.	15.2.2
2	تحقق من أن بيئة الإنتاج لا تشتمل إلا على الوظائف اللازمة لعمل التطبيق، ولا تكشف وظائف زائدة مثل شيفرة الاختبار والمقتطفات النموذجية ووظائف التطوير.	15.2.3
3	تحقق من أن مكونات الأطراف الثالثة وجميع تبعياتها المتعدّية تُضمّن من المستودع المتوقع، سواء كان مملوكاً داخلياً أو مصدرًا خارجياً، ومن عدم وجود خطر هجوم التباس التبعيات.	15.2.4
3	تحقق من أن التطبيق ينفّذ حماية إضافية حول أجزاء التطبيق الموثّقة أنها تحتوي على "وظائف خطيرة" أو تستخدم مكتبات أطراف ثالثة تُعدّ "مكونات محفوفة بالمخاطر". وقد يشمل ذلك تقنيات مثل العزل في صندوق رملي أو التغليف أو الاحتواء في حاويات أو العزل على مستوى الشبكة، لتأخير المهاجمين الذين يخترقون جزءاً من التطبيق وردعهم عن الانتقال إلى أماكن أخرى فيه.	15.2.5

V15.3 البرمجة الدفاعية

يتناول هذا القسم أنواع الثغرات، بما فيها تلاعب الأنواع وتلوّث النموذج الأولي وغيرها، الناتجة عن استخدام أنماط برمجة غير آمنة في لغة معيّنة. وقد لا يكون بعضها ذا صلة بجميع اللغات، بينما سيكون لبعضها الآخر إصلاحات خاصة باللغة أو قد يتعلق بكيفية تعامل لغة أو إطار عمل معيّن مع ميزة مثل معاملات HTTP. ويراعي كذلك خطر عدم التحقق تشفيراً من تحديثات التطبيق.

ويراعي كذلك المخاطر المرتبطة باستخدام الكائنات لتمثيل عناصر البيانات وقبولها وإعادةتها عبر واجهات برمجة التطبيقات الخارجية. وفي هذه الحالة، يجب أن يضمن التطبيق ألا تُعدّل حقول البيانات التي لا ينبغي أن تكون قابلة للكّابة بواسطة مدخلات المستخدم (الإسناد الجماعي) وأن تكون واجهة برمجة التطبيقات انتقائية بشأن حقول البيانات التي تُعاد. وحيث يعتمد الوصول إلى الحقول على صلاحيات المستخدم، ينبغي مراعاة ذلك في سياق متطلب التحكم في الوصول على مستوى الحقول في فصل التحويل.

المستوى	الوصف	#
1	تحقق من أن التطبيق لا يعيد إلا المجموعة الفرعية المطلوبة من الحقول من كائن بيانات. على سبيل المثال، ينبغي ألا يعيد كائن بيانات كاملاً، إذ لا ينبغي أن تكون بعض الحقول الفردية متاحة للمستخدمين.	15.3.1
2	تحقق من أن الواجهة الخلفية للتطبيق، حيث تجري استدعاءات إلى عناوين URL خارجية، مُهيّأة لعدم اتّباع عمليات إعادة التوجيه إلا إذا كانت وظيفة مقصودة.	15.3.2
2	تحقق من أن التطبيق يمتلك تدابير مضادة للحماية من هجمات الإسناد الجماعي عن طريق تحديد الحقول المسموح بها لكل متحكّم وإجراء، أي أنه لا يمكن إدراج قيمة حقل أو تحديثها إذا لم يكن مقصوداً أن تكون جزءاً من ذلك الإجراء.	15.3.3
2	تحقق من أن جميع مكونات الوكالة والبرمجيات الوسيطة تنقل عنوان IP الأصلي للمستخدم على نحو صحيح باستخدام حقول بيانات موثوقة لا يمكن للمستخدم النهائي التلاعب بها، ومن أن التطبيق وخادم الويب يستخدمان هذه القيمة الصحيحة لتسجيل الأحداث والقرارات الأمنية مثل تحديد المعدّل، مع مراعاة أن عنوان IP الأصلي نفسه قد لا يكون موثقاً بسبب عناوين IP الديناميكية أو الشبكات الخاصة الافتراضية أو الجدران النارية للشركات.	15.3.4
2	تحقق من أن التطبيق يضمن صراحةً أن المتغيرات من النوع الصحيح وبنّقد عمليات مساواة ومقارنة صارمة. والغرض من ذلك تجنّب ثغرات تلاعب الأنواع أو التباسها الناتجة عن افتراض شيفرة التطبيق نوعاً لمتغير ما.	15.3.5
2	تحقق من أن شيفرة JavaScript مكتوبة بطريقة تمنع تلوّث النموذج الأولي، وذلك مثلاً باستخدام Set() أو Map() بدلاً من الكائنات الحرفية.	15.3.6
2	تحقق من أن التطبيق يمتلك دفاعات ضد هجمات تلوّث معاملات HTTP، وخصوصاً إذا كان إطار عمل التطبيق لا يميّز بين مصادر معاملات الطلب (سلسلة الاستعلام أو معاملات المتن أو ملفات تعريف الارتباط أو حقول الترويسة).	15.3.7

V15.4 التزامن الآمن

يمكن أن تؤدي مشكلات التزامن، مثل حالات التسابق وثغرات من وقت الفحص إلى وقت الاستخدام (TOCTOU) والجمود والجمود الحيوي وتجميع الخيوط والمزامنة غير السليمة، إلى سلوك غير متوقع ومخاطر أمنية. ويشتمل هذا القسم على تقنيات واستراتيجيات متنوعة للمساعدة في التخفيف من هذه المخاطر.

المستوى	الوصف	#
3	تحقق من أن الكائنات المشتركة في الشيفرة متعددة الخيوط (مثل ذاكرات التخزين المؤقت أو الملفات أو الكائنات في الذاكرة التي تصل إليها خيوط متعددة) يُوصل إليها بأمان باستخدام أنواع آمنة للخيوط وآليات مزامنة مثل الأقفال أو الإشارات، وذلك لتجنّب حالات التسابق وتلف البيانات.	15.4.1
3	تحقق من أن الفحوص على حالة مورد ما، مثل وجوده أو صلاحياته، والإجراءات التي تعتمد عليها تُنفَّذ كعملية ذرية واحدة لمنع حالات تسابق من وقت الفحص إلى وقت الاستخدام (TOCTOU) على سبيل المثال، فحص وجود ملف قبل فتحه، أو التحقق من وصول مستخدم قبل منحه.	15.4.2
3	تحقق من استخدام الأقفال باتساق لتجنّب تعلق الخيوط، سواء بانتظار بعضها بعضاً أو بإعادة المحاولة إلى ما لا نهاية، ومن أن منطق القفل يبقى داخل الشيفرة المسؤولة عن إدارة المورد لضمان عدم إمكانية تعديل الأقفال عن غير قصد أو بشكل خبيث بواسطة أصناف أو شيفرات خارجية.	15.4.3
3	تحقق من أن سياسات تخصيص الموارد تمنع تجويع الخيوط بضمان وصول عادل إلى الموارد، وذلك مثلاً بالاستفادة من مجمّعات الخيوط، بما يتيح للخيوط ذات الأولوية الأدنى المضي قدماً في إطار زمني معقول.	15.4.4

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Sheet Cheat Prevention Pollution Prototype OWASP
- Sheet Cheat Prevention Assignment Mass OWASP
- Specification Materials of Bill CycloneDX OWASP
- Pollution Parameter HTTP for Testing Guide: Testing Security Web OWASP

V16 تسجيل الأحداث الأمنية ومعالجة الأخطاء

الهدف من ضوابط الأمان

تختلف سجلات الأمان عن سجلات الأخطاء أو الأداء، وتُستخدم لتدوين الأحداث ذات الصلة بالأمان مثل قرارات المصادقة وقرارات التحكم في الوصول ومحاولات تجاوز ضوابط الأمان، مثل التحقق من صحة المدخلات أو التحقق من منطق العمل. والغرض منها دعم الكشف والاستجابة والتحقيق من خلال توفير بيانات منظّمة عالية الإشارة لأدوات التحليل مثل أنظمة SIEM.

ولا ينبغي أن تشمل السجلات على بيانات شخصية حساسة إلا إذا كان ذلك مطلوباً قانوناً، ويجب حماية أي بيانات مسجّلة كأصل عالي القيمة. ويجب ألا يمسّ تسجيل الأحداث بالخصوصية أو بأمان النظام. ويجب كذلك أن تفشل التطبيقات بأمان، متجنّبة الكشف أو التعطيل غير الضروريين.

وللحصول على إرشادات تنفيذ مفصّلة، راجع أوراق OWASP المرجعية في قسم المراجع.

V16.1 توثيق تسجيل الأحداث الأمنية

يضمن هذا القسم وجود جرد واضح وكامل لتسجيل الأحداث على امتداد حزمة التطبيق. وهذا ضروري للمراقبة الأمنية الفعّالة والاستجابة للحوادث والامثال.

المستوى	الوصف	#
2	تحقق من وجود جرد يوثق تسجيل الأحداث المنفّذ في كل طبقة من حزمة تقنيات التطبيق، وما الأحداث التي تُسجّل، وصيغ السجلات، وأين تُخزّن، وكيف تُستخدم، وكيف يُتحكّم في الوصول إليها، ومدة الاحتفاظ بها.	16.1.1

V16.2 تسجيل الأحداث العام

يوفر هذا القسم متطلبات للتأكد من أن سجلات الأمان منظّمة باتساق وتحتوي على البيانات الوصفية المتوقعة. والهدف جعل السجلات قابلة للقراءة آلياً وللتحليل على امتداد الأنظمة والأدوات الموزّعة.

وبطبيعة الحال، تتضمّن الأحداث الأمنية غالباً بيانات حساسة. وإذا نُجّلت هذه البيانات دون مراعاة، تصبح السجلات نفسها مصنّفة ومن ثم خاضعة لمتطلبات التشفير وسياسات استبقاء أكثر صرامة واحتمال الكشف عنها أثناء عمليات التدقيق.

ولذلك من الأهمية البالغة تسجيل ما هو ضروري فقط والتعامل مع بيانات السجلات بالعناية نفسها التي تُولى للأصول الحساسة الأخرى.

وتُرسى المتطلبات أدناه متطلبات أساسية لبيانات السجلات الوصفية والمزامنة والصيغة والتحكم.

المستوى	الوصف	#
2	تحقق من أن كل مدخلة في السجل تشتمل على البيانات الوصفية اللازمة (مثل متى وأين ومن وماذا) التي تتيح إجراء تحقيق مفصّل في التسلسل الزمني عند وقوع حدث.	16.2.1
2	تحقق من أن مصادر الوقت لجميع مكوّنات تسجيل الأحداث متزامنة، ومن أن الطوايع الزمنية في البيانات الوصفية للأحداث الأمنية تستخدم التوقيت العالمي المنسق (UTC) أو تشتمل على فرق منطقة زمنية صريح. ويوصى باستخدام UTC لضمان الاتساق على امتداد الأنظمة الموزّعة ولمنع الالتباس أثناء التحوّلات إلى التوقيت الصيفي.	16.2.2
2	تحقق من أن التطبيق لا يخزّن السجلات أو يبيّنها إلا إلى الملفات والخدمات الموثّقة في جرد السجلات.	16.2.3
2	تحقق من أن السجلات قابلة للقراءة والربط بواسطة معالج السجلات المستخدم، ويُفضّل باستخدام صيغة تسجيل شائعة.	16.2.4
2	تحقق من أن التطبيق، عند تسجيل بيانات حساسة، يُنفذ التسجيل بناءً على مستوى حماية البيانات. على سبيل المثال، قد لا يُسمح بتسجيل بيانات معيّنة، مثل بيانات الاعتماد أو تفاصيل الدفع. وقد لا تُسجّل بيانات أخرى، مثل رموز الجلسة، إلا بعد تليدها أو إخفاءها، كلياً أو جزئياً.	16.2.5

V16.3 الأحداث الأمنية

يحدّد هذا القسم متطلبات تسجيل الأحداث ذات الصلة بالأمان داخل التطبيق. والتقاط هذه الأحداث بالغ الأهمية لكشف السلوك المشبوه ودعم التحقيقات والوفاء بالتزامات الامتثال.

ويبيّن هذا القسم أنواع الأحداث التي ينبغي تسجيلها لكنه لا يحاول تقديم تفاصيل شاملة. فلكل تطبيق عوامل مخاطر وسياق تشغيلي فريدان. ولاحظ أنه مع أن معيار التحقق من أمان التطبيقات يدرج تسجيل الأحداث الأمنية في نطاقه، فإن التنبيه والربط (مثل قواعد SIEM أو بنية المراقبة التحتية) يُعدّان خارج النطاق ويتولاهما نظاماً التشغيل والمراقبة.

المستوى	الوصف	#
2	تحقق من تسجيل جميع عمليات المصادقة، بما فيها المحاولات الناجحة وغير الناجحة. وينبغي كذلك جمع بيانات وصفية إضافية، مثل نوع المصادقة أو العوامل المستخدمة.	16.3.1
2	تحقق من تسجيل محاولات التحويل الفاشلة. وبالنسبة إلى المستوى 3، يجب أن يشمل ذلك تسجيل جميع قرارات التحويل، بما فيها التسجيل عند الوصول إلى بيانات حساسة (دون تسجيل البيانات الحساسة نفسها).	16.3.2
2	تحقق من أن التطبيق يسجّل الأحداث الأمنية المحدّدة في الوثائق ويسجّل كذلك محاولات تجاوز ضوابط الأمان، مثل التحقق من صحة المدخلات ومنطق العمل ومكافحة الأتمتة.	16.3.3
2	تحقق من أن التطبيق يسجّل الأخطاء غير المتوقعة وأعطال ضوابط الأمان مثل أعطال TLS في الواجهة الخلفية.	16.3.4

V16.4 حماية السجلات

السجلات آثار جنائية قيمة ويجب حمايتها. فإذا كان من السهل تعديل السجلات أو حذفها، فإنها تفقد سلامتها وتصبح غير موثوقة للتحقيق في الحوادث أو للإجراءات القانونية. وقد تكشف السجلات السلوك الداخلي للتطبيق أو بيانات وصفية حساسة، ما يجعلها هدفاً جذاباً للهackerين.

ويحدّد هذا القسم متطلبات للتأكد من حماية السجلات من الوصول غير المصرّح به والتلاعب والكشف، ومن أنها تُنقل وتُخزّن بأمان في أنظمة آمنة ومعزولة.

المستوى	الوصف	#
2	تحقق من أن جميع مكّنات تسجيل الأحداث تُرمّز البيانات على النحو الملائم لمنع حقن السجلات.	16.4.1
2	تحقق من أن السجلات محمية من الوصول غير المصرّح به ولا يمكن تعديلها.	16.4.2
2	تحقق من أن السجلات تُنقل بأمان إلى نظام منفصل منطقياً للتحليل والكشف والتنبيه والتصعيد. والهدف التأكد من أنه في حال اختراق التطبيق، لا تُخترق السجلات.	16.4.3

V16.5 معالجة الأخطاء

يحدّد هذا القسم متطلبات للتأكد من أن التطبيقات تفشل بسلاسة وأمان دون كشف تفاصيل داخلية حساسة.

المستوى	الوصف	#
2	تحقق من إعادة رسالة عامة إلى المستهلك عند وقوع خطأ غير متوقع أو حسّاس أمنياً، بما يضمن عدم كشف بيانات داخلية حساسة للنظام مثل تتبعات المكّس والاستعلامات والمفاتيح السريّة والرموز المميزة.	16.5.1
2	تحقق من أن التطبيق يستمر في العمل بأمان عند فشل الوصول إلى مورد خارجي، وذلك مثلاً باستخدام أنماط مثل قواطع الدائرة أو التدهور السلس.	16.5.2
2	تحقق من أن التطبيق يفشل بسلاسة وأمان، بما في ذلك عند وقوع استثناء، بما يمنع حالات الفشل المفتوح مثل معالجة معاملة رغم الأخطاء الناتجة عن منطق التحقق من الصحة.	16.5.3
3	تحقق من تعريف معالج أخطاء "كلاذ أخير" يلتقط جميع الاستثناءات غير المعالجة، والغرض من ذلك تجنّب فقدان تفاصيل الأخطاء التي يجب أن تذهب إلى ملفات السجلات، وكذلك ضمان ألا يسقط خطأ ما عملية التطبيق بأكملها، ما يؤدي إلى فقدان التوافر.	16.5.4

ملاحظة: هناك لغات معيّنة (منها Go و Swift)، وبحكم الممارسة التصميمية الشائعة، كثير من اللغات الوظيفية لا تدعم الاستثناءات أو معالجات الأحداث كلاذ أخير. وفي هذه الحالة، ينبغي للمعماريين والمطوّرين استخدام نمط أو لغة أو طريقة ملائمة لإطار العمل لضمان قدرة التطبيقات على معالجة الأحداث الاستثنائية أو غير المتوقعة أو المتصلة بالأمان بأمان.

المراجع

لمزيد من المعلومات، انظر أيضاً:

- Handling Error for Testing Guide: Testing Security Web OWASP •
- messages error about section Sheet Cheat Authentication OWASP •
- Sheet Cheat Logging OWASP •
- Sheet Cheat Vocabulary Logging Application OWASP •

WebRTC V17

الهدف من ضوابط الأمان

تتيح اتصالات الويب في الوقت الحقيقي (WebRTC) تبادل الصوت والفيديو والبيانات في الوقت الحقيقي في التطبيقات الحديثة. ومع تزايد التبني، يصبح تأمين بنية WebRTC التحتية أمراً بالغ الأهمية. ويوفّر هذا القسم متطلبات أمنية لأصحاب المصلحة الذين يطوّرون أنظمة WebRTC أو يستضيفونها أو يدمجونها.

ويمكن تصنيف سوق WebRTC عموماً في ثلاثة قطاعات:

1. مطوّرو المنتجات: الموردون المالكون وموردو المصادر المفتوحة الذين ينشئون منتجات وحلول WebRTC ويوفّرونها وتركيزهم على تطوير تقنيات WebRTC متينة وأمنة يمكن للآخرين استخدامها.

2. منصّات الاتصالات نكّمة (CPaaS) المزودون الذين يوفّرون واجهات برمجية التطبيقات وحِزم تطوير البرمجيات والبنية التحتية أو المنصّات اللازمة لتكّين وظائف WebRTC. وقد يستخدم مزودو CPaaS منتجات من الفئة الأولى أو يطوّرون برمجيات WebRTC خاصة بهم لتقديم هذه الخدمات.

3. مزودو الخدمات: المؤسسات التي تستفيد من منتجات مطوّري المنتجات أو مزودي CPaaS، أو تطوّر حلول WebRTC خاصة بها. وهي تنشئ وتنفّذ تطبيقات للمؤتمرات عبر الإنترنت والرعاية الصحية والتعلّم الإلكتروني وغيرها من المجالات التي يكون فيها الاتصال في الوقت الحقيقي بالغ الأهمية.

والمطلبات الأمنية المبينة هنا موجّهة أساساً إلى مطوّري المنتجات ومزودو CPaaS ومزودو الخدمات الذين:

- يستخدمون من حلول المصادر المفتوحة لبناء تطبيقات WebRTC الخاصة بهم.
- يستخدمون منتجات WebRTC التجارية كجزء من بنيتهم التحتية.
- يستخدمون حلول WebRTC المطوّرة داخلياً أو يدجّون مكوّنات متنوعة في عرض خدمة متكامل.

ومن المهم ملاحظة أن هذه المتطلبات الأمنية لا تنطبق على المطوّرين الذين يستخدمون حصرياً حِزم تطوير البرمجيات وواجهات برمجية التطبيقات التي يوفّرها مزودو CPaaS. فبالنسبة إلى هؤلاء المطوّرين، يكون مزودو CPaaS مسؤولين عادةً عن معظم الاعتبارات الأمنية الأساسية داخل منصّاتهم، وقد لا يلبّي معيار أمني عام مثل معيار التحقق من أمان التطبيقات احتياجاتهم بالكامل.

V17.1 خادم TURN

يحدّد هذا القسم متطلبات أمنية للأنظمة التي تشغّل خوادم TURN (الاجتياز باستخدام المُرحّلات حول NAT) الخاصة بها. وتساعد خوادم TURN في ترحيل الوسائط في بيئات الشبكات المقيدة، لكنها قد تمثّل مخاطر إذا هيئت على نحو خاطئ. وتركّز هذه الضوابط على التصفية الآمنة للعناوين والحماية من استنفاد الموارد.

المستوى	الوصف	#
2	تحقق من أن خدمة الاجتياز باستخدام المُرحّلات حول NAT (TURN) لا تسمح بالوصول إلا إلى عناوين IP غير المحجوزة لأغراض خاصة (مثل الشبكات الداخلية والبث والاسترجاع المحلي). ولاحظ أن هذا ينطبق على عناوين IPv4 وIPv6 على حد سواء.	17.1.1
3	تحقق من أن خدمة الاجتياز باستخدام المُرحّلات حول NAT (TURN) غير معرّضة لاستنفاد الموارد عندما يحاول مستخدمون شرعيون فتح عدد كبير من المنافذ على خادم TURN.	17.1.2

V17.2 الوسائط

لا تنطبق هذه المتطلبات إلا على الأنظمة التي تستضيف خوادم وسائط WebRTC الخاصة بها، مثل وحدات التوجيه الانتقائي (SFUs) ووحدات التحكم متعددة النقاط (MCUs) وخوادم التسجيل أو خوادم البوابات. وتعامل خوادم الوسائط مع تدفقات الوسائط وتوزّعها، ما يجعل أمانها بالغ الأهمية لحماية الاتصال بين الأنداد. وحماية تدفقات الوسائط أمر بالغ الأهمية في تطبيقات WebRTC لمنع التنصّت والتلاعب وهجمات حجب الخدمة التي قد تمسّ بخصوصية المستخدم وجودة الاتصال.

وعلى وجه الخصوص، من الضروري تنفيذ حماية من هجمات الإغراق، مثل تحديد المعدّل والتحقق من الطوابع الزمنية واستخدام ساعات متزامنة لمطابقة الفواصل الزمنية في الوقت الحقيقي وإدارة المخازن المؤقتة لمنع الفيضان والحفاظ على التوقيت السليم. وإذا وصلت رزم جلسة

وسائط معيّنة بسرعة مفرطة، فينبغي إسقاط الرزم الزائدة. ومن المهم كذلك حماية النظام من الرزم المشوّهة عن طريق تنفيذ التحقق من صحة المدخلات ومعالجة فيضان الأعداد الصحيحة بأمان ومنع فيضان المخازن المؤقتة واستخدام تقنيات أخرى متينة لمعالجة الأخطاء.

أما الأنظمة التي تعتمد كلياً على اتصال الوسائط نداءً لنّ بين متصفحات الويب، دون مشاركة خوادم وسائط وسيطة، فهي مستثناة من هذه المتطلبات الأمنية المحددة المتعلقة بالوسائط.

ويشير هذا القسم إلى استخدام أمان طبقة النقل لرزم البيانات (DTLS) في سياق WebRTC ويمكن العثور على مطلب متعلق بوجود سياسة موثقة لإدارة مفاتيح التشفير في فصل "التشفير". ويمكن العثور على معلومات عن طرائق التشفير المعتمدة إما في ملحق التشفير في معيار التحقق من أمان التطبيقات أو في وثائق مثل 2 Rev. 800-52 SP NIST أو TR-02102-2 BSI (الإصدار 2025-01).

المستوى	الوصف	#
2	تحقق من أن مفتاح شهادة أمان طبقة النقل لرزم البيانات (DTLS) يُدار ويُحجى بناءً على السياسة الموثقة لإدارة مفاتيح التشفير.	17.2.1
2	تحقق من أن خادم الوسائط مُهيأ لاستخدام ودعم مجموعات تشفير معتمدة لأمان طبقة النقل لرزم البيانات (DTLS) وملف حماية آمن لامتداد DTLS الخاص بإنشاء مفاتيح لبروتوكول النقل الآمن في الوقت الحقيقي (DTLS-SRTP).	17.2.2
2	تحقق من فحص مصادقة بروتوكول النقل الآمن في الوقت الحقيقي (SRTP) في خادم الوسائط لمنع هجمات حقن بروتوكول النقل في الوقت الحقيقي (RTP) من أن تؤدي إلى حالة حجب خدمة أو إلى إدخال وسائط صوتية أو مرئية في تدفقات الوسائط.	17.2.3
2	تحقق من أن خادم الوسائط قادر على مواصلة معالجة حزم الوسائط الواردة عند مواجهة رزم مشوّهة من بروتوكول النقل الآمن في الوقت الحقيقي (SRTP).	17.2.4
3	تحقق من أن خادم الوسائط قادر على مواصلة معالجة حزم الوسائط الواردة أثناء إغراق برزم بروتوكول النقل الآمن في الوقت الحقيقي (SRTP) من مستخدمين شرعيين.	17.2.5
3	تحقق من أن خادم الوسائط غير معرض لثغرة حالة التسابق في "ClientHello" في أمان طبقة النقل لرزم البيانات (DTLS)، وذلك بفحص ما إذا كان خادم الوسائط معروفاً علناً بأنه معرض لها أو بإجراء اختبار حالة التسابق.	17.2.6
3	تحقق من أن أي آليات لتسجيل الصوت أو الفيديو مرتبطة بخادم الوسائط قادرة على مواصلة معالجة حزم الوسائط الواردة أثناء إغراق برزم بروتوكول النقل الآمن في الوقت الحقيقي (SRTP) من مستخدمين شرعيين.	17.2.7
3	تحقق من فحص شهادة أمان طبقة النقل لرزم البيانات (DTLS) مقابل سمة البصمة في بروتوكول وصف الجلسة (SDP)، وإنهاء تدفق الوسائط في حال فشل الفحص، وذلك لضمان أصالة تدفق الوسائط.	17.2.8

17.3 V الإشارات

يحدّد هذا القسم متطلبات للأنظمة التي تشغل خوادم الإشارات الخاصة بها في WebRTC وتنسق الإشارات الاتصال نداءً لنّ ويجب أن تكون صامدة أمام الهجمات التي قد تعطل إنشاء الجلسة أو التحكم فيها.

ولضمان إشارات آمنة، يجب أن تتعامل الأنظمة مع المدخلات المشوّهة بسلاسة وأن تبقى متاحة تحت الحمل.

المستوى	الوصف	#
2	تحقق من أن خادم الإشارات قادر على مواصلة معالجة رسائل الإشارات الواردة الشرعية أثناء هجوم إغراق. وينبغي تحقيق ذلك بتنفيذ تحديد للمعدل على مستوى الإشارات.	17.3.1
2	تحقق من أن خادم الإشارات قادر على مواصلة معالجة رسائل الإشارات الشرعية عند مواجهة رسالة إشارات مشوهة قد تسبب حالة حجب خدمة. وقد يشمل ذلك تنفيذ التحقق من صحة المدخلات ومعالجة فيضان الأعداد الصحيحة بأمان ومنع فيضان المخازن المؤقتة واستخدام تقنيات أخرى متينة لمعالجة الأخطاء.	17.3.2

المراجع

لمزيد من المعلومات، انظر أيضاً:

- أفضل توثيق لهجوم حجب الخدمة عبر ClientHello في DTLS الخاص بـ WebRTC موجود في post blog Security's Enable
- aimed security at professionals وفي aimed paper white WebRTC developers المرتبطة به
- Applications Real-Time for Protocol Transport A RTP: - 3550 RFC
- (SRTP) Protocol Transport Real-time Secure The - 3711 RFC
- Secure the for Keys Establish to Extension (DTLS) Security Layer Transport Datagram - 5764 RFC
- ((SRTP)) Protocol Transport Real-time
- Applications Browser-Based for Protocols Real-Time Overview: - 8825 RFC
- WebRTC for Considerations Security - 8826 RFC
- Architecture Security WebRTC - 8827 RFC
- Profiles Protection DTLS-SRTP

الملحق أ: قائمة المصطلحات

- **Lifetime Session Maximum Absolute** (العمر الأقصى المطلق للجلسة) - يُشار إليه أيضاً باسم "Overall Timeout" في NIST، وهو أقصى مدة زمنية يمكن أن تبقى فيها الجلسة نشطة بعد المصادقة بغض النظر عن تفاعل المستخدم. وهو أحد مكونات انتهاء صلاحية الجلسة.
- **Allowlist** (قائمة السماح) - قائمة بالبيانات أو العمليات المسموح بها، على سبيل المثال قائمة بالمحارف المسموح بها لإجراء التحقق من صحة المدخلات.
- **token Anti-forgery** (رمز الحماية من التزوير) - آلية يتم فيها تمرير رمز مميز واحد أو أكثر في الطلب ويتحقق منها خادم التطبيق للتأكد من أن الطلب قد ورد من نقطة نهاية متوقعة.
- **Security Application** (أمان التطبيق) - يركز الأمان على مستوى التطبيق على تحليل المكونات التي تشكل طبقة التطبيق في النموذج المرجعي لربط الأنظمة المفتوحة (OSI)، (Model) بدلاً من التركيز على نظام التشغيل الأساسي أو الشبكات المتصلة مثلاً.
- **Verification Security Application** (التحقق من أمان التطبيق) - التقييم الفني لتطبيق ما مقابل معيار معيار OWASP للتحقق من أمان التطبيقات.
- **Report Verification Security Application** (تقرير التحقق من أمان التطبيق) - تقرير يوثق النتائج الإجمالية والتحليل الداعم الذي ينتجه المدقق لتطبيق معين.

- **Authentication** (المصادقة) - التحقق من الهوية المدّعاة لمستخدم التطبيق.
- **Verification Automated** (التحقق المؤتمت) - استخدام أدوات مؤتمتة (إما أدوات التحليل الديناميكي أو أدوات التحليل الساكن أو كليهما) تستخدم مواقع الثغرات للعثور على المشكلات.
- **testing box Black** (اختبار الصندوق الأسود) - طريقة لاختبار البرمجيات تفحص وظائف التطبيق دون النظر في هيكله أو آليات عمله الداخلية.
- **CWE، Enumeration Weakness Common** (تعداد نقاط الضعف الشائعة) - قائمة مطوّرة من قبل المجتمع لنقاط ضعف أمان البرمجيات الشائعة. وهي بمثابة لغة مشتركة، ومقياس لأدوات أمان البرمجيات، وخط أساس لجهود تحديد نقاط الضعف والتخفيف منها والوقاية منها.
- **Component** (المكوّن) - وحدة برمجية قائمة بذاتها، مع ما يرتبط بها من واجهات القرص والشبكة، تتواصل مع المكونات الأخرى.
- **CSP، Provider Service Credential** (مزود خدمة بيانات الاعتماد) - يُسمّى أيضاً مزود الهوية (IdP) مصدر لبيانات المستخدمين يمكن أن تستخدمه تطبيقات أخرى كمصدر للمصادقة.
- **XSSI، Inclusion Script Cross-Site** (تضمين النصوص البرمجية عبر المواقع) - نوع من هجمات البرمجة النصية عبر المواقع (XSS) يجلب فيه تطبيق الويب شيفرة ضارة من مورد خارجي ويضمّن جزءاً من محتواه.
- **XSS، Scripting Cross-Site** (البرمجة النصية عبر المواقع) - ثغرة أمنية توجد عادةً في تطبيقات الويب وتسمح بحقن نصوص برمجية تُنفّذ من جانب العميل في المحتوى.
- **module Cryptographic** (وحدة التشفير) - العتاد أو البرمجيات أو البرمجيات الثابتة التي تنفّذ خوارزميات التشفير أو تُنشئ مفاتيح التشفير.
- **CSPRNG، generator number pseudo-random secure Cryptographically** (مولّد أعداد شبه عشوائية آمنة تشفيرياً) - مولّد أعداد شبه عشوائية يتمتع بخصائص تجعله مناسباً للاستخدام في التشفير، ويُشار إليه أيضاً باسم مولّد الأعداد العشوائية التشفيري (CRNG).
- **DTLS، Security Layer Transport Datagram** (أمان طبقة النقل لرزم البيانات) - بروتوكول تشفير يوفّر أمان الاتصال عبر اتصال شبكي. يستند إلى بروتوكول TLS لكنه مكيف لحماية البروتوكولات الموجهة للرزم (عادةً عبر UDP). معرف في RFC 9147 لإصدار DTLS 1.3.
- **Trans- Real-time Secure the for Keys Establish to Extension Security Layer Transport Datagram** (آلية لاستخدام مصالحة DTLS لإنشاء مادة المفاتيح لجلسة SRTP. معرفة في RFC 5764).
- **Verification Design** (التحقق من التصميم) - التقييم الفني لمعمارية أمان التطبيق.
- **DAST، Testing Security Application Dynamic** (الاختبار الديناميكي لأمان التطبيقات) - تقنيات مصممة لكشف الظروف التي تدل على وجود ثغرة أمنية في التطبيق أثناء تشغيله.
- **Verification Dynamic** (التحقق الديناميكي) - استخدام أدوات مؤتمتة تستخدم مواقع الثغرات للعثور على المشكلات أثناء تنفيذ التطبيق.
- **FIDO، Online Identity Fast** (الهوية السريعة عبر الإنترنت) - مجموعة من معايير المصادقة تتيح استخدام طرائق مصادقة متنوعة، منها القياسات الحيوية ووحدات النظام الأساسي الموثوق (TPMs) ورموز أمان USB وغيرها.
- **HSM، Module Security Hardware** (وحدة أمان العتاد) - مكوّن عتادي يخزّن مفاتيح التشفير وغيرها من الأسرار بطريقة محمية.
- **(HQL) Language Query Hibernate** - لغة استعلام تشبه في شكلها لغة SQL وتستخدمها مكتبة ORM. Hibernate.
- **(HSTS) Security Transport Strict HTTP** - سياسة توجه المتصفح إلى الاتصال بالنطاق الذي يعيد الترويسة عبر TLS فقط وعند تقديم شهادة صالحة. وتُنشّط باستخدام حقل ترويسة الاستجابة Strict-Transport-Security.
- **(HTTP، Protocol Transfer HyperText)** (بروتوكول نقل النص التشعبي) - بروتوكول تطبيقي لأنظمة المعلومات التشعبية

- الموزعة والتعاونية. وهو أساس تبادل البيانات في شبكة الويب العالمية.
- **SSL/TLS over Protocol Transfer HyperText (HTTPS)** - طريقة لتأمين اتصالات HTTP عن طريق تشفيرها باستخدام أمان طبقة النقل (TLS).
- **IdP، Provider Identity** (مزود الهوية) - يُسمّى أيضاً مزود خدمة بيانات الاعتماد (CSP) في مراجع NIST. كان يوفر مصدراً للمصادقة لتطبيقات أخرى.
- **Timeout Inactivity** (مهلة عدم النشاط) - المدة الزمنية التي يمكن أن تبقى فيها الجلسة نشطة في غياب تفاعل المستخدم مع التطبيق. وهو أحد مكونات انتهاء صلاحية الجلسة.
- **Validation Input** (التحقق من صحة المدخلات) - توحيد مدخلات المستخدم غير الموثوقة إلى صورتها القياسية والتحقق من صحتها.
- **Token Web JSON (JWT)** - يحدّد RFC 7519 معياراً لكائن بيانات JSON. يتكوّن من قسم ترويسة يوضح كيفية التحقق من الكائن، وقسم متن يحتوي على مجموعة من المطالبات، وقسم توقيع يحتوي على توقيع رقمي يمكن استخدامه للتحقق من محتويات قسم المتن. وهو نوع من الرموز المميزة المكتفية بذاتها.
- **LFI، Inclusion File Local** (تضمين الملفات المحلية) - هجوم يستغل إجراءات تضمين الملفات المعرضة للخطر في التطبيق، ما يؤدي إلى تضمين ملفات محلية موجودة بالفعل على الخادم.
- **Code Malicious** (الشفيرة الضارة) - شيفرة تُدخل في التطبيق أثناء تطويره دون علم مالك التطبيق، وتحايل على سياسة الأمان المقصودة للتطبيق. وهي ليست كالبرمجيات الخبيثة مثل الفيروس أو الدودة!
- **Malware** (البرمجيات الخبيثة) - شيفرة قابلة للتنفيذ تُدخل في التطبيق أثناء وقت التشغيل دون علم مستخدم التطبيق أو مسؤوله.
- **MAC، code authentication Message** (رمز مصادقة الرسالة) - مجموع تحقق تشفيري على البيانات، يُحسب بواسطة خوارزمية توليد MAC، ويُستخدم لتوفير ضمان لسلامة البيانات وأصالتها.
- **MFA، authentication Multi-factor** (المصادقة متعددة العوامل) - مصادقة تتضمن عاملين أو أكثر من العوامل الفردية.
- **mTLS، TLS Mutual authentication** (أمان طبقة النقل المتبادل) - انظر TLS client authentication.
- **ORM، Mapping Object-relational** (التعيين الكياني العلائقي) - نظام يُستخدم للسماح بالإشارة إلى قاعدة بيانات علائقية أو جدولية والاستعلام عنها داخل برنامج تطبيقي باستخدام نموذج كائني متوافق مع التطبيق.
- **OTP، Password One-time** (كلمة المرور لمرة واحدة) - كلمة مرور تولّد بشكل فريد لاستخدامها في مناسبة واحدة.
- **OWASP، Project Security Application Worldwide Open** (المشروع العالمي المفتوح لأمان التطبيقات) - المشروع العالمي المفتوح لأمان التطبيقات (OWASP) هو مجتمع عالمي حر ومفتوح يركّز على تحسين أمان برمجيات التطبيقات. ومهمتنا هي جعل أمان التطبيقات "مرئياً"، بحيث يستطيع الأفراد والمؤسسات اتخاذ قرارات مستنيرة بشأن مخاطر أمان التطبيقات. انظر: <https://www.owasp.org/>
- **PBKDF2، 2 Function Derivation Key Password-Based** (دالة اشتقاق المفاتيح المعتمدة على كلمة المرور 2) - خوارزمية خاصة أحادية الاتجاه تُستخدم لإنشاء مفتاح تشفيري قوي من نص مُدخل (مثل كلمة مرور) وقيمة ملح عشوائية إضافية، ويمكن استخدامها بالتالي لزيادة صعوبة كسر كلمة المرور دون اتصال إذا خزنت القيمة الناتجة بدلاً من كلمة المرور الأصلية.
- **PKI، Infrastructure Key Public** (البنية التحتية للمفتاح العام) - ترتيب يربط المفاتيح العامة بهويات الكيانات المقابلة لها. ويُنشأ هذا الربط من خلال عملية تسجيل وإصدار للشهادات لدى سلطة إصدار الشهادات (CA) وبواسطتها.
- **PSTN، Network Telephone Switched Public** (شبكة الهاتف العمومية المبدلة) - شبكة الهاتف التقليدية التي تشمل كلاً من هواتف الخطوط الثابتة والهواتف المحمولة.
- **RTP، Protocol Transport Real-time** و **RTCP، Protocol Control Transport Real-time** - بروتوكولان يُستخدمان معاً لنقل تدفقات الوسائط المتعددة. تستخدمهما حزمة WebRTC معرّفان في RFC 3550.
- **Token Reference** (الرمز المميز المرجعي) - نوع من الرموز المميزة يعمل كمؤشّر أو معرف لحالة أو بيانات وصفية مخزنة على

الخادم، ويُشار إليه أحياناً بالرموز العشوائية أو الرموز المعتمدة. وبخلاف الرموز المكتفية بذاتها، التي تضمّن بعض بياناتها ذات الصلة داخل الرمز نفسه، لا تحتوي الرموز المرجعية على أي معلومات ذاتية، بل تعتمد على الخادم للحصول على السياق. ويكون الرمز المرجعي معرّف جلسة أو يحتوي عليه.

- **RP، Party Relying** (الطرف المعوّل) - عموماً تطبيق يعوّل على مستخدم قد صادق لدى مزوّد مصادقة منفصل. ويعتمد التطبيق على نوع من الرموز المميزة أو مجموعة من التأكيدات الموقّعة التي يوفّرها مزوّد المصادقة ليثق بأن المستخدم هو من يدّعي أنه هو.
- **RFI، Inclusion File Remote** (تضمين الملفات البعيدة) - هجوم يستغل إجراءات التضمين المعرضة للخطر في التطبيق، ما ينتج عنه تضمين ملفات بعيدة.
- **SVG، Graphics Vector Scalable** (الرسوميات المتجهية القابلة للتجسيم) - لغة توصيف قائمة على XML لوصف الرسوميات المتجهية ثنائية الأبعاد.

- **Protocol Control Transport Real-time Secure (SRTCP) و Protocol Transport Real-time Secure (SRTP)** - ملف تعريف لبروتوكولي RTP و RTCP يوفّر دعماً لتشفير الرسائل والمصادقة وحماية السلامة. معرّف في RFC 3711.
- **Architecture Security** (معمارية الأمان) - تجريد لتصميم التطبيق يحدّد ويصف موضع ضوابط الأمان وكيفية استخدامها، ويحدّد ويصف كذلك موضع بيانات المستخدم والتطبيق وحساسيتها.
- **SAML، Language Markup Assertion Security** (معيّار مفتوح لمصادقة الدخول الموحد يستند إلى تمرير تأكيدات موقّعة (كائنات XML عادةً) بين مزوّد الهوية والطرف المعوّل).
- **Configuration Security** (تكوين الأمان) - تكوين وقت التشغيل للتطبيق الذي يؤثر في كيفية استخدام ضوابط الأمان.
- **Control Security** (ضوابط الأمان) - دالة أو مكوّن يجري فحصاً أمنياً (مثل فحص التحويل) أو يؤدي عند استدعائه إلى أثر أمني (مثل توليد سجل تدقيق).

- **SIEM، management event and information Security** (إدارة معلومات الأمان والأحداث) - نظام لكشف التهديدات والامثال وإدارة حوادث الأمان من خلال جمع وتحليل البيانات المتعلقة بالأمان من مصادر مختلفة داخل البنية التحتية لتقنية المعلومات في المؤسسة.

- **Token Self-Contained** (الرمز المميز المكتفي بذاته) - رمز مميز يضمّن سمة واحدة أو أكثر لا تعتمد على حالة مخزّنة في الخادم أو على تخزين خارجي آخر. وتضمن هذه الرموز أصالة سماتها المضمّنة وسلامتها، ما يتيح تبادلًا آمنًا و"عديم الحالة" للمعلومات بين الأنظمة. وتؤمن الرموز المكتفية بذاتها عموماً باستخدام تقنيات تشفيرية، مثل التوقيعات الرقمية أو رموز مصادقة الرسائل (MACs)، لضمان أصالة بياناتها وسلامتها، وفي بعض الحالات سريتها. ومن الأمثلة الشائعة تأكيدات SAML و JWTs.

- **SSRF، Forgery Request Server-side** (تزوير الطلب من جانب الخادم) - هجوم يسيء استخدام وظيفة على الخادم لقراءة موارد داخلية أو تحديثها. يقدّم المهاجم عنوان URL أو يعدّله، لتقرأ الشيفرة العاملة على الخادم أو ترسل إليه بيانات.

- **SDP، Protocol Description Session** (بروتوكول وصف الجلسة) - صيغة رسائل لإعداد جلسة وسائط متعددة (تُستخدم في WebRTC مثلاً). معرّف في RFC 4566.

- **ID Session أو Identifier Session** (معرّف الجلسة) - مفتاح يعرف جلسة ذات حالة مخزّنة في الواجهة الخلفية. وينقل إلى العميل ومنه إما كـ "رمز مرجعي" أو داخله.

- **Token Session** (الرمز المميز للجلسة) - عبارة جامعة تُستخدم في هذا المعيار للإشارة إلى الرمز المميز أو القيمة المستخدمة في آليات الجلسات عديمة الحالة (التي تستخدم رمزاً مكتفياً بذاته) أو آليات الجلسات ذات الحالة (التي تستخدم رمزاً مرجعياً).

- **STUN، NAT for Utilities Traversal Session** - بروتوكول يُستخدم للمساعدة في اجتياز NAT من أجل إنشاء اتصالات نَدّ لندّ. معرّف في RFC 3489.

- **authenticator Single-factor** (مُصادق أحادي العامل) - آلية للتحقق من أن المستخدم مُصادق عليه. وينبغي أن تكون إما شيئاً تعرفه (أسرار محفوظة، كلمات مرور، عبارات مرور، أرقام تعريف شخصية)، أو شيئاً أنت عليه (القياسات الحيوية، بصمة

- الإصبع، مسح الوجه)، أو شيئاً تملكه (رموز، OTP، جهاز تشفيري مثل البطاقة الذكية).
- **SSO، Authentication Sign-on Single** (مصادقة الدخول الموحد) - يحدث هذا عندما يدخل المستخدم إلى تطبيق واحد فيُسجّل دخوله تلقائياً إلى تطبيقات أخرى دون الحاجة إلى إعادة المصادقة. على سبيل المثال، عند الدخول إلى Google، يُسجّل دخول المستخدم تلقائياً إلى خدمات Google الأخرى مثل YouTube و Docs و Gmail.
- **SBOM، materials of bill Software** (قائمة مكونات البرمجيات) - قائمة منظّمة وشاملة بجميع المكونات والوحدات والمكتبات وأطر العمل وغيرها من الموارد اللازمة لبناء تطبيق برمجي أو تجميعه.
- **SCA، Analysis Composition Software** (تحليل تركيب البرمجيات) - مجموعة من التقنيات المصمّمة لتحليل تركيب التطبيق وتبعياته ومكتباته وحزمه بحثاً عن ثغرات أمنية في إصدارات مكونات معينة قيد الاستخدام. ولا ينبغي الخلط بينه وبين تحليل الشيفرة المصدرية الذي يُشار إليه الآن عادةً باسم SAST.
- **SDLC، Ifecycle development Software** (دورة حياة تطوير البرمجيات) - العملية التدريجية التي يُطوّر بها البرنامج من المتطلبات الأولية إلى النشر والصيانة.
- **SQLi، Injection SQL** (حقن SQL) - تقنية حقن شيفرة تُستخدم لمهاجمة التطبيقات المعتمدة على البيانات، حيث تُدرج عبارات SQL ضارة في نقطة إدخال.
- **Mechanism Session Stateful** (آلية الجلسة ذات الحالة) - في آلية الجلسة ذات الحالة، يحتفظ التطبيق بحالة الجلسة في الواجهة الخلفية، وهي تقابل عادةً رمزاً مميزاً للجلسة يُولّد باستخدام مولّد أعداد شبه عشوائية آمنة تشفيرياً (CSPRNG) ويُصدر للمستخدم النهائي.
- **Mechanism Session Stateless** (آلية الجلسة عديمة الحالة) - تُستخدم آلية الجلسة عديمة الحالة رمزاً مميزاً مكتفياً بذاته يُمرّر إلى العملاء، ويحتوي على معلومات الجلسة التي لا تُخزّن بالضرورة داخل الخدمة التي تستقبل الرمز وتتحقق منه. وفي الواقع، ستحتاج الخدمة إلى الوصول إلى بعض معلومات الجلسة (مثل قائمة إبطال JWT لتكون قادرة على إنفاذ ضوابط الأمان المطلوبة).
- **SAST، testing security application Static** (الاختبار الساكن لأمان التطبيقات) - مجموعة من التقنيات المصمّمة لتحليل الشيفرة المصدرية للتطبيق ورمزه البايتي وملفاته الثنائية بحثاً عن ظروف في الكّابة والتصميم تدل على وجود ثغرات أمنية. وتحلّل حلول SAST التطبيق من "الداخل إلى الخارج" وهو في حالة عدم تشغيل.
- **Modeling Threat** (نمذجة التهديدات) - تقنية تتمثّل في تطوير معماريات أمنية متزايدة الدقة لتحديد عناصر التهديد ومناطق الأمان وضوابط الأمان والأصول التقنية والتجارية المهمة.
- **TOCTOU، time-of-use to Time-of-check** (من وقت الفحص إلى وقت الاستخدام) - حالة يفحص فيها التطبيق حالة مورد قبل استخدامه، لكن حالة المورد يمكن أن تتغيّر بين الفحص والاستخدام. وقد يُبطل ذلك نتائج الفحص ويؤدي إلى وضع ينفذ فيه التطبيق إجراءات غير صحيحة بسبب عدم تطابق الحالة.
- **TOTPs، Passwords One-time based Time** (كلمات المرور لمرة واحدة المعتمدة على الوقت) - طريقة لتوليد كلمة مرور لمرة واحدة يكون فيها الوقت الحالي جزءاً من الخوارزمية المستخدمة لتوليد كلمة المرور.
- **authentication client TLS** (مصادقة العميل في TLS)، ويُسمّى أيضاً **TLS Mutual** (mTLS) - في اتصال TLS القياسي، يمكن للعميل استخدام الشهادة التي يوقّرها الخادم للتحقق من هوية الخادم. وعند استخدام مصادقة العميل في TLS، يستخدم العميل أيضاً مفتاحه الخاص وشهادته للسماح للخادم بالتحقق من هوية العميل كذلك.
- **TLS، Security Layer Transport** (أمان طبقة النقل) - بروتوكولات تشفيرية توفّر أمان الاتصال عبر اتصال شبكي.
- **NAT around Relays Using Traversal** (TURN) - امتداد لبروتوكول STUN يستخدم خادم TURN كمرحّل عندما لا يمكن إنشاء اتصالاتٍ ندّ لندّ مباشرة. معرّف في RFC 8656.
- **TEE، environment execution Trusted** (بيئة التنفيذ الموثوقة) - بيئة معالجة معزولة يمكن فيها تنفيذ التطبيقات بأمان بصرف النظر عن بقية النظام.

- **TPM، Module Platform Trusted** وحدة النظام الأساسي الموثوق - نوع من وحدات أمان العتاد (HSM) يكون عادةً مرفقاً بمكوّن عتادي أكبر مثل اللوحة الأم، ويعمل كـ "جذر الثقة" لذلك النظام.
- **Layer Service Trusted** (طبقة الخدمة الموثوقة) - أي نقطة إنفاذ موثوقة للضوابط، مثل خدمة مصغرة، أو واجهة برمجية تطبيقات بلا خادم، أو جانب الخادم، أو واجهة برمجية تطبيقات موثوقة على جهاز عميل يمتلك إقلاعاً آمناً، أو واجهات برمجية تطبيقات لشركاء أو خارجية، وما إلى ذلك. والموثوقية تعني عدم وجود قلق من أن يتكّن مستخدم غير موثوق من تجاوز الطبقة أو الضوابط المنفّذة فيها أو تخطّيها.
- **URI، Identifier Resource Uniform** معرّف الموارد الموحد - سلسلة محارف فريدة تعرّف مورداً، مثل صفحة ويب أو عنوان بريد أو أماكن.
- **URL، Locator Resource Uniform** محدّد موقع الموارد الموحد - سلسلة تحدّد موقع مورد على الإنترنت.
- **UUID، Identifier Unique Universally** المعرّف الفريد عالمياً - رقم مرجعي فريد يُستخدم كعرّف في البرمجيات.
- **Verfier** (المدقق) - الشخص أو الفريق الذي يراجع تطبيقاً مقابل متطلبات معيار OWASP للتحقق من أمان التطبيقات.
- **WebRTC، Communication Real-Time Web** اتصالات الويب في الوقت الحقيقي - حزمة بروتوكولات وواجهات برمجية تطبيقات ويب مرتبطة بها تُستخدم لنقل تدفقات الوسائط المتعددة في تطبيقات الويب، عادةً في سياق المؤتمرات المرئية. تستند إلى STUN/TURN و SDP و DTLS و SRTCP و SRTP.
- **TLS over WebSocket (WSS)** - ممارسة تأمين اتصالات WebSocket عن طريق تشغيل WebSocket فوق بروتوكول TLS.
- **WYSIWYG، Get You What Is See You What** ما تراه هو ما تحصل عليه - نوع من محرّرات المحتوى الغني يظهر كيف سيبدو المحتوى فعلياً عند عرضه بدلاً من إظهار الشيفرة المستخدمة للتحكّم في العرض.
- **Certificate X.509** (شهادة X.509 - شهادة X.509 هي شهادة رقمية تستخدم معيار البنية التحتية للمفتاح العام (PKI) الدولي X.509 المعتمد على نطاق واسع للتحقق من أن مفتاحاً عاماً ينتمي إلى هوية المستخدم أو الحاسوب أو الخدمة الواردة في الشهادة.
- **XXE، Entity eXternal XML** كيان XML الخارجي - نوع من كيانات XML يمكنه الوصول إلى محتوى محلي أو بعيد عبر معرّف نظام معن. وقد يؤدي ذلك إلى هجمات حقن مختلفة.

الملحق ب: المراجع

من المرجّح أن تكون مشاريع OWASP التالية مفيدة لمستخدمي هذا المعيار ومتبنّيه:

مشاريع OWASP الأساسية

1. <https://owasp.org/www-project-top-ten/> Project: 10 Top OWASP
2. <https://owasp.org/www-project-web-security-testing-guide/> Guide: Testing Security Web OWASP
3. <https://owasp.org/www-project-proactive-controls/> Controls: Proactive OWASP
4. <https://owasp.org/www-project-samm/> (SAMM): Model Maturity Assurance Software OWASP
5. <https://owasp.org/www-project-secure-headers/> Project: Headers Secure OWASP

مشروع سلسلة الأوراق المرجعية من OWASP

هذا المشروع يضم عدة أوراق مرجعية ذات صلة بمواضيع مختلفة في معيار التحقق من أمان التطبيقات.

وهناك تخطيط إلى معيار التحقق من أمان التطبيقات يمكن الاطلاع عليه هنا: <https://cheatsheetseries.owasp.org/IndexASVS.h.tml>

المشاريع المتعلقة بأمان الأجهزة المحمولة

1. <https://owasp.org/www-project-mobile-security/> Project: Security Mobile OWASP
2. <https://owasp.org/www-project-mobile-top-10/> Risks: 10 Top Mobile OWASP
3. <https://owasp.org/www-project-mobile-security-testing-guide/> Standard: Verification Security Application Mobile and Guide Testing Security Mobile OWASP

مشاريع OWASP المتعلقة بإترنت الأشياء

1. <https://owasp.org/www-project-internet-of-things/> Project: Things of Internet OWASP

مشاريع OWASP الخاصة بالحوسبة بلا خادم

1. <https://owasp.org/www-project-serverless-top-10/> Project: Serverless OWASP

أخرى

وبالمثل، من المرجح أن تكون المواقع التالية مفيدة لمستخدمي هذا المعيار ومتبنّيه

1. <https://github.com/danielmiessler/SecLists> Github: SecLists
2. <https://cwe.mitre.org/> Enumeration: Weakness Common MITRE
3. <https://www.pcisecuritystandards.org/> Council: Standards Security PCI
4. https://www.pcisecuritystandards.org/documents/PCI_DSS_v3-2-1.pdf Procedures: Assessment Security and Requirements v3.2.1 (DSS) Standard Security Data PCI
5. https://www.pcisecuritystandards.org/documents/PCI-Secure-Software-Standard-v1_0.pdf Procedures: Assessment and Requirements Software Secure - Framework Security Software PCI
6. https://www.pcisecuritystandards.org/documents/PCI-Secure-SLC-Standard-v1_0.pdf Procedures: Assessment and Requirements SLC) (Secure Lifecycle Software Secure PCI
7. <https://github.com/BlazingWind/OWASP-ASVS-4.0-testing-guide> Guide Testing 4.0 ASVS OWASP

الملحق ج: معايير التشفير

يتجاوز فصل "التشفير" مجرد تحديد الممارسات الفضلى. فهو يهدف إلى تعزيز فهم مبادئ التشفير والتشجيع على تبني طرائق أمنية أكثر صموداً وحداثاً. ويوفّر هذا الملحق معلومات تقنية مفصّلة عن كل متطلب، مكمّلاً المعايير الشاملة المبينة في فصل "التشفير".

يحدّد هذا الملحق مستوى الاعتماد لآليات التشفير المختلفة:

- الآليات المعتمدة (A) يمكن استخدامها في التطبيقات.

- الآليات القديمة (L) لا ينبغي استخدامها في التطبيقات لكن قد تبقى مستخدمة للتوافق مع التطبيقات أو الشيفرات القديمة القائمة فقط. ومع أن استخدام هذه الآليات لا يُعدّ حالياً ثغرة في حد ذاته، فينبغي استبدالها بآليات أكثر أماناً وأصمد للمستقبل في أسرع وقت ممكن.
- الآليات الممنوعة (D) يجب ألا تُستخدم لأنها تُعدّ حالياً مكسورة أو لا توفر أماناً كافياً.

وقد تتجاوز هذه القائمة في سياق تطبيق معيّن لأسباب متنوعة منها:

- التطورات الجديدة في مجال التشفير؛
- الامتثال للتنظيمات.

جرد التشفير وتوثيقه

يوفر هذا القسم معلومات إضافية عن V11.1 جرد التشفير وتوثيقه.

من المهم التأكد من أن جميع الأصول التشفيرية، مثل الخوارزميات والمفاتيح والشهادات، تُستكشف وتُجرّد وتُقيم بانتظام. وبالنسبة إلى المستوى 3، ينبغي أن يشمل ذلك استخدام الفحص الساكن والديناميكي لاستكشاف استخدام التشفير في التطبيق. وقد تساعد أدوات مثل SAST وDAST في ذلك، لكن من المحتمل أن تكون هناك حاجة إلى أدوات مخصصة للحصول على تغطية أشمل. ومن أمثلة الأدوات المجانية:

- python in written eBPF, using - Monitor Cryptography Network - CryptoMon
- Outputs CodeQL from CBOMs Comprehensive Generating Tool: Forge Cryptobom

القوى المكافئة لمعاملات التشفير

ترد القوى الأمنية النسبية لأنظمة تشفير متنوعة في هذا الجدول (من NIST SP 800-57 Part 1، ص. 71):

المنحنى الإهليلجي	تحليل الأعداد الصحيحة إلى عوامل	الحقل المنتهي	خوارزميات المفاتيح المتناظر	القوة الأمنية
160-223 = f	1024 = k	160 = N 1024 = L	2TDEA	80 =>
224-255 = f	2048 = k	224 = N 2048 = L	3TDEA	112
256-383 = f	3072 = k	256 = N 3072 = L	AES-128	128
384-511 = f	7680 = k	384 = N 7680 = L	AES-192	192
+512 = f	15360 = k	512 = N 15360 = L	AES-256	256

أمثلة على التطبيقات:

- تشفير الحقل المنتهي: DSA وFFDH وMQV
- تشفير تحليل الأعداد الصحيحة إلى عوامل: RSA
- تشفير المنحنيات الإهليلجية: ECDSA وEdDSA وECDH وMQV

ملاحظة: يفترض هذا القسم عدم وجود حاسوب كمومي؛ فإذا وُجد مثل هذا الحاسوب، فلن تبقى التقديرات في الأعمدة الثلاثة الأخيرة صالحة.

القيم العشوائية

يوفّر هذا القسم معلومات إضافية عن V11.5 القيم العشوائية.

الحالة	ملاحظات	الإصدار/المرجع	الاسم
A	stream. ChaCha20 Utilizing iOS in Found and SecRandomCopyBytes Random Secure Android settings correct the with each. to provided	also , (Oct +4.8 Linux and Android, iOS, in found POSIX Linux-based other on Based systems. operating RFC7539	/dev/random
A	entropy high-quality, Provides hardware from sources randomness	for file special kernel's Linux data random providing	/dev/urandom
A	common in used As as such implementations, API CNG Windows by set BCryptGenRandom .BCRYPT_RNG_ALGORITHM	SP800-90A NIST	AES-CTR-DRBG
A		SP800-90A NIST	HMAC-DRBG
A		SP800-90A NIST	Hash-DRBG
A	bytes random secure Provides kernel's the from directly a with source entropy minimal and straightforward and modern more It's API, with associated pitfalls avoids APIs. older	Linux in available ,OpenBSD macOS and +2.25 glibc +10.12	getentropy()

يجب أن تكون دالة التليد الأساسية المستخدمة مع HMAC-DRBG أو Hash-DRBG معتمدة لهذا الاستخدام.

خوارزميات التشفير

يوفّر هذا القسم معلومات إضافية عن V11.3 خوارزميات التشفير.

خوارزميات التشفير المعتمدة مدرجة بترتيب التفضيل.

الحالة	المرجع	خوارزميات المفاتيح المتناظر
A	197 FIPS	AES-256
A	specfication 20 Salsa	Salsa20
A	Draft XChaCha20	XChaCha20
A	nonce Salsa20 the Extending	XSalsa20
A	8439 RFC	ChaCha20
A	197 FIPS	AES-192
L	197 FIPS	AES-128
D		2TDEA
D		(3DES/3DEA) TDEA
D		IDEA
D		RC4
D		Blowfish
D		ARC4
D		DES

أنماط تشفير AES

يمكن استخدام تشفيرات الكتل، مثل AES، مع أنماط تشغيل مختلفة. وكثير من أنماط التشغيل، مثل كتّاب الشيفرة الإلكتروني (ECB)، غير آمن ويجب ألا يُستخدم. أما نمط جالوا/العداد (GCM) ونمط العداد مع رمز مصادقة رسالة تسلسل كتل التشفير (CCM) فيوفران تشفيراً مصادقاً عليه وينبغي استخدامهما في التطبيقات الحديثة. الأنماط المعتمدة مدرجة بترتيب التفضيل.

التقيد	الحالة	المرجع	مصادق عليه	النمط
	A	SP NIST 800-38D	Yes	GCM
	A	SP NIST 800-38C	Yes	CCM
	L	SP NIST 800-38A	No	CBC
	D		Yes	CCM-8
	D		No	ECB

النمط	مصادَق عليه	المرجع	الحالة	القيّد
CFB	No		D	
OFB	No		D	
CTR	No		D	

ملاحظات:

- يجب أن تكون جميع الرسائل المشفرة مصادَقاً عليها. ولأي استخدام لنمط CBC يجب أن تكون هناك خوارزمية MAC تليدية مرتبطة به للتحقق من الرسالة. وعموماً، يجب تطبيق ذلك بطريقة التشفير ثم التليد (لكن TLS 1.2 يستخدم التليد ثم التشفير بدلاً من ذلك). وإذا لم يكن من الممكن ضمان ذلك، فيجب ألا يُستخدم CBC. والتطبيق الوحيد الذي يُسمح فيه بالتشفير دون خوارزمية MAC هو تشفير الأقراص.
- في حال استخدام CBC، يجب ضمان أن التحقق من الحشو يُنفَّذ في زمن ثابت.
- عند استخدام CCM-8، لا تمتلك وسمة MAC سوى 64 بتاً من الأمان. وهذا لا يتوافق مع المتطلب 6.2.9 الذي يقتضي 128 بتاً من الأمان على الأقل.
- يُعدّ تشفير الأقراص خارج نطاق معيار التحقق من أمان التطبيقات. ولذلك لا يُدرج هذا الملحق أي طريقة معتمدة لتشفير الأقراص. ولهذا الاستخدام، يُقبل عادةً التشفير دون مصادقة وتُستخدم عادةً الأنماط XTS و XEX و LRW.

تغليف المفاتيح

تغليف المفاتيح التشفيري (وما يقابله من فك التغليف) طريقة لحماية مفتاح قائم بتغليفه (أي تطويقه) باستخدام آلية تشفير إضافية بحيث لا يكون المفتاح الأصلي مكشوفاً بجلاء، مثلاً أثناء النقل. ويُشار إلى هذا المفتاح الإضافي المستخدم لحماية المفتاح الأصلي بمفتاح التغليف. وقد تُنفَّذ هذه العملية عندما يكون من المرغوب حماية المفاتيح في أماكن تُعدّ غير موثوقة، أو إرسال مفاتيح حساسة عبر شبكات غير موثوقة أو داخل التطبيقات. لكن ينبغي إيلاء اعتبار جدي لفهم طبيعة المفتاح الأصلي (مثل هويته والغرض منه) قبل الإقدام على إجراء تغليف/فك تغليف، إذ قد تكون لذلك تبعات على الأنظمة أو التطبيقات المصدر والمهدف على حد سواء من حيث الأمان، وخصوصاً الامتثال، الذي قد يشمل مسارات تدقيق لوظيفة المفتاح (مثل التوقيع) وكذلك التخزين الملائم للمفاتيح.

وعلى وجه التحديد، يجب استخدام AES-256 لتغليف المفاتيح، وفقاً لـ 800-38F SP NIST ومع مراعاة الأحكام الاستشرافية ضد التهديد الكومي. وأنماط التشفير التي تستخدم AES هي التالية، بترتيب التفضيل:

الحالة	المرجع	تغليف المفاتيح
A	800-38F SP NIST	KW
A	800-38F SP NIST	KWP

ويمكن استخدام AES-192 و AES-128 إذا اقتضت حالة الاستخدام ذلك، لكن يجب توثيق مبرر ذلك في جرد التشفير الخاص بالجهة.

التشفير المصادق عليه

باستثناء تشفير الأقراص، يجب حماية البيانات المشفرة من التعديل غير المصرّح به باستخدام صورة ما من مخططات التشفير المصادق عليه (AE)، وعادةً باستخدام مخطط التشفير المصادق عليه مع البيانات المرتبطة (AEAD). وينبغي للتطبيق أن يستخدم مخطط AEAD معتمدًا تفضيلاً. وقد يجمع بدلاً من ذلك بين مخطط تشفير معتمد وخوارزمية MAC معتمدة ببنية التشفير ثم MAC. ولا يزال التليبد ثم التشفير مسموحاً به للتوافق مع التطبيقات القديمة. وهو مستخدم في TLS v1.2 مع مجموعات التشفير القديمة.

الحالة	المرجع	آلية AEAD
A	800-38D SP	AES-GCM
A	800-38C SP	AES-CCM
A	7539 RFC	ChaCha-Poly1305
A	(v1.1) Algorithm Encryption Authenticated Fast A AEGIS:	AEGIS-256
A	(v1.1) Algorithm Encryption Authenticated Fast A AEGIS:	AEGIS-128
A	(v1.1) Algorithm Encryption Authenticated Fast A AEGIS:	AEGIS-128L
A		Encrypt-then-MAC
L		MAC-then-encrypt

دوالّ التليبد

يوفّر هذا القسم معلومات إضافية عن V11.4 التليبد والدوالّ المبنية على التليبد.

دوالّ التليبد لحالات الاستخدام العامة

يسرد الجدول التالي دوالّ التليبد المعتمدة في حالات الاستخدام التشفيري العامة مثل التوقيعات الرقمية:

- توفّر دوالّ التليبد المعتمدة مقاومة قوية للتصادم وهي ملائمة للتطبيقات عالية الأمان.
- توفّر بعض هذه الخوارزميات مقاومة قوية للهجمات عند استخدامها مع إدارة سليمة لمفاتيح التشفير، ولذلك فهي معتمدة إضافةً إلى ذلك لدوالّ HMAC و KDF و RBG.
- دوالّ التليبد التي يقل طول مخرّجها عن 254 بتاً لا تمتلك مقاومة كافية للتصادم ويجب ألا تُستخدم للتوقيع الرقمي أو غيره من التطبيقات التي تقتضي مقاومة التصادم. أما للاستخدامات الأخرى، فقد تُستخدم للتوافق والتحقق مع الأنظمة القديمة فقط، لكن يجب ألا تُستخدم في التصميم الجديدة.

دالة التلييد	المرجع	الحالة	القيود
SHA3-512	202 FIPS	A	
SHA-512	180-4 FIPS	A	
SHA3-384	202 FIPS	A	
SHA-384	180-4 FIPS	A	
SHA3-256	202 FIPS	A	
SHA-512/256	180-4 FIPS	A	
SHA-256	180-4 FIPS	A	
SHAKE256	202 FIPS	A	
BLAKE2s	as fast smaller, simpler, BLAKE2: MD5	A	
BLAKE2b	as fast smaller, simpler, BLAKE2: MD5	A	
BLAKE3	fast function, one BLAKE3 everywhere	A	
SHA-224	180-4 FIPS	L	KDF, HMAC, for suitable Not signatures digital RBG,
SHA-512/224	180-4 FIPS	L	KDF, HMAC, for suitable Not signatures digital RBG,
SHA3-224	202 FIPS	L	KDF, HMAC, for suitable Not signatures digital RBG,
SHA-1	6194 RFC & 3174 RFC	L	KDF, HMAC, for suitable Not signatures digital RBG,
length) (any CRC		D	
MD4	1320 RFC	D	
MD5	1321 RFC	D	

دوالّ التلييد لتخزين كلمات المرور

لتلييد كلمات المرور بأمان، يجب استخدام دوالّ تلييد مخصّصة. وتخفّف خوارزميات التلييد البطيء هذه من هجمات القوة الغاشمة وهجمات القواميس بزيادة الصعوبة الحسابية لكسر كلمات المرور.

KDF	المرجع	المعاملات المطلوبة	الحالة
argon2id	9106 RFC	1 = p MiB), 46) 47104 =< m :1 = t	A
		1 = p MiB), 19) 19456 =< m :2 = t	A
		= p MiB), 12) 12288 =< m :3 =< t	A
		1	
scrypt	7914 RFC	8 = r MiB), 128) 17^2 =< N :1 = p	A
		8 = r MiB), 64) 16^2 =< N :2 = p	A
		8 = r MiB), 32) 15^2 =< N :3 =< p	A
bcrypt	Future-Adaptable A Scheme Password	10 =< cost	A
PBKDF2-HMAC-SHA-512	FIPS ,800-132 SP NIST 180-4	210,000 =< iterations	A
PBKDF2-HMAC-SHA-256	FIPS ,800-132 SP NIST 180-4	600,000 =< iterations	A
PBKDF2-HMAC-SHA-1	FIPS ,800-132 SP NIST 180-4	1,300,000 =< iterations	L

ويمكن استخدام دوالّ اشتقاق المفاتيح المعتمدة القائمة على كلمات المرور لتخزين كلمات المرور.

دوالّ اشتقاق المفاتيح (KDFs)

دوالّ اشتقاق المفاتيح العامة

KDF	المرجع	الحالة
HKDF	5869 RFC	A
PRF 1.2 TLS	5248 RFC	L
KDFs MD5-based	1321 RFC	D
KDFs SHA-1-based	6194 RFC & 3174 RFC	D

دوالّ اشتقاق المفاتيح القائمة على كلمات المرور

الحالة	المعاملات المطلوبة	المرجع	KDF
A	$1 = p \text{ MiB}), 46) 47104 \leq m : 1 = t$	9106 RFC	argon2id
A	$1 = p \text{ MiB}), 19) 19456 \leq m : 2 = t$		
A	$8 = r \text{ MiB}), 128) 17^2 \leq N : 1 = p$	7914 RFC	scrypt
A	$8 = r \text{ MiB}), 64) 16^2 \leq N : 2 = p$		
A	$8 = r \text{ MiB}), 32) 15^2 \leq N : 3 \leq p$		
A	210,000 $\leq$ iterations	FIPS ,800-132 SP NIST 180-4	PBKDF2-HMAC-SHA-512
A	600,000 $\leq$ iterations	FIPS ,800-132 SP NIST 180-4	PBKDF2-HMAC-SHA-256
L	1,300,000 $\leq$ iterations	FIPS ,800-132 SP NIST 180-4	PBKDF2-HMAC-SHA-1

آليات تبادل المفاتيح

يوفر هذا القسم معلومات إضافية عن V11.6 تشفير المفتاح العام.

مخططات تبادل المفاتيح

يجب ضمان قوة أمنية قدرها 112 بتاً أو أكثر لجميع مخططات تبادل المفاتيح، ويجب أن يتبع تنفيذها اختيارات المعاملات الواردة في الجدول التالي.

الحالة	للتوجيه التامة السرية	المجال معاملات	المخطط
A	Yes	$L \leq 3072 \text{ \& } N \leq 256$	Finite Field Diffie-Hellman (FFDH)
A	Yes	$f \leq 256-383$	Elliptic Curve Diffie-Hellman (ECDH)
D	No		Encrypted key transport with RSA-PKCS#1 v1.5

حيث المعاملات التالية هي:

- k هو حجم المفتاح لمفتاح RSA.
- L هو حجم المفتاح العام و N هو حجم المفتاح الخاص لتشفير الحقل المنتهي.
- f هو نطاق أحجام المفاتيح لتشفير المنحنيات الإهليلجية (ECC).

ويجب ألا يستخدم أي تنفيذ جديد أي مخطط غير متوافق مع NIST SP 800-56A B و NIST SP 800-77. وعلى وجه التحديد، يجب ألا يُستخدم IKEv1 في الإنتاج.

مجموعات ديفي-هيلمان

المجموعات التالية معتمدة لتنفيذات تبادل المفاتيح بطريقة ديفي-هيلمان. والقوى الأمنية موثقة في NIST SP 800-56A، الملحق د، وفي NIST SP 800-57 Part 1 Rev.5.

المجموعة	الحالة
P-224, secp224r1	A
P-256, secp256r1	A
P-384, secp384r1	A
P-521, secp521r1	A
K-233, sect233k1	A
K-283, sect283k1	A
K-409, sect409k1	A
K-571, sect571k1	A
B-233, sect233r1	A
B-283, sect283r1	A
B-409, sect409r1	A
B-571, sect571r1	A
Curve448	A
Curve25519	A
MODP-2048	A
MODP-3072	A
MODP-4096	A
MODP-6144	A
MODP-8192	A
ffdhe2048	A
ffdhe3072	A
ffdhe4096	A
ffdhe6144	A
ffdhe8192	A

رموز مصادقة الرسائل (MAC)

رموز مصادقة الرسائل (MACs) بنى تشفيرية تُستخدم للتحقق من سلامة الرسالة وأصالتها. يأخذ رمز MAC رسالة ومفتاحاً سرّياً كمدخلات وينتج وسمة ثابتة الحجم (قيمة MAC) وتُستخدم رموز MAC على نطاق واسع في بروتوكولات الاتصال الآمن (مثل TLS/SSL) لضمان أن الرسائل المتبادلة بين الأطراف أصيلة وسليمة.

خوارزمية MAC	المرجع	الحالة
HMAC-SHA-256	198-1 FIPS & 2104 RFC	A
HMAC-SHA-384	198-1 FIPS & 2104 RFC	A
HMAC-SHA-512	198-1 FIPS & 2104 RFC	A
KMAC128	800-185 SP NIST	A
KMAC256	800-185 SP NIST	A
mode) (keyed_hash BLAKE3	everywhere fast function, one BLAKE3	A
AES-CMAC	800-38B SP NIST & 4493 RFC	A
AES-GMAC	800-38D SP NIST	A
Poly1305-AES	code message-authentication Poly1305-AES The	A
HMAC-SHA-1	198-1 FIPS & 2104 RFC	L
HMAC-MD5	1321 RFC	D

التوقيعات الرقمية

يجب أن تستخدم مخططات التوقيع أحجام مفاتيح ومعاملات معتمدة وفق 1 Part 800-57 SP NIST.

خوارزمية التوقيع	المرجع	الحالة
Ed448) (Ed25519, EdDSA	8032 RFC	A
Curve448) (Curve25519, XEdDSA	XEdDSA	A
P-521) P-384, (P-256, ECDSA	186-4 FIPS	A
RSA-RSSA-PSS	8017 RFC	A
v1.5 RSA-SSA-PKCS#1	8017 RFC	D
size) key (any DSA	186-4 FIPS	D

معايير التشفير ما بعد الكومي

يجب أن تكون تنفيذات التشفير ما بعد الكومي متوافقة مع 205/204/FIPS-203 إذ لا يوجد بعد سوى قدر ضئيل من الشيفرات المحصّنة أو المراجع التنفيذية. <https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finalized-post-quantum-encryption-standards>

طريقة اتفاق المفاتيح الهجينة ما بعد الكومية المقترحة mlkem768x25519 ل TLS مدعومة من متصفحات رئيسية مثل Firefox release 132 و Chrome release 131. ويمكن استخدامها في بيئات الاختبار التشفيري أو عند توافرها في مكتبات معتمدة صناعياً أو حكومياً.

الملحق د: التوصيات

مقدمة

أثناء إعداد الإصدار 5.0 من معيار التحقق من أمان التطبيقات، (ASVS) اتضح أن هناك عدداً من البنود القائمة والمقترحة حديثاً التي لا ينبغي إدراجها كمتطلبات في الإصدار 5.0. وقد يكون ذلك لأنها لم تكن داخل نطاق معيار التحقق من أمان التطبيقات وفق تعريف الإصدار 5.0، أو بدلاً من ذلك لأنه رُئي أنها، وإن كانت فكرة جيدة، لا يمكن جعلها إلزامية. ولعدم الرغبة في فقدان كل هذه البنود تماماً، فقد ضُم بعضها في هذا الملحق.

آليات موصى بها وداخلة في النطاق

البنود التالية داخلة في نطاق معيار التحقق من أمان التطبيقات. ولا ينبغي جعلها إلزامية، لكن يُوصى بقوة بالنظر فيها كجزء من تطبيق آمن.

- ينبغي توفير مقياس لقوة كلمة المرور لمساعدة المستخدمين على تعيين كلمة مرور أقوى.
- أنشئ ملف security.txt متاحاً للعموم في الجذر أو في مجلد well-known. انلخص بالتطبيق، يحدّد بوضوح رابطاً أو عنوان بريد إلكتروني ليتصل الناس بالمالكين بشأن المشكلات الأمنية.
- ينبغي إنفاذ التحقق من صحة المدخلات من جانب العميل إضافةً إلى التحقق في طبقة خدمة موثوقة، إذ يوفر ذلك فرصة جيدة لاكتشاف تجاوز أحدهم للضوابط من جانب العميل في محاولة لمهاجمة التطبيق.
- امنع ظهور الصفحات الحساسة والتي يمكن الوصول إليها عن غير قصد في محركات البحث باستخدام ملف robots.txt أو ترويسة الاستجابة X-Robots-Tag أو وسم robots في html.
- عند استخدام GraphQL، نفّذ منطق التحويل في طبقة منطق العمل بدلاً من طبقة GraphQL أو المُحلِّل، لتجنّب الحاجة إلى معالجة التحويل في كل واجهة منفصلة.

المراجع:

- RFC the to link a including security.txt on information More

مبادئ أمان البرمجيات

كانت البنود التالية موجودة سابقاً في معيار التحقق من أمان التطبيقات لكنها ليست متطلبات في الحقيقة. بل هي مبادئ ينبغي مراعاتها عند تنفيذ ضوابط الأمان، والتي يؤدي اتباعها إلى ضوابط أكثر متانة. وتشمل ما يلي:

- ينبغي أن تكون ضوابط الأمان مركزية وبسيطة (اقتصاد التصميم) وآمنة على نحو قابل للتحقق وقابلة لإعادة الاستخدام. وهذا ينبغي أن يمنع الضوابط المكررة أو المفقودة أو غير الفعّالة.
- استخدم، حيثما أمكن، تنفيذات ضوابط أمان مكتوبة مسبقاً ومدروسة جيداً بدلاً من الاعتماد على تنفيذ الضوابط من الصفر.
- من الأفضل استخدام آلية واحدة للتحكم في الوصول للوصول إلى البيانات والموارد المحمية. وينبغي أن تمرّ جميع الطلبات عبر هذه الآلية الواحدة لتجنّب النسخ واللصق أو المسارات البديلة غير الآمنة.
- يُعدّ التحكم في الوصول المبني على السمات أو الميزات نمطاً موصى به، تتحقق فيه الشيفرة من تحويل المستخدم لميزة أو عنصر بيانات بدلاً من التحقق من دوره فقط. ومع ذلك ينبغي أن تُخصّص الصلاحيات باستخدام الأدوار.

عمليات أمان البرمجيات

هناك عدد من العمليات الأمنية التي أُزيلت من معيار التحقق من أمان التطبيقات 5.0 لكنها لا تزال فكرة جيدة. وقد يكون مشروع SAMM OWASP مصدراً جيداً لمعرفة كيفية تنفيذ هذه العمليات بفعالية. وتشمل البنود التي كانت موجودة سابقاً في معيار التحقق من أمان التطبيقات ما يلي:

- تحقق من استخدام دورة حياة آمنة لتطوير البرمجيات تعالج الأمان في جميع مراحل التطوير.
- تحقق من استخدام نمذجة التهديدات لكل تغيير في التصميم أو تخطيط لدورة عمل، لتحديد التهديدات والتخطيط للتدابير المضادة وتيسير الاستجابات الملائمة للمخاطر وتوجيه اختبار الأمان.
- تحقق من أن جميع قصص المستخدم والميزات تتضمن قيوداً أمنية وظيفية، مثل "كستخدم، ينبغي أن أكون قادراً على عرض ملفي الشخصي وتحريره. وينبغي ألا أكون قادراً على عرض ملف أي شخص آخر أو تحريره".
- تحقق من توافر قائمة تحقق للبرمجة الآمنة أو متطلبات أمنية أو دليل أو سياسة لجميع المطوّرين والمختبرين.
- تحقق من وجود عملية مستمرة للتأكد من أن الشيفرة المصدّرة للتطبيق خالية من الأبواب الخلفية والشيفرة الضارة (مثل هجمات السلاحي والقنابل المنطقية والقنابل الزمنية) والميزات غير الموثقة أو الخفية (مثل بيض الفصح وأدوات التنقيح غير الآمنة). والامتثال لهذا القسم غير ممكن دون وصول كامل إلى الشيفرة المصدّرة، بما في ذلك مكتبات الأطراف الثالثة، ولذلك فهو على الأرجح مناسب فقط للتطبيقات التي تتطلب أعلى مستويات الأمان.
- تحقق من وجود آليات لكشف انحراف التكوين في البيئات المنشورة والاستجابة له. وقد يشمل ذلك استخدام بنية تحتية غير قابلة للتغيير أو إعادة نشر مؤتمتة من خط أساس آمن أو أدوات لكشف الانحراف تقارن الحالة الراهنة بالتكوينات المعتمدة.
- تحقق من إجراء تحسين التكوين على جميع منتجات ومكتبات وأطر وخدمات الأطراف الثالثة وفقاً لتوصيات كل منها.

المراجع:

- Sheet Cheat Modeling Threat OWASP
- modeling Threat OWASP
- Project Model Maturity Assurance Software OWASP
- SDL Microsoft

الملحق هـ - المساهمون

نعرب عن امتناننا لإسهامات الأشخاص التالية أسماؤهم، الذين علّقوا أو فتحوا طلبات دمج منذ إصدار معيار التحقق من أمان التطبيقات 4.0.0.

وإذا كنت على علم بأي أخطاء أو كنت ترغب في ظهور اسمك بصورة مختلفة، فيرجى إخبارنا.

(sydseter) Sydseter Johan	(flservin) servin luis	Dovydkov Oleksii (oleksiidov)	Masahiro IZUKA (maizuka)
(jsulinski) Sulinski James	(ThunderSon) Saad Eli	kkshitish9	Stock der van Andrew (vanderaj)
(kingthorin) M Rick	(Bankde) Eakasit Bankde	Gargiullo Michael (mgargiullo)	Dunant Raphael (Racater)
(cesarkohl) Kohl Cesar	inaz0	Bruenner Joerg (JoergBruenner)	Deatherage David (securitydave)
(yosignals) Carroll John	(jimfenton) Fenton Jim	(M4tteoP) Pace Matteo	gioria Sebastien (SPoint42)
Baan der van Steven (vdbaan)	Choi Bonghwan Jeremy (jeremychoi)	craig-shony	Sirigu Riccardo (ricsirigu)
(tw2as) Wrobel Tomasz	Dubeshko Alena (belalena)	Green Rafael (RafaelGreen1)	mjang-cobalt
clallier94	(kwwall) Wall W. Kevin	Sherman Jordan / jsherm-fwdsec) (deleterepo	Rauner Ingo (ingo-rauner)
(drwetter) Wetter Dirk	Zioni Moshe (moshe-apiiro)	Dwyer Patrick (coderpatros)	Clarke David (davidclarke-au)
Ogasa Takaharu (takaharuogasa)	Yakovets Arkadii (arkid15r)	Saburi Motoyasu (motoyasu-saburi)	leirn
wet-certitude	timhemel	Thornton RL (thornshadow99)	Bandt Thomas (aspnetde)
(roelstorms) Storms Roel	Willemsen Jeroen (commjoen)	anonymous-31	Safiullah Kamran (deFr0ggy)
Springett Steve (stevespringett)	(northdpole) Spyros	(hansphp) Herrera Hans	Marx314
CarlosAllendes	(yruss972) Russ Yonah	Maijers Sander (sanmai-NL)	Bretschneider Luboš (bretik)
Sarafianou Eva (esarafianou)	ataseren	(Sc00bz) Thomas Steve	RIGHETTO Dominique (righettod)
Baan der van Steven (svdb-ncc)	Vacarella Michael (Afi4thah)	Kisasondi Tonimir (tkisason)	Streichsbier Stefan (streichsbaer)
hi-unc1e	(starbuck3000) sb3k	mario-platt	(devd) Akhawe Devdatta

Gissing Michael (scolytus)	(thatsjet) Anderson Jet	Wichers Dave (davewichers)	Schnittger Jonny (JonnySchnittger)
(silviavali) Väli Silvia	jackgates73	1songb1rd	(timurozkul) - Timur
Heyes Gareth (hackvertor)	appills	suvikaartinen	(chaals) chaals
DanielPharos (AtlasHackert)	(wilflarrell) Farrell will	Vasiljeva Alina (avasiljeva)	McCann Paul (ismisepaul)
(SajjadPourali) Sage	rbsec	Bauer Benedikt (mastacheata)	Jardine James (jamesjardine)
Burnett Mark (m8urnett)	dschwarz91	Cyber-AppSec (Cyber-AppSec)	Tib3rius
BitnessWise (bitnesswise)	(damienbod) damienbod	Meit Jared (jmeit-fwdsec)	Seelmann Stefan (sseelmann)
O'Connor Brendan (ussjoin)	(andrettv) Titov Andrei	Fjeld Hans-Petter (atluxity)	markehack
Madden Neil (NeilMadden)	Geramb Michael (mgeramb)	Elnaggar Osama (ossie-git)	mackowski
(raviballa) Balla Ravi	(hazanasec) Hazana	Means David (dmeans82)	(tohch4) Stein Alexander
(baesenseii) BaeSenseii	Schutter De Vincent (VincentDS)	(sbani) Bani S	Akiyama Mitsuaki (mak1yama)
Loessl Christopher (hashier)	victorxm	Rada Michal (michalradacz)	Devireddy Veeresh (drveresh)
MaknaSEO	darkzero2022	(LiamDobbelaere) Liam	(jedisct1) Denis Frank
(ottosulin) Sulin Otto	carllaw6885	Holmefjord Johan Anders (aholmis)	(rfricz) Fritsch Richard
mesutgungor	Helme Scott (ScottHelme)	Reggiani Carlo (carloreggiani)	Srivastava Suyash (suyash5053)
Potter Mark (markonweb)	(alamers) Lamers Arjan	(gobrtg) Breivik Gøran	flo-blg
Déflache Guillaume (guillaume-d)	Airane Toufik (toufik-airane)	Hoodlet Keith (securingdev)	(SoftwareSinner) Sinner
iloving	Beckers Jeroen (TheDauntless)	(joubin) Jabbari Joubin	(fujiokayu) fujioka yu

(execjosh) execjosh	(tomato42) Kario Alicja	Ribeiro Sidney (srjsoftware)	Marquet Gabriel (Gby56)
(drschulz) Schulz Drew	bedirhan	muralito	Flathers Ronnie (ropnop)
Ryck De Philippe (philippederyck)	(mal33) Malte	MazeOfThoughts	(andfalk) Falk Andreas
(javixeneize) Javi	(averell23) Hahn Daniel	borislav-c	(digininja) Wood Robin
miro2ns	(jandockx) Dockx Jan	vipinsaini434	priyanshukumar397
Sakimura Nat (sakimura)	Häublein Benjamin (BenjaminHae)	unknown-user-from	TAŞDELEN Ramazan Ali (alitasdln)
(oEscal) Escaleira Pedro	(josh-hemphill) Josh	(SECTim) Würtele Tim	(avidouglen) AviD
SheHacksPurple (shehackspurple)	fcerullo-cycubix	Paredes Eryx Hector (heryxpc) Camacho	Michlin Irene (irene221b)
(TG-Techie) Y-M Jonah	Bahroos Dhiraj (bahroos)	(jefmeijvis) Meijvis Jef	IzmaDoesItbeta
TEMMAR Abdessamad (TmmmmmmR)	sectroyer	(sohsatoh) Satoh Soh	regoravalaz
james-t (james-bitherder)	Hovsepyan Aram (aramhovsepyan)	JaimeGomezGarciaSan	ValdiGit01
(ishowta) iwatachan	Anandan Vinod (VinodAnandan)	(KevinKien) Kien Kevin	paul-williamson-swoop
endergzzr	Alshamamri Radhwan (Rado0z)	(rewtd) Ongers Grant	(cure53) Cure53
AliR2Linux	Dawson Ads (GangGreenTemperTatum)	Reyor William (BillReyor)	(gcrow) gabe
mascotter	luissaiz	Manukyan Suren (vx-sec)	Gliżniewicz Piotr (pglizniewicz)
Wachowski Tadeusz (tadeuszwachowski)	(andesec) Nate aka Nasir	settantasette	(LarsH) Haulin Lars
(edent) Eden Terence	JasmineScholz	Sivadasan Arun (teavanist)	(yusuffgur) GÜR Yusuf
Marshall Troy (troymarshall)	(tprynn) Prynn Tanner	(nickflic) K. Nick	raoul361
(TheAxZim) Ilyas Azeem	(avioli) Stamatov Evo	Potter Tim (timpotter87)	(GavinRay97) Ray Gavin

(demideus) monis	Hoppe Marcin (MarcinHoppe)	(ramshazar) Grambufl	Pike Jordan (computersarebad)
Rogers Jason (jason-invision)	(benbhall) Hall Ben	JamesPoppyCock (jamesly123)	WhiteHackLabs (whitehacklabs)
(alex) Gaynor Alex	Laenen van Filip (filipvanlaenen)	jeurgen	GraoMelo
(ay-kay) Kurtz Andreas	Tervoort Tom (TomTervoort)	(deveras) man old	Schnüriger Marco (marcortw)
stiiin	infoseclearn (teaminfoseclearn)	hljupkij	(nmarher) Noe
(lyz-code) Lyz	(mrtnrdl) Riedel Martin	(tcaesvk) Jaesuck KIM	Schachner Barbara (bschach)
(AresSec) Reuter René	carhackpils	(tyler2cr) Tyler	(hasousa) Hugo
Bloeyaert Wouter (Someniak)	Rijk de Mark (markderijkinfosec)	(picohub) Ramin	Turner D. Philip (philipdturner)
(willc) Chatham Will			